ЗАДАНИЕ НА КУРСОВУЮ РАБОТУ

Студент: Тимошкин П. С.

Группа: 4364

Тема работы: Настройка маршрутизатора Cisco для организации защищённого сегмента сети

Исходные данные:

Вариант: упрощённая корпоративная сеть малого предприятия с демилитаризованной зоной (DMZ) и выходом в Интернет. Среда моделирования – Cisco Modeling Labs. На маршрутизаторе Cisco требуется: настроить адресацию и маршрутизацию между сегментами сети; защитить управление маршрутизатором; настроить защиту от подмены адресов; разграничить доступ между сегментами так, чтобы один клиент имел доступ в DMZ, а другой не имел; обеспечить выход внутренних сетей и DMZ в Интернет и публикацию веб-сервера DMZ; настроить учёт событий с точным временем; проверить работу защиты.

Содержание пояснительной записки:

Титульный лист, задание на курсовую работу, аннотация, содержание, введение, цель работы, разделы, заключение, список использованной литературы, приложения.

Содержание разделов:

Теоретическая часть, проектирование защищённой сети, настройка маршрутизатора, тестирование защиты.

АННОТАЦИЯ

В курсовой работе на маршрутизаторе Cisco под управлением IOS 15.9 построена защищённая сеть малого предприятия: сегмент пользователей, сегмент внутренних серверов, демилитаризованная зона с публичным веб-сервером и выход в Интернет. Работа выполнена на виртуальном стенде в среде Cisco Modeling Labs.

На маршрутизаторе настроены защита управления, фильтрация поддельных адресов, межсетевой экран на зонах, трансляция адресов, синхронизация времени и отправка журнала на сервер. Каждая мера проверена по схеме «до и после», а итоговая конфигурация – атаками с внешнего узла с помощью nmap, hping3 и hydra. Результаты проверок, листинги конфигурации и снимки экрана приведены в работе.

SUMMARY

In this course project a secured small-enterprise network is built on a Cisco router running IOS 15.9. The network consists of a user segment, an internal server segment, a demilitarized zone with a public web server, and an Internet uplink. The work was carried out on a virtual testbed in Cisco Modeling Labs.

The router is configured with management-plane hardening, anti-spoofing filters, a zone-based policy firewall, address translation, time synchronization and remote logging. Each measure is verified with a before-and-after test, and the final configuration is tested with attacks from an external host using nmap, hping3 and hydra. Test results, configuration listings and screenshots are included.

СОДЕРЖАНИЕ

АННОТАЦИЯ 2
ВВЕДЕНИЕ 6
ЦЕЛЬ РАБОТЫ 7
1. ТЕОРЕТИЧЕСКАЯ ЧАСТЬ 9
1.1. Маршрутизатор на границе сети и угрозы для него 9
1.2. Сегментация сети и демилитаризованная зона 10
1.3. Защита управления маршрутизатором 11
1.4. Списки доступа и защита от подмены адреса 12
1.5. Межсетевой экран на зонах 13
1.6. Трансляция сетевых адресов 14
1.7. Синхронизация времени и журналирование 15
2. ПРОЕКТИРОВАНИЕ ЗАЩИЩЁННОЙ СЕТИ 16
2.1. Формулировка задания 16
2.2. Среда моделирования и выбор платформы 17
2.3. Топология сети и роли узлов 17
2.4. План адресации 19
2.5. Политика доступа между сегментами 20
2.6. Рубежи защиты 21
2.7. Порядок выполнения работы 22
3. НАСТРОЙКА МАРШРУТИЗАТОРА 24
3.1. Адресация и маршрутизация 24
3.2. Защита управления маршрутизатором 26
3.2.1. Исходное состояние 27
3.2.2. Пароли и учётные записи 27
3.2.3. Настройка SSH 28
3.2.4. Ограничение доступа к линиям управления 30
3.2.5. Защита от подбора пароля 31
3.2.6. Неиспользуемые службы, предупреждение и консоль 32
3.2.7. Журнал изменений и учётная запись аудитора 33
3.3. Защита от подмены адресов 35
3.3.1. Исходное состояние 35

3.3.2. Проверка обратного пути и входной список доступа 36
3.3.3. Настройки внешнего интерфейса 37
3.3.4. Проверка 37
3.3.5. Защищённая копия конфигурации 39
3.4. Разграничение доступа между сегментами 40
3.4.1. Исходное состояние 40
3.4.2. Зоны и классы трафика 42
3.4.3. Политики 42
3.4.4. Пары зон и включение экрана 43
3.4.5. Защита самого маршрутизатора 45
3.4.6. Проверка 48
3.5. Выход в Интернет и публикация веб-сервера 55
3.5.1. Исходное состояние 55
3.5.2. Трансляция с перегрузкой для выхода в Интернет 55
3.5.3. Статическая трансляция для веб-сервера 57
3.5.4. Публикация веб-сервера 59
3.6. Учёт событий с точным временем 62
3.6.1. Исходное состояние 62
3.6.2. Часовой пояс и формат меток времени 63
3.6.3. Отправка журнала на сервер 63
3.6.4. Синхронизация времени 66
3.6.5. Проверка 68
4. ТЕСТИРОВАНИЕ ЗАЩИТЫ 72
4.1. Методика тестирования 72
4.2. Сводные проверки по пунктам задания 72
4.3. Проверка защиты атаками 76
4.3.1. Разведка портов маршрутизатора 76
4.3.2. Разведка веб-сервера 77
4.3.3. Попытка достичь внутренних сетей 78
4.3.4. Подмена адреса источника 79
4.3.5. Поток пакетов на закрытый порт 80
4.3.6. Подбор пароля SSH 81

4.4. Сводная таблица угроз 82
4.5. Остаточные риски и направления развития 83
ЗАКЛЮЧЕНИЕ 85
СПИСОК ИСПОЛЬЗОВАННОЙ ЛИТЕРАТУРЫ 87
ПРИЛОЖЕНИЕ А. ПОЛНАЯ КОНФИГУРАЦИЯ МАРШРУТИЗАТОРА R1 .. 89
ПРИЛОЖЕНИЕ Б. НАСТРОЙКА УЗЛОВ СТЕНДА 95

ВВЕДЕНИЕ

Сеть малого предприятия обычно подключена к Интернету через одно пограничное устройство. Через него сотрудники выходят в Интернет, через него же посетители попадают на сайт компании. Отдельного межсетевого экрана и штатного специалиста по безопасности у такого предприятия, как правило, нет, поэтому задачи маршрутизации и защиты ложатся на один маршрутизатор.

Если все узлы находятся в одной сети, а маршрутизатор просто пересылает пакеты, то взлом любого узла открывает нарушителю дорогу ко всем остальным. Особенно опасен в этом смысле публичный веб-сервер: он доступен из Интернета по определению, и уязвимость в нём превращает сервер в плацдарм для атаки на рабочие места и внутренние серверы. Сам маршрутизатор тоже является целью: получив доступ к его управлению, нарушитель контролирует весь трафик предприятия.

Решением служит разделение сети на сегменты с разным уровнем доверия и контроль трафика между ними. Публичные сервисы выносятся в демилитаризованную зону (DMZ), внутренние сети скрываются за трансляцией адресов, а доступ к управлению маршрутизатором ограничивается. Все эти функции есть в операционной системе Cisco IOS, и в данной работе они настраиваются на одном маршрутизаторе.

В теме работы говорится о защищённом сегменте сети. Под ним в работе понимается внутренняя сеть предприятия, расположенная за маршрутизатором: сегмент пользователей и сегмент внутренних серверов. Демилитаризованная зона играет роль буфера между этой сетью и Интернетом: в ней находится сервер, который должен быть виден снаружи, но не должен иметь возможности обращаться внутрь.

Работа выполнена на виртуальном стенде в среде Cisco Modeling Labs с настоящим образом Cisco IOS. Это позволило не только ввести команды, но и проверить каждую меру защиты реальным трафиком и инструментами, которыми пользуются при тестировании на проникновение.

Пояснительная записка состоит из четырёх разделов. В первом изложены теоретические сведения о применяемых механизмах. Во втором описаны задание, стенд, топология, адресация и политика доступа. Третий раздел содержит настройку маршрутизатора по пунктам задания с листингами и проверками. В четвёртом приведены итоговые проверки и результаты атак на собранную сеть. В приложениях даны полная конфигурация маршрутизатора и настройки узлов стенда.

ЦЕЛЬ РАБОТЫ

Целью работы является закрепление теоретических знаний о построении и защите компьютерных сетей и получение практических навыков настройки маршрутизатора Cisco для организации защищённого сегмента сети малого предприятия с демилитаризованной зоной и выходом в Интернет.

Для достижения цели решаются следующие задачи:

1) изучить механизмы Cisco IOS, применяемые для защиты сети: средства защиты управления, списки доступа, проверку обратного пути, межсетевой экран на зонах, трансляцию адресов, журналирование;

2) спроектировать сеть малого предприятия: выбрать топологию, составить план адресации и политику доступа между сегментами;

3) собрать стенд в среде моделирования и выполнить базовую настройку маршрутизатора и узлов;

4) защитить управление маршрутизатором;

5) настроить фильтрацию пакетов с поддельным адресом источника;

6) разделить сеть на зоны и настроить межсетевой экран в соответствии с политикой доступа;

7) обеспечить выход внутренних сетей и DMZ в Интернет и публикацию веб-сервера с помощью трансляции адресов;

8) настроить синхронизацию времени и хранение журнала событий на отдельном сервере;

9) проверить каждую меру по схеме «до и после» и испытать итоговую конфигурацию атаками.

1. ТЕОРЕТИЧЕСКАЯ ЧАСТЬ

1.1. Маршрутизатор на границе сети и угрозы для него

Маршрутизатор соединяет сети и пересылает пакеты между ними на сетевом уровне модели OSI [1, 2]. Решение о пересылке он принимает по адресу назначения пакета и таблице маршрутизации. Маршрутизатор, стоящий между сетью предприятия и сетью провайдера, называют пограничным: через него проходит весь обмен предприятия с внешним миром.

Обычная пересылка пакетов ничего не проверяет. Маршрутизатору безразлично, кто отправил пакет, настоящий ли у него адрес источника и ждал ли кто-нибудь этот пакет внутри сети. Поэтому пограничный маршрутизатор без дополнительных настроек не защищает сеть, а лишь соединяет её с Интернетом. Для сети малого предприятия с публичным сервером существенны следующие угрозы:

– разведка: сканирование портов маршрутизатора и узлов сети для поиска доступных служб;

– доступ из Интернета к внутренним узлам, которые не предназначены для внешних пользователей;

– использование взломанного публичного сервера как точки входа во внутреннюю сеть;

– подмена адреса источника (спуфинг), позволяющая выдать пакет за пришедший от доверенного узла;

– захват управления маршрутизатором: перехват пароля в открытом протоколе, подбор пароля, использование лишних служб;

– перегрузка узла или маршрутизатора потоком пакетов (флуд);

– сокрытие следов: без журнала с точным временем невозможно установить, что и когда произошло.

В работе устройства Cisco принято выделять три плоскости. Плоскость управления (management plane) отвечает за доступ администратора: консоль, SSH, журнал, учётные записи. Плоскость контроля (control plane) обслуживает

служебные протоколы самого маршрутизатора, например ответы на ping и синхронизацию времени. Плоскость данных (data plane) пересылает транзитный трафик пользователей. Защищать нужно все три: настройки плоскости данных бесполезны, если нарушитель может войти на маршрутизатор и отключить их.

Ни одна мера в отдельности не закрывает все угрозы, поэтому защита строится в несколько рубежей (эшелонированная оборона). Пакет нарушителя должен последовательно преодолеть несколько независимых проверок, и ошибка в одной из них не открывает сеть целиком.

1.2. Сегментация сети и демилитаризованная зона

Сегментация означает разделение сети на части с разным назначением и разным уровнем доверия. Каждый сегмент является отдельной IP-сетью, а обмен между сегментами идёт только через маршрутизатор, где его можно контролировать. Если узлы находятся в одной сети, они общаются напрямую, и маршрутизатор этого обмена не видит.

Демилитаризованная зона (DMZ) – это отдельный сегмент для серверов, которые должны быть доступны из Интернета: веб-сервер, почтовый сервер и подобные. Такие серверы подвержены атакам больше других, поэтому им доверяют меньше, чем внутренним узлам. Для DMZ действует правило: внешние пользователи могут обращаться к серверу только по опубликованным портам, внутренние пользователи могут обращаться к серверу, а сам сервер не может начинать соединения с внутренней сетью. Тогда взлом сервера не даёт нарушителю прямого пути к рабочим местам и внутренним серверам [19].

Распространены две схемы построения DMZ. В схеме с двумя межсетевыми экранами DMZ расположена между внешним и внутренним экраном. В схеме с одним устройством и тремя интерфейсами («трёхногая» схема) внешняя сеть, внутренняя сеть и DMZ подключены к разным интерфейсам одного устройства. Вторая схема дешевле и проще, поэтому подходит малому предприятию; именно она применена в работе. Её недостаток в том, что безопасность всей сети зависит от одного устройства.

1.3. Защита управления маршрутизатором

Меры по сокращению возможностей для атаки на само устройство называют усилением защиты (hardening). Они относятся прежде всего к плоскости управления [3–5].

Хранение паролей. В конфигурации Cisco IOS пароль может храниться несколькими способами. Тип 0 – открытый текст. Тип 7 – обратимое преобразование, которое восстанавливается за секунды и защищает только от случайного взгляда. Тип 5 – хеш MD5, который сегодня считается слабым. Тип 8 – PBKDF2 на основе SHA-256, тип 9 – scrypt [15]. Алгоритм scrypt требует при вычислении много памяти, поэтому перебор паролей по хешу на специализированном оборудовании обходится дорого. Для паролей администраторов рекомендуется команда `secret` с типом 9.

Удалённый доступ. Протокол Telnet передаёт имя и пароль открытым текстом, и их можно перехватить. Протокол SSH шифрует сеанс и проверяет подлинность сервера по его ключу [14]. На маршрутизаторе следует разрешить только SSH версии 2, выбрать стойкие алгоритмы шифрования и контроля целостности и ограничить адреса, с которых разрешено подключение.

Защита от подбора пароля. Если число попыток входа не ограничено, пароль можно подобрать перебором по словарю. В Cisco IOS есть механизм блокировки входа: после заданного числа неудачных попыток за заданное время маршрутизатор на время перестаёт принимать подключения (тихий режим).

Разграничение прав. В IOS предусмотрено 16 уровней привилегий. Уровень 15 даёт полный доступ, уровень 1 – только просмотр основных сведений. Промежуточным уровням можно назначить отдельные команды. Это позволяет выдать, например, аудитору право читать журнал без права менять настройки.

Сокращение числа служб. Каждая работающая служба расширяет поверхность атаки. Неиспользуемые службы (встроенный веб-сервер, CDP на внешнем интерфейсе, обработка пакетов с маршрутизацией от источника и другие) отключают.

Учёт действий. Изменения конфигурации и попытки входа должны записываться в журнал с указанием пользователя и времени. Без этого нельзя ни расследовать инцидент, ни обнаружить ошибку администратора.

1.4. Списки доступа и защита от подмены адреса

Список доступа (ACL) – это упорядоченный набор правил «разрешить» или «запретить», которые сравниваются с полями пакета. Стандартный список проверяет только адрес источника, расширенный – также адрес назначения, протокол и порты. Правила просматриваются сверху вниз до первого совпадения; в конце любого списка подразумевается запрет всего остального. Список, применённый к интерфейсу, рассматривает каждый пакет отдельно и не знает, относится ли пакет к уже установленному соединению. Такую фильтрацию называют фильтрацией без учёта состояния.

Протокол IP не проверяет подлинность адреса источника: отправитель может записать в пакет любой адрес. Подмену адреса используют, чтобы обойти фильтры по адресам, скрыть источник атаки или направить ответы на третий узел. Противодействие описано в рекомендациях BCP 38 (RFC 2827) и BCP 84 (RFC 3704) [10, 11]: сеть должна отбрасывать пакеты, адрес источника которых не мог появиться на данном интерфейсе.

Применяются два дополняющих друг друга способа. Первый – входной список доступа на внешнем интерфейсе, запрещающий заведомо невозможные адреса источника: частные сети по RFC 1918 [9], служебные диапазоны и собственные адреса предприятия. Из Интернета такие пакеты прийти не могут. Второй способ – проверка обратного пути uRPF (Unicast Reverse Path Forwarding). Получив пакет, маршрутизатор ищет в таблице маршрутизации путь к адресу источника. В строгом режиме пакет принимается, только если этот путь ведёт через тот же интерфейс, на который пакет пришёл. Для uRPF не нужно перечислять адреса вручную: проверка опирается на таблицу маршрутизации.

1.5. Межсетевой экран на зонах

Межсетевой экран с учётом состояния (stateful) запоминает разрешённые соединения в таблице сессий. Когда внутренний узел начинает соединение, экран записывает адреса, порты и состояние соединения и автоматически пропускает ответные пакеты, относящиеся к этой сессии. Пакет, который не начинает разрешённое соединение и не принадлежит существующей сессии, отбрасывается. Благодаря этому достаточно описать, кто имеет право начинать соединение, а обратное направление можно полностью закрыть.

В Cisco IOS такой экран называется Zone-Based Policy Firewall (ZBFW) [6]. Его конфигурация строится из следующих элементов:

– зона (`zone security`) – группа интерфейсов с одинаковым уровнем доверия;

– пара зон (`zone-pair`) – одно направление движения трафика от зоны-источника к зоне-назначению;

– карта классов (`class-map type inspect`) – описание трафика по протоколу или списку доступа;

– карта политики (`policy-map type inspect`) – действие для каждого класса;

– привязка политики к паре зон командой `service-policy`.

Для класса трафика задаётся одно из трёх действий. Действие `inspect` пропускает трафик и создаёт запись в таблице сессий, по которой пройдут ответы. Действие `pass` пропускает пакеты только в одном направлении без запоминания. Действие `drop` отбрасывает пакет; с ключевым словом `log` отбрасывание записывается в журнал. Весь трафик, не попавший ни в один класс, относится к классу `class-default`.

Работа ZBFW подчиняется нескольким правилам. Между интерфейсами одной зоны трафик проходит свободно. Между интерфейсом, входящим в зону, и интерфейсом без зоны трафик запрещён. Между разными зонами трафик

запрещён, пока для этого направления не создана пара зон с политикой. Таким образом, экран работает по принципу «запрещено всё, что не разрешено явно».

Особое место занимает встроенная зона `self`, обозначающая сам маршрутизатор. Трафик, адресованный маршрутизатору или исходящий от него, по умолчанию разрешён. Если же создать пару зон с участием `self`, то для этого направления начинает действовать назначенная политика. Это позволяет защитить плоскости управления и контроля средствами того же экрана.

1.6. Трансляция сетевых адресов

Адреса частных диапазонов (RFC 1918) не маршрутизируются в Интернете. Чтобы узлы с такими адресами могли обмениваться с внешними узлами, пограничный маршрутизатор заменяет адреса в заголовках пакетов. Этот механизм называется трансляцией сетевых адресов (NAT) [13].

В терминологии Cisco различают четыре вида адресов. Inside local – настоящий адрес внутреннего узла. Inside global – адрес, под которым внутренний узел виден снаружи. Outside global – настоящий адрес внешнего узла. Outside local – адрес внешнего узла, каким его видят изнутри; обычно он совпадает с outside global.

В работе используются два вида трансляции. Статическая трансляция (static NAT) постоянно связывает один внутренний адрес с одним публичным и работает в обе стороны. Она нужна серверу, к которому обращаются из Интернета. Трансляция с перегрузкой (PAT, `overload`) позволяет многим внутренним узлам выходить наружу под одним публичным адресом. Соединения различаются по номеру порта источника, а для ICMP – по идентификатору запроса. Запись в таблице трансляций создаётся только тогда, когда соединение начинает внутренний узел.

Трансляция адресов скрывает структуру внутренней сети, но не является средством защиты. Статическая трансляция открывает для внешних узлов все порты сервера, и ограничивать доступ к ним должен межсетевой экран.

При совместной работе NAT и экрана важен порядок обработки пакета [7]. Для пакета, пришедшего с внешнего интерфейса, сначала выполняются входной список доступа и проверка uRPF, затем трансляция адреса назначения, затем маршрутизация и только после этого применяется политика экрана. Поэтому в правилах экрана для опубликованного сервера указывается его настоящий внутренний адрес, а не публичный.

1.7. Синхронизация времени и журналирование

Устройства Cisco сообщают о событиях по протоколу syslog [16]. Каждое сообщение имеет уровень важности от 0 до 7: emergencies, alerts, critical, errors, warnings, notifications, informational, debugging. Чем меньше число, тем серьёзнее событие. Для каждого получателя сообщений задаётся порог: например, порог informational означает, что передаются сообщения уровней от 0 до 6.

Сообщения выводятся на консоль, сохраняются в буфере в оперативной памяти и могут отправляться на внешний сервер. Буфер ограничен по размеру и очищается при перезагрузке, а нарушитель, получивший доступ к устройству, может его стереть. Поэтому журнал хранят на отдельном сервере. Стандартная передача syslog идёт по протоколу UDP, порт 514, без шифрования и без подтверждения доставки.

Журнал полезен только при правильном времени. Если часы маршрутизатора и сервера расходятся, записи об одном событии на разных устройствах невозможно сопоставить. Часы синхронизируют по протоколу NTP [18]. Источники времени образуют иерархию: уровень (stratum) 1 имеют серверы, подключённые к эталонным часам, а каждый следующий уровень синхронизируется от предыдущего. Клиент опрашивает несколько серверов и выбирает лучший.

Сам журнал тоже нуждается в защите: сервер должен принимать записи только от известных источников, а поток сообщений нужно ограничивать, чтобы массовая атака не перегрузила маршрутизатор и не вытеснила из журнала важные записи.

2. ПРОЕКТИРОВАНИЕ ЗАЩИЩЁННОЙ СЕТИ

2.1. Формулировка задания

Тема работы – настройка маршрутизатора Cisco для организации защищённого сегмента сети. Вариант задания – упрощённая корпоративная сеть малого предприятия с демилитаризованной зоной и выходом в Интернет.

К сети предъявлены общие требования. Инфраструктура должна быть простой и наглядной. Клиенты располагаются в разных сегментах, а маршрутизатор находится между ними. В сети должны присутствовать и демилитаризованная зона, и выход в Интернет. Доступ в DMZ должен быть избирательным: один клиент получает его, а другой нет. Работу защиты необходимо показать на практике.

Задание включает семь пунктов. Они перечислены в таблице 2.1 вместе с принятым решением и номером подраздела, в котором пункт выполнен.

Таблица 2.1 – Пункты задания и их выполнение

№	Пункт задания	Принятое решение	Подраздел
1	Настроить адресацию и маршрутизацию между сегментами	Четыре интерфейса R1 в четырёх сетях, маршрут по умолчанию к провайдеру	3.1
2	Защитить управление маршрутизатором	Пароли scrypt, SSH версии 2 только из сети пользователей, блокировка перебора, роли, журнал изменений	3.2
3	Настроить защиту от подмены адресов	Проверка обратного пути uRPF на всех интерфейсах и входной список доступа на внешнем интерфейсе	3.3
4	Разграничить доступ между сегментами; один клиент имеет доступ в DMZ, другой не имеет	Межсетевой экран на зонах: 4 зоны, 20 пар зон, запрет по умолчанию	3.4
5	Обеспечить выход в Интернет и публикацию веб-сервера DMZ	PAT для внутренних сетей, статическая трансляция для сервера	3.5
6	Настроить учёт событий с точным временем	Синхронизация по NTP, отправка журнала на syslog-сервер	3.6
7	Проверить работу защиты	Проверки «до и после» по каждому пункту и атаки с внешнего узла	3.1–3.6, 4

2.2. Среда моделирования и выбор платформы

Стенд собран в среде Cisco Modeling Labs (CML) версии 2.10.0 в бесплатной редакции [8]. CML запущена как виртуальная машина в VMware Workstation 17 Pro и управляется через веб-интерфейс. В отличие от Cisco Packet Tracer, который имитирует поведение устройств, CML запускает настоящие образы операционных систем: маршрутизатор работает под управлением Cisco IOS, узлы – под управлением Linux. Благодаря этому доступны все команды IOS, а проверять защиту можно обычными сетевыми утилитами.

Бесплатная редакция допускает одновременную работу не более пяти узлов. Это ограничение определило состав стенда: один маршрутизатор и четыре узла. Внешний соединитель, через который стенд получает доступ в реальный Интернет, в это число не входит.

В качестве маршрутизатора выбран образ IOSv с операционной системой Cisco IOS версии 15.9(3)M12.

Узлы стенда работают под управлением Alpine Linux 3.23 и Ubuntu 24.04. Виртуальной машине CML выделено 8 ГБ оперативной памяти.

2.3. Топология сети и роли узлов

Сеть построена по схеме с одним маршрутизатором и тремя внутренними сегментами. К маршрутизатору R1 подключены четыре сети: сеть пользователей, сеть внутренних серверов, демилитаризованная зона и внешняя сеть провайдера. Каждый сегмент подключён к отдельному интерфейсу маршрутизатора, поэтому любой обмен между сегментами проходит через R1. Схема сети показана на рисунке 2.1, топология стенда в CML – на рисунке 2.2.

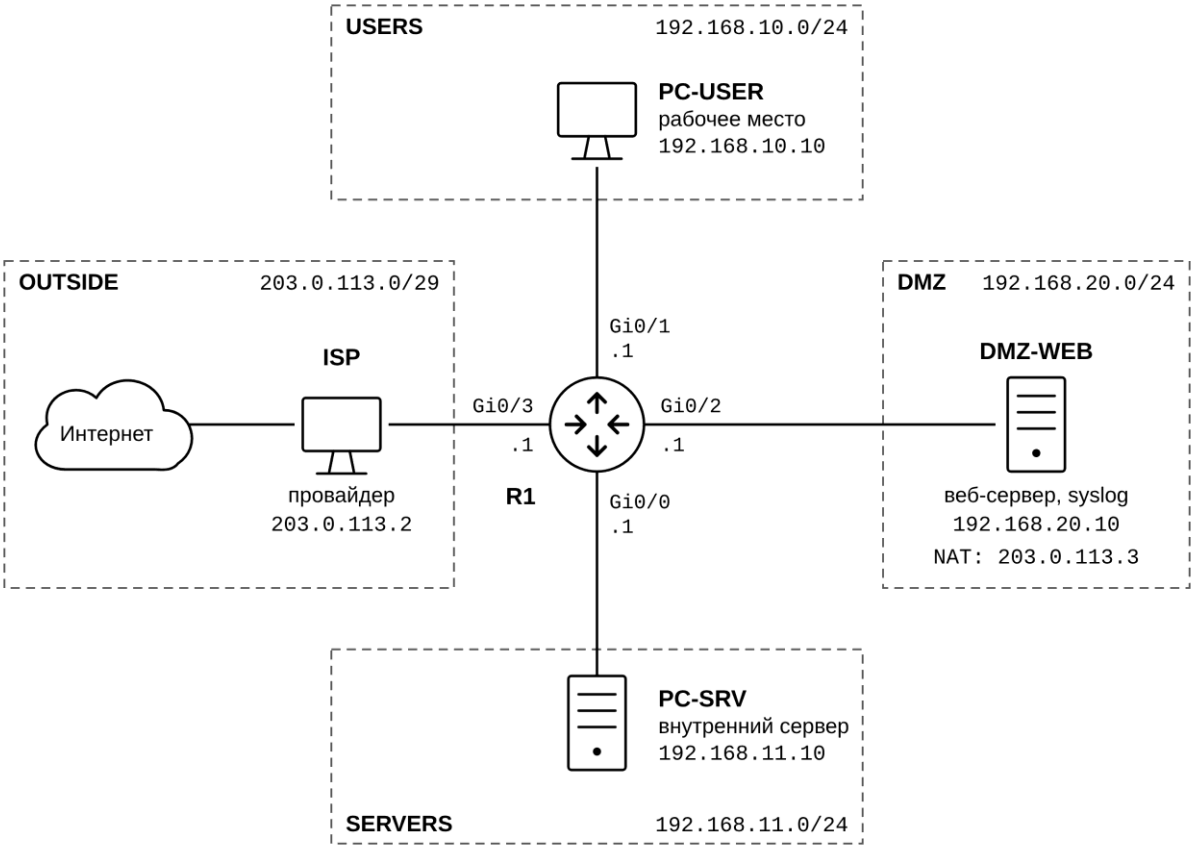


Рисунок 2.1 – Схема сети

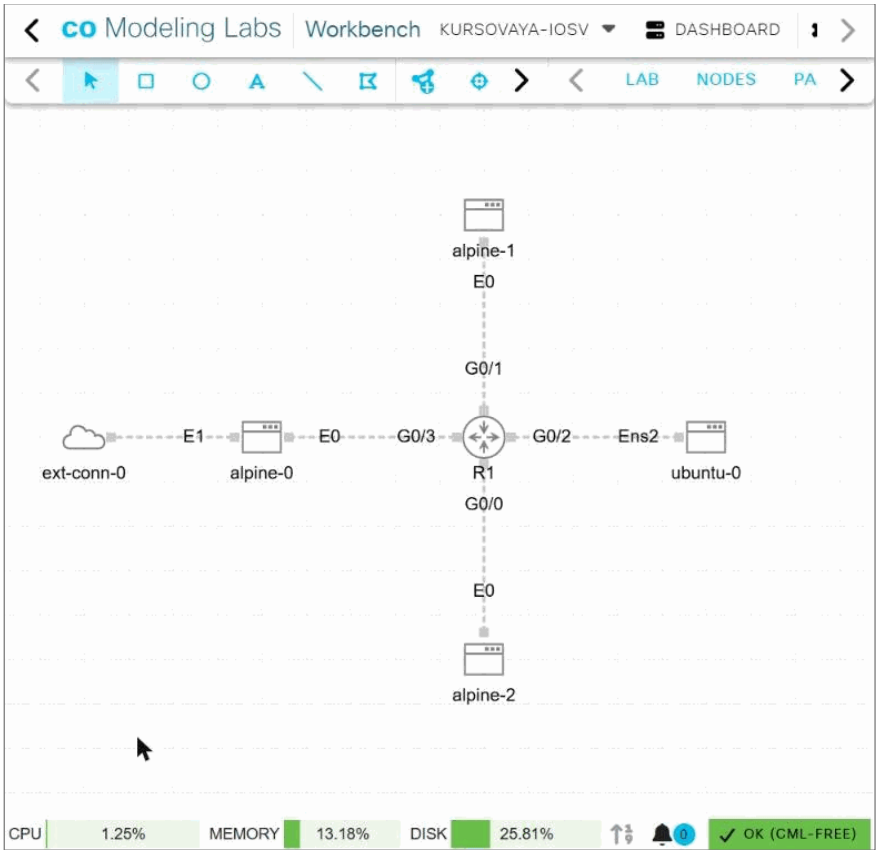


Рисунок 2.2 – Топология стенда в Cisco Modeling Labs

Назначение узлов приведено в таблице 2.3. Каждому узлу в CML присвоено имя, отражающее его роль.

Таблица 2.3 – Узлы стенда и их роли

Узел CML	Имя	Сегмент	Роль в сети
R1	R1	–	Пограничный маршрутизатор Cisco. Соединяет сегменты, фильтрует трафик, транслирует адреса, ведёт журнал
alpine-1	PC-USER	USERS	Рабочее место сотрудника. С него же администратор управляет маршрутизатором. Клиент, которому доступ в DMZ разрешён
alpine-2	PC-SRV	SERVERS	Узел сегмента внутренних серверов. Клиент, которому доступ в DMZ запрещён
ubuntu-0	DMZ-WEB	DMZ	Публичный веб-сервер (nginx, порты 80 и 443) и сервер журналов (rsyslog)
alpine-0	ISP	OUTSIDE	Маршрутизатор провайдера и внешний пользователь. При тестировании – источник атак
ext-conn-0	–	–	Внешний соединитель CML: выход в реальный Интернет

Сегмент SERVERS предназначен для внутренних серверов предприятия, например файлового сервера или сервера учётной системы. В стенде он представлен одним узлом. Этот же узел выступает вторым клиентом из задания: в отличие от рабочего места пользователя, обращаться в DMZ ему не требуется, поэтому такой доступ запрещён.

Узел ISP выполняет две роли. Во-первых, он заменяет сеть провайдера: принимает пакеты от R1 и передаёт их в Интернет. Во-вторых, он является ближайшим к R1 внешним узлом, поэтому с него удобно проверять, как сеть выглядит снаружи, и проводить атаки.

Из-за ограничения на число узлов сервер журналов размещён на том же узле, что и веб-сервер. В реальной сети журнал следует хранить на отдельном узле во внутреннем сегменте; это отмечено в подразделе 4.5.

2.4. План адресации

Для внутренних сегментов выбраны частные сети из диапазона 192.168.0.0/16 с маской /24. Номер сети отражает назначение сегмента. Адрес маршрутизатора в каждой сети оканчивается на .1, адрес узла – на .10.

Для внешней сети использован блок 203.0.113.0/29. Он принадлежит диапазону TEST-NET-3, который по RFC 5737 выделен для примеров и документации [12]. В работе этот блок играет роль публичных адресов, выданных предприятию провайдером. План адресации приведён в таблице 2.4.

Таблица 2.4 – План адресации

Сегмент	Сеть	Интерфейс R1	Адрес R1	Узел	Адрес узла
USERS	192.168.10.0/24	Gi0/1	192.168.10.1	PC-USER	192.168.10.10
SERVERS	192.168.11.0/24	Gi0/0	192.168.11.1	PC-SRV	192.168.11.10
DMZ	192.168.20.0/24	Gi0/2	192.168.20.1	DMZ-WEB	192.168.20.10
OUTSIDE	203.0.113.0/29	Gi0/3	203.0.113.1	ISP	203.0.113.2

Из блока 203.0.113.0/29 используются три адреса. Адрес 203.0.113.1 назначен внешнему интерфейсу R1; под ним выходят в Интернет сегменты USERS и SERVERS. Адрес 203.0.113.2 принадлежит провайдеру и служит шлюзом по умолчанию для R1. Адрес 203.0.113.3 отведён веб-серверу: под ним сервер DMZ виден из Интернета.

Узел ISP имеет второй интерфейс, подключённый к внешнему соединителю CML. Адрес на нём выдаётся автоматически. Пакеты, уходящие в реальный Интернет, узел ISP транслирует в этот адрес, поскольку за пределами стенда сеть 203.0.113.0/29 не маршрутизируется.

2.5. Политика доступа между сегментами

Политика доступа определяет, какой сегмент имеет право начинать соединения с каким. Она построена на принципе наименьших привилегий: разрешено только то, что нужно для работы, остальное запрещено. Ответы на разрешённые соединения проходят автоматически, отдельных разрешений для них не требуется. Политика приведена в таблице 2.5: в строках указан источник соединения, в столбцах – назначение.

Таблица 2.5 – Матрица доступа (кто имеет право начинать соединение)

Откуда \ куда	USERS	SERVERS	DMZ	Интернет	R1
USERS	–	SSH, HTTP, HTTPS, ping	разрешено	разрешено	SSH, ping
SERVERS	запрещено	–	запрещено	разрешено	ping
DMZ	запрещено	запрещено	–	разрешено	ping
Интернет	запрещено	запрещено	только TCP 80 и 443	–	запрещено
R1	разрешено	разрешено	разрешено	разрешено	–

Основные решения объясняются следующим образом.

– Пользователи могут обращаться в DMZ, а внутренние серверы – нет. Это прямое требование задания: сотрудникам сайт компании нужен, серверам обращаться к нему незачем.

– Из Интернета доступен только веб-сервер и только по портам 80 и 443. Остальные порты сервера, включая SSH, для внешних узлов закрыты.

– Сервер DMZ не может начинать соединения с сегментами USERS и SERVERS. Если сервер будет взломан, нарушитель не получит с него прямого доступа во внутреннюю сеть.

– Из Интернета нельзя начать соединение ни с внутренними сегментами, ни с самим маршрутизатором.

– Пользователи обращаются к внутренним серверам только по служебным портам: SSH, HTTP и HTTPS, а также могут проверять доступность серверов командой ping.

– Управлять маршрутизатором по SSH можно только из сегмента USERS, где находится рабочее место администратора.

– Все сегменты могут выходить в Интернет. Это упрощение: в реальной сети исходящий трафик серверов и DMZ также следует ограничивать.

2.6. Рубежи защиты

Защита сети складывается из нескольких независимых механизмов. Пакет, пришедший из Интернета, проходит их по очереди в порядке, показанном на рисунке 2.3. Сначала входной список доступа отбрасывает пакеты с заведомо невозможными адресами источника. Затем проверка обратного пути убеждается,

что источник достижим через тот же интерфейс. После этого выполняется трансляция адреса назначения и выбор маршрута, и только затем пакет попадает в межсетевой экран, который применяет политику соответствующей пары зон.



Рисунок 2.3 – Порядок обработки пакета, пришедшего из Интернета

Соответствие механизмов защиты и угроз приведено в таблице 2.6.

Таблица 2.6 – Механизмы защиты и угрозы

Механизм	От какой угрозы защищает	Подраздел
Пароли scrypt, SSH версии 2, блокировка входа, доступ к управлению только из USERS	Захват управления маршрутизатором: перехват и подбор пароля	3.2
Отключение неиспользуемых служб	Разведка и атаки на лишние службы	3.2, 3.3
Входной список OUTSIDE-IN и uRPF	Подмена адреса источника	3.3
Межсетевой экран на зонах	Доступ к внутренним узлам из Интернета и из DMZ, сканирование портов, обращение к неопубликованным службам	3.4
Трансляция адресов	Раскрытие внутренней адресации; прямое обращение к внутренним адресам	3.5
Журнал на отдельном сервере, время по NTP, защищённая копия конфигурации	Сокрытие следов, уничтожение журнала и конфигурации	3.3, 3.6

2.7. Порядок выполнения работы

Пункты задания выполнялись в том порядке, в котором они перечислены в таблице 2.1. Порядок выбран не случайно: каждый следующий пункт опирается

на предыдущие. Сначала обеспечивается связность сети, затем защищается управление маршрутизатором, чтобы дальнейшая настройка шла по защищённому каналу. После этого закрывается подмена адресов, на которой могли бы основываться обходы следующих правил. Затем настраивается межсетевой экран, и только после него – трансляция адресов и публикация сервера, поскольку публиковать сервер без экрана небезопасно. Журнал и время настраиваются последними, когда появились события, которые нужно учитывать.

Каждая мера защиты проверялась по единой схеме «до и после». До настройки фиксировалось исходное поведение сети, то есть сама уязвимость. Затем вводились команды. После настройки та же проверка повторялась, и результат сравнивался с исходным. Там, где это возможно, отказ подтверждается тремя независимыми способами: результатом на стороне клиента, счётчиком на маршрутизаторе и записью в журнале.

Команды вводились с консоли маршрутизатора и узлов в веб-интерфейсе CML. Снимки экрана сделаны там же. Значения паролей в записке не приводятся, а хеши паролей в листингах и на снимках скрыты.

3. НАСТРОЙКА МАРШРУТИЗАТОРА

В разделе описано выполнение пунктов задания с первого по шестой. Для каждого пункта приведены исходное состояние, введённые команды с пояснениями и проверка результата. Полная итоговая конфигурация маршрутизатора дана в приложении А, настройки узлов стенда – в приложении Б.

3.1. Адресация и маршрутизация

Первый пункт задания – обеспечить связность сети. Маршрутизатору присвоено имя, на четырёх интерфейсах заданы адреса согласно плану адресации, интерфейсы включены. Для выхода во внешнюю сеть задан статический маршрут по умолчанию через адрес провайдера. Сети, подключённые к интерфейсам напрямую, попадают в таблицу маршрутизации автоматически, поэтому других маршрутов не требуется. Команды приведены в листинге 3.1.

Листинг 3.1 – Базовая настройка R1

```
hostname R1
! Не искать опечатки в командах как имена узлов в DNS
no ip domain lookup
!
interface GigabitEthernet0/0
 description INSIDE-SERVERS
 ip address 192.168.11.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/1
 description INSIDE-USERS
 ip address 192.168.10.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/2
 description DMZ
 ip address 192.168.20.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/3
 description OUTSIDE
 ip address 203.0.113.1 255.255.255.248
 no shutdown
!
! Маршрут по умолчанию: всё, что не в своих сетях, - провайдеру
ip route 0.0.0.0 0.0.0.0 203.0.113.2
!
! Сообщения журнала не разрывают вводимую команду
line con 0
 logging synchronous
```

На узлах заданы статические адреса и шлюз по умолчанию – адрес R1 в соответствующей сети. Состояние интерфейсов после настройки показано на рисунке 3.1: все четыре интерфейса имеют адреса и находятся в состоянии up.

```
R1#show ip interface brief
Interface                  IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0         192.168.11.1    YES manual up                    up
GigabitEthernet0/1         192.168.10.1    YES manual up                    up
GigabitEthernet0/2         192.168.20.1    YES manual up                    up
GigabitEthernet0/3         203.0.113.1     YES manual up                    up
R1#
```

Рисунок 3.1 – Состояние интерфейсов R1

Таблица маршрутизации (рисунок 3.2) содержит четыре подключённые сети и маршрут по умолчанию через 203.0.113.2.

```
R1#show ip route
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
       a - application route
       + - replicated route, % - next hop override, p - overrides from PfR

Gateway of last resort is 203.0.113.2 to network 0.0.0.0

S*    0.0.0.0/0 [1/0] via 203.0.113.2
      192.168.10.0/24 is variably subnetted, 2 subnets, 2 masks
C        192.168.10.0/24 is directly connected, GigabitEthernet0/1
L        192.168.10.1/32 is directly connected, GigabitEthernet0/1
      192.168.11.0/24 is variably subnetted, 2 subnets, 2 masks
C        192.168.11.0/24 is directly connected, GigabitEthernet0/0
L        192.168.11.1/32 is directly connected, GigabitEthernet0/0
      192.168.20.0/24 is variably subnetted, 2 subnets, 2 masks
C        192.168.20.0/24 is directly connected, GigabitEthernet0/2
L        192.168.20.1/32 is directly connected, GigabitEthernet0/2
      203.0.113.0/24 is variably subnetted, 2 subnets, 2 masks
C        203.0.113.0/29 is directly connected, GigabitEthernet0/3
L        203.0.113.1/32 is directly connected, GigabitEthernet0/3
R1#
```

Рисунок 3.2 – Таблица маршрутизации R1

Связность проверена командой ping с маршрутизатора до всех узлов (рисунок 3.3) и между сегментами (рисунок 3.4). Потеря первого пакета в двух проверках объясняется тем, что маршрутизатор в этот момент ещё определял MAC-адрес узла по протоколу ARP.

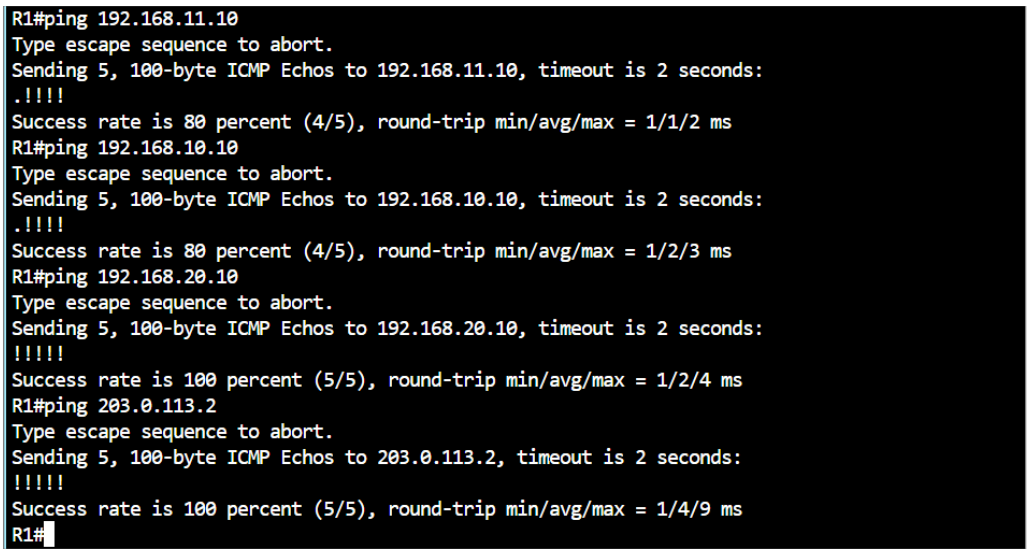


Рисунок 3.3 – Проверка связи R1 с узлами

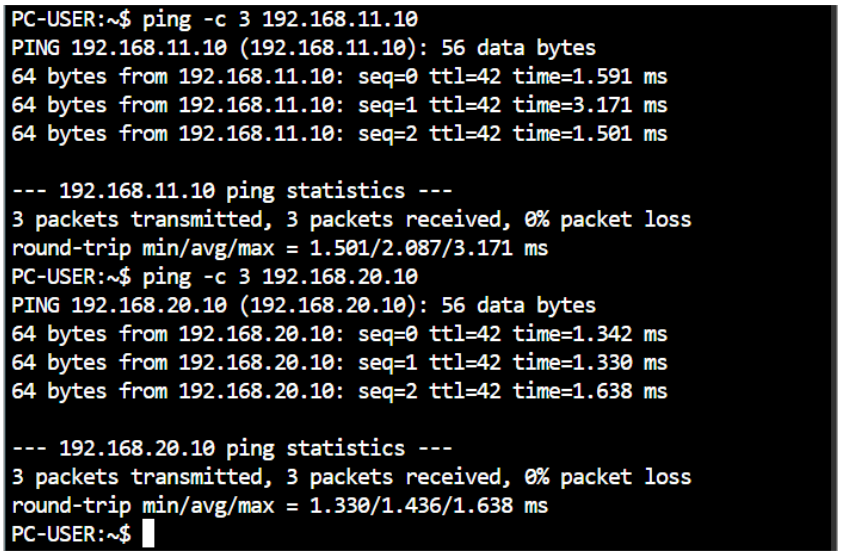


Рисунок 3.4 – Проверка связи между сегментами: узел PC-USER достигает сегментов SERVERS и DMZ

На этом шаге маршрутизатор пересылает пакеты между всеми сегментами без ограничений. Сеть работает, но не защищена: любой узел может обратиться к любому другому. Это состояние служит исходным для всех последующих проверок.

3.2. Защита управления маршрутизатором

Второй пункт задания – защитить доступ к управлению маршрутизатором. Настройка выполнена в первую очередь, чтобы вся дальнейшая работа шла через защищённое управление.

3.2.1. Исходное состояние

Состояние маршрутизатора до настройки показано на рисунке 3.5. Служба SSH выключена, поскольку ключ ещё не создан. На виртуальных линиях vty указано `transport input none`, то есть удалённое подключение закрыто полностью. Встроенный веб-сервер выключен. Протокол CDP включён. На консоли вход не запрашивается: строка `login` в разделе `line con 0` отсутствует, пароль привилегированного режима не задан.

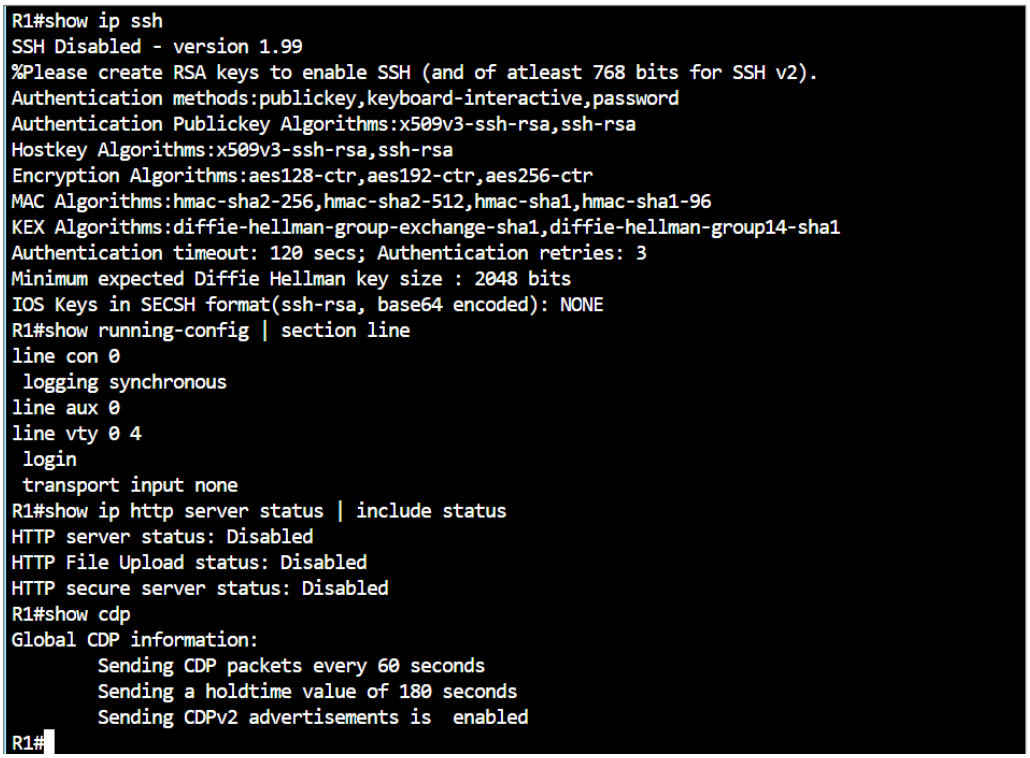


Рисунок 3.5 – Состояние служб управления до настройки

Таким образом, образ IOSv по умолчанию не открывает лишних сетевых служб, но и не имеет ни защиты консоли, ни безопасного удалённого управления. Требуется задать учётные записи, включить SSH, ограничить круг адресов управления и настроить учёт действий.

3.2.2. Пароли и учётные записи

Команды приведены в листинге 3.2. Требование к минимальной длине пароля вводится раньше самих паролей, чтобы оно распространялось на них. Пароли хранятся в виде хеша scrypt (тип 9). Вместо общего пароля на линии

используется персональная учётная запись: в журнале видно, кто именно выполнил вход и изменил настройки.

Листинг 3.2 – Пароли и учётная запись администратора

```
! Пароли короче 10 символов отклоняются
security passwords min-length 10
! Пароль привилегированного режима, хеш scrypt (тип 9)
enable algorithm-type scrypt secret <ПАРОЛЬ>
! Персональная учётная запись администратора, уровень 15
username admin privilege 15 algorithm-type scrypt secret <ПАРОЛЬ>
! Скрыть оставшиеся пароли открытого типа (тип 7)
service password-encryption
```

Проверка длины показана на рисунке 3.6: пароль из четырёх символов отклонён сообщением `Invalid Password length - must contain 10 to 25 characters`. На рисунке 3.7 видно, что оба пароля сохранены как `secret 9`.

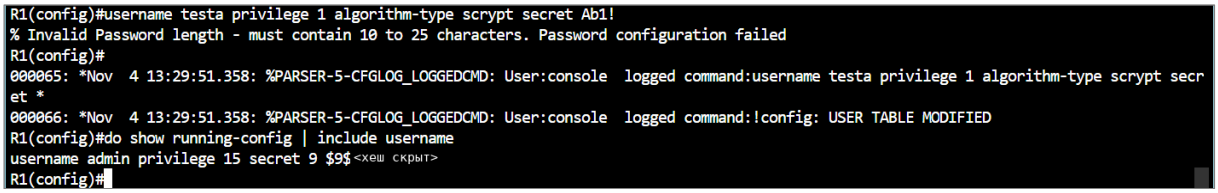


Рисунок 3.6 – Короткий пароль отклонён

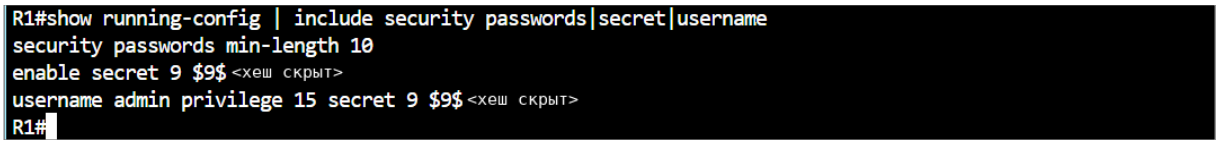


Рисунок 3.7 – Пароли хранятся в виде хеша scrypt (тип 9)

3.2.3. Настройка SSH

Для SSH нужны имя узла, доменное имя и пара ключей RSA. Создан ключ длиной 2048 бит. Затем разрешена только вторая версия протокола, сокращено время на аутентификацию и ограничено число попыток ввода пароля в одном соединении. Из предлагаемых сервером алгоритмов исключены устаревшие: коды аутентичности на основе SHA-1 и обмен ключами с группой, размер которой выбирает клиент. Команды приведены в листинге 3.3.

Листинг 3.3 – Настройка SSH

```
ip domain name lab.local
! Пара ключей RSA 2048 бит с именем R1.lab.local
crypto key generate rsa general-keys modulus 2048
ip ssh rsa keypair-name R1.lab.local
! Только SSH версии 2
ip ssh version 2
! 60 секунд на вход, не более 3 попыток пароля за соединение
ip ssh time-out 60
ip ssh authentication-retries 3
! Группа Диффи-Хеллмана не менее 2048 бит
ip ssh dh min size 2048
! Записывать события SSH в журнал
ip ssh logging events
! Разрешённые алгоритмы
ip ssh server algorithm encryption aes256-ctr aes192-ctr aes128-ctr
ip ssh server algorithm mac hmac-sha2-512 hmac-sha2-256
ip ssh server algorithm kex diffie-hellman-group14-sha1
! Разрывать зависшие TCP-соединения
service tcp-keepalives-in
service tcp-keepalives-out
```

Результат показан на рисунке 3.8. Служба включена в версии 2.0, время аутентификации сокращено со 120 до 60 секунд, список алгоритмов сужен. Число попыток и минимальный размер группы Диффи–Хеллмана совпадают со значениями по умолчанию для этого образа (они видны и на рисунке 3.5), поэтому в итоговой конфигурации эти две строки не отображаются.

```
R1#show ip ssh
SSH Enabled - version 2.0
Authentication methods:publickey,keyboard-interactive,password
Authentication Publickey Algorithms:x509v3-ssh-rsa,ssh-rsa
Hostkey Algorithms:x509v3-ssh-rsa,ssh-rsa
Encryption Algorithms:aes256-ctr,aes192-ctr,aes128-ctr
MAC Algorithms:hmac-sha2-512,hmac-sha2-256
KEX Algorithms:diffie-hellman-group14-sha1
Authentication timeout: 60 secs; Authentication retries: 3
Minimum expected Diffie Hellman key size : 2048 bits
```

Рисунок 3.8 – Параметры SSH после настройки

Действие ограничений проверено с клиента (рисунок 3.9). При попытке использовать код аутентичности hmac-sha1 или шифр aes128-cbc сервер отказывает: общего алгоритма не найдено.

```
PC-USER:~$ ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithm
s=+ssh-rsa -o MACs=hmac-sha1 admin@192.168.10.1
Unable to negotiate with 192.168.10.1 port 22: no matching MAC found. Their offer: hmac-sha2-512,hmac-sha2-256
PC-USER:~$ ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithm
s=+ssh-rsa -c aes128-cbc admin@192.168.10.1
Unable to negotiate with 192.168.10.1 port 22: no matching cipher found. Their offer: aes256-ctr,aes192-ctr,aes128-ctr
PC-USER:~$
```

Рисунок 3.9 – Подключение со слабыми алгоритмами отклонено

3.2.4. Ограничение доступа к линиям управления

Удалённое управление разрешено только по SSH и только из сети пользователей, где находится рабочее место администратора. Для этого создан стандартный список доступа и применён к линиям vty (листинг 3.4). Запрещающая строка указана явно и с ключевым словом `log`, чтобы каждая отклонённая попытка попадала в журнал. Простаивающий сеанс закрывается через пять минут.

Листинг 3.4 – Ограничение доступа к линиям vty

```
ip access-list standard MGMT-ACCESS
 permit 192.168.10.0 0.0.0.255
 deny   any log
!
line vty 0 4
 ! Подключаться можно только с адресов из списка
 access-class MGMT-ACCESS in
 ! Только SSH; Telnet не принимается
 transport input ssh
 ! Вход по локальным учётным записям
 login local
 ! Закрывать сеанс после 5 минут бездействия
 exec-timeout 5 0
```

Подключение с узла PC-USER проходит успешно (рисунок 3.10). Попытки с узла PC-SRV отклоняются (рисунок 3.11), а в журнале маршрутизатора появляются записи `%SEC-6-IPACCESSLOGNP: list MGMT-ACCESS denied` с адресом источника (рисунок 3.12). Счётчики списка показывают четыре разрешённых и три отклонённых подключения.

```
PC-USER:~$ ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithm
s=+ssh-rsa admin@192.168.10.1
The authenticity of host '192.168.10.1 (192.168.10.1)' can't be established.
RSA key fingerprint is: SHA256:m1aW0A0/PkE2Kv92PAxvm7BLjNVx8MqNBEkBTN/R89I
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.10.1' (RSA) to the list of known hosts.

WARNING: Authorized access only.
All activity on this device is logged and monitored.
Disconnect now if you are not an authorized user.
(admin@192.168.10.1) Password:



**************************************************************************
* IOSv is strictly limited to use for evaluation, demonstration and IOS  *
* education. IOSv is provided as-is and is not supported by Cisco's      *
* Technical Advisory Center. Any use or disclosure, in whole or in part, *
* of the IOSv Software or Documentation to any third party for any       *
* purposes is expressly prohibited except as otherwise authorized by     *
* Cisco in writing.                                                      *
**************************************************************************
R1#show ssh
Connection Version Mode  Encryption  Hmac          State               Username
0          2.0     IN    aes128-ctr  hmac-sha2-256 Session started       admin
0          2.0     OUT   aes128-ctr  hmac-sha2-256 Session started       admin
```

Рисунок 3.10 – Подключение по SSH из сети пользователей

```
PC-SRV:~$ ssh -o ConnectTimeout=5 admin@192.168.11.1
ssh: connect to host 192.168.11.1 port 22: Connection refused
PC-SRV:~$ ssh -o ConnectTimeout=5 admin@192.168.10.1
ssh: connect to host 192.168.10.1 port 22: Connection refused
PC-SRV:~$
```

Рисунок 3.11 – Подключение из сети серверов отклонено

```
000115: *Nov  4 13:37:09.690: %SEC-6-IPACCESSLOGNP: list MGMT-ACCESS denied 0 192.168.11.10 -> 0.0.0.0, 1 packet
R1#
000116: *Nov  4 13:37:30.212: %SEC-6-IPACCESSLOGNP: list MGMT-ACCESS denied 0 203.0.113.2 -> 0.0.0.0, 1 packet
R1#
R1#show access-lists MGMT-ACCESS
Standard IP access list MGMT-ACCESS
    10 permit 192.168.10.0, wildcard bits 0.0.0.255 (4 matches)
    20 deny   any log (3 matches)
R1#
```

Рисунок 3.12 – Записи журнала и счётчики списка MGMT-ACCESS

3.2.5. Защита от подбора пароля

Команды листинга 3.5 включают блокировку входа. Если за 60 секунд происходит три неудачные попытки, маршрутизатор на 120 секунд переходит в тихий режим и отклоняет новые подключения. Успешные и неудачные входы записываются в журнал.

Листинг 3.5 – Блокировка входа при подборе пароля

```
! 3 неудачи за 60 с -> тихий режим на 120 с
login block-for 120 attempts 3 within 60
! Записывать неудачные и успешные входы
login on-failure log
login on-success log
```

Проверка показана на рисунках 3.13 и 3.14. После трёх записей `LOGIN_FAILED` в журнале появляется сообщение `QUIET_MODE_ON`, а команда `show login` сообщает, что маршрутизатор находится в тихом режиме и до его окончания остаётся 73 секунды. Через 120 секунд режим снимается автоматически. Блокировка действует только на удалённые подключения: войти с консоли можно всегда.

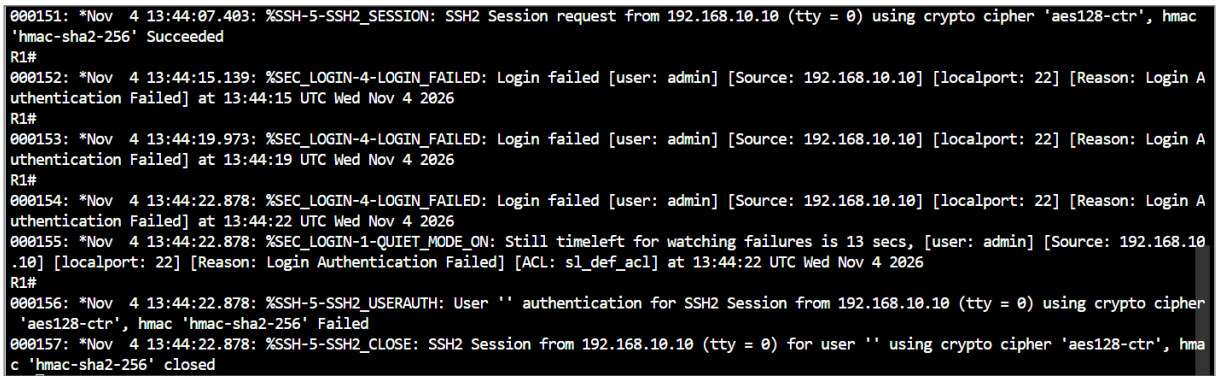


Рисунок 3.13 – Три неудачные попытки входа и включение тихого режима

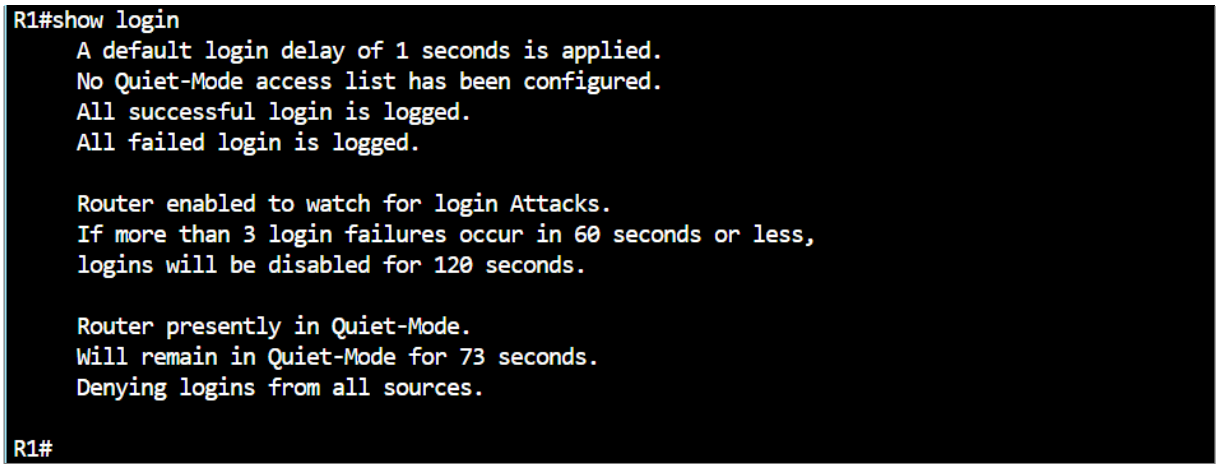


Рисунок 3.14 – Состояние блокировки входа

3.2.6. Неиспользуемые службы, предупреждение и консоль

Службы, которые в этой сети не нужны, отключены (листинг 3.6). Перед запросом имени пользователя выводится предупреждение о том, что доступ

разрешён только уполномоченным лицам и действия записываются. На консоли включён вход по локальной учётной записи.

Листинг 3.6 – Отключение служб, предупреждение, защита консоли

```
! Встроенный веб-сервер
no ip http server
no ip http secure-server
! CDP сообщает соседям модель и версию устройства
no cdp run
! Пакеты с маршрутом, заданным отправителем
no ip source-route
! Устаревшие службы
no service pad
no ip bootp server
!
banner login ^
WARNING: Authorized access only.
All activity on this device is logged and monitored.
Disconnect now if you are not an authorized user.
^
!
line con 0
 login local
 exec-timeout 10 0
```

Вход с консоли после настройки показан на рисунке 3.15: выводится предупреждение, запрашиваются имя и пароль, успешный вход записан в журнал.



Рисунок 3.15 – Вход с консоли по учётной записи

3.2.7. Журнал изменений и учётная запись аудитора

Чтобы каждое изменение конфигурации оставляло след, включён журнал команд (листинг 3.7). В него записываются введённая команда и имя пользователя; пароли в командах заменяются звёздочкой. Записи журнала

нумеруются, поэтому пропуск номера выдаёт потерянную или удалённую запись.

Листинг 3.7 – Журнал изменений конфигурации и роль аудитора

```
! Номер и время в каждой записи журнала
service sequence-numbers
service timestamps log datetime msec
!
archive
 log config
  ! Записывать каждую команду конфигурации
  logging enable
  logging size 200
  ! Дублировать записи в системный журнал
  notify syslog contenttype plaintext
  ! Не показывать пароли
  hidekeys
!
! Аудитор: уровень 5, из дополнительных команд - только просмотр журнала
privilege exec level 5 show logging
username auditor privilege 5 algorithm-type scrypt secret <ПАРОЛЬ>
```

Журнал команд показан на рисунке 3.16. Для проверяющего создана отдельная учётная запись с уровнем привилегий 5. На рисунке 3.17 видно, что аудитор может просматривать журнал, но команды `configure terminal` и `show running-config` ему недоступны.

```
  3    1       console@console  |  logging size 200
  4    1       console@console  |  notify syslog contenttype plaintext
  5    1       console@console  |  hidekeys
  6    1       console@console  |  exit
  7    1       console@console  |   exit
  8    1       console@console  |security passwords min-length 10
  9    1       console@console  |enable algorithm-type scrypt secret *
 10    1       console@console  |username admin privilege 15 algorithm-type scrypt secret *
 11    1       console@console  |!config: USER TABLE MODIFIED
 12    1       console@console  |username testa privilege 1 algorithm-type scrypt secret *
 13    1       console@console  |!config: USER TABLE MODIFIED
 14    1       console@console  |service password-encryption
 15    1       console@console  |ip domain name lab.local
 16    1       console@console  |crypto key generate rsa general-keys modulus 2048
 17    1       console@console  |ip ssh rsa keypair-name *
 18    1       console@console  |ip ssh version 2
 19    1       console@console  |ip ssh time-out 60
 20    1       console@console  |ip ssh authentication-retries 3
 21    1       console@console  |ip ssh logging events
 22    1       console@console  |ip ssh dh min size 2048
 23    1       console@console  |service tcp-keepalives-in
 24    1       console@console  |service tcp-keepalives-out
 25    1       console@console  |ip access-list standard MGMT-ACCESS
 26    1       console@console  | permit 192.168.10.0 0.0.0.255
 27    1       console@console  | deny any log
 28    1       console@console  | exit
 29    1       console@console  |line vty 0 4
 30    1       console@console  | access-class MGMT-ACCESS in
```

Рисунок 3.16 – Журнал изменений конфигурации

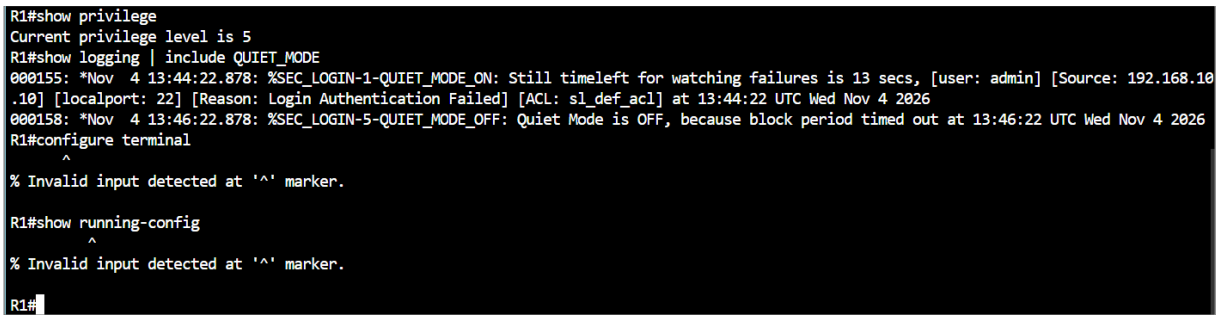


Рисунок 3.17 – Права учётной записи аудитора

3.3. Защита от подмены адресов

Третий пункт задания – не допустить прохождения пакетов с поддельным адресом источника. Мера реализована до межсетевого экрана, поскольку правила экрана опираются на адреса: если адрес можно подделать, правило можно обойти.

3.3.1. Исходное состояние

До настройки проведены две проверки. В первой узел PC-SRV отправил пакеты в DMZ, указав в качестве источника адрес 192.168.10.99 из сети пользователей. Сервер DMZ получил эти пакеты (рисунок 3.18). Во второй проверке узел ISP отправил маршрутизатору пакеты от имени частного адреса 10.10.10.10 и получил ответы (рисунок 3.19). Маршрутизатор не проверял ни то, ни другое.

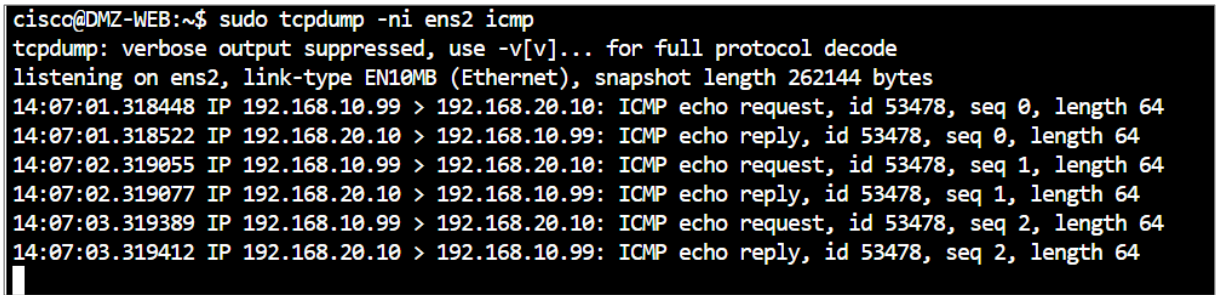


Рисунок 3.18 – До настройки: пакеты с поддельным адресом источника дошли до сервера DMZ

```
ISP:~$ sudo ip addr add 10.10.10.10/32 dev eth0
ISP:~$ ping -c 3 -I 10.10.10.10 203.0.113.1
PING 203.0.113.1 (203.0.113.1) from 10.10.10.10: 56 data bytes
64 bytes from 203.0.113.1: seq=0 ttl=42 time=1.906 ms
64 bytes from 203.0.113.1: seq=1 ttl=42 time=2.080 ms
64 bytes from 203.0.113.1: seq=2 ttl=42 time=6.848 ms

--- 203.0.113.1 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max = 1.906/3.611/6.848 ms
```

Рисунок 3.19 – До настройки: R1 отвечает на пакеты с частным адресом, пришедшие извне

3.3.2. Проверка обратного пути и входной список доступа

На каждом интерфейсе включена проверка обратного пути в строгом режиме (листинг 3.8). На внутренних интерфейсах она требует, чтобы адрес источника принадлежал сети этого интерфейса. На внешнем интерфейсе добавлено слово `allow-default`: адреса Интернета достижимы только по маршруту по умолчанию, и без этого слова строгая проверка отбрасывала бы все внешние пакеты.

Проверка обратного пути на внешнем интерфейсе не отличает частные адреса от настоящих, поскольку маршрут по умолчанию подходит к любому адресу. Поэтому на вход внешнего интерфейса дополнительно применён список доступа OUTSIDE-IN. Он запрещает частные диапазоны, служебные диапазоны и собственные публичные адреса предприятия, а остальное пропускает. Решение о том, кому и куда можно обращаться, этот список не принимает – это задача межсетевого экрана.

Листинг 3.8 – Проверка обратного пути и список OUTSIDE-IN

```
interface GigabitEthernet0/0
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/1
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/2
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/3
 ip verify unicast source reachable-via rx allow-default
!
ip access-list extended OUTSIDE-IN
 remark Anti-spoofing: private sources (RFC 1918)
 deny   ip 10.0.0.0 0.255.255.255 any log
 deny   ip 172.16.0.0 0.15.255.255 any log
 deny   ip 192.168.0.0 0.0.255.255 any log
 remark Anti-spoofing: special-use sources
 deny   ip 0.0.0.0 0.255.255.255 any log
 deny   ip 127.0.0.0 0.255.255.255 any log
 deny   ip 169.254.0.0 0.0.255.255 any log
 deny   ip 224.0.0.0 15.255.255.255 any log
 deny   ip 240.0.0.0 15.255.255.255 any log
 remark Anti-spoofing: our own addresses
 deny   ip host 203.0.113.1 any log
 deny   ip host 203.0.113.3 any log
 remark Everything else passes
 permit ip any any
!
interface GigabitEthernet0/3
 ip access-group OUTSIDE-IN in
```

3.3.3. Настройки внешнего интерфейса

На внешнем интерфейсе отключены три функции, которые помогают разведке (листинг 3.9). Сообщения ICMP unreachable раскрывают, какие адреса и порты существуют, и позволяют построить путь до сети. Сообщения ICMP redirect могут использоваться для изменения маршрутов соседей. Функция proxy ARP заставляет маршрутизатор отвечать на запросы ARP за чужие адреса.

Листинг 3.9 – Настройки внешнего интерфейса

```
interface GigabitEthernet0/3
 no ip redirects
 no ip unreachables
 no ip proxy-arp
```

3.3.4. Проверка

После настройки обе проверки повторены. Пакеты узла PC-SRV с адресом источника 192.168.10.99 до сервера больше не доходят. Счётчик проверки обратного пути на интерфейсе Gi0/0 показывает три отброшенных пакета

(рисунок 3.20). На том же рисунке видны счётчики списка OUTSIDE-IN и отключённый proxy ARP.

```
R1#show ip interface GigabitEthernet0/0 | include verif
  IP verify source reachable-via RX
   3 verification drops
   0 suppressed verification drops
   0 verification drop-rate
R1#show ip interface GigabitEthernet0/3 | include verif
  IP verify source reachable-via RX, allow default
   0 verification drops
   0 suppressed verification drops
   0 verification drop-rate
R1#show ip access-lists OUTSIDE-IN
Extended IP access list OUTSIDE-IN
    10 deny ip 10.0.0.0 0.255.255.255 any log (3 matches)
    20 deny ip 172.16.0.0 0.15.255.255 any log
    30 deny ip 192.168.0.0 0.0.255.255 any log (3 matches)
    40 deny ip 0.0.0.0 0.255.255.255 any log
    50 deny ip 127.0.0.0 0.255.255.255 any log
    60 deny ip 169.254.0.0 0.0.255.255 any log
    70 deny ip 224.0.0.0 15.255.255.255 any log
    80 deny ip 240.0.0.0 15.255.255.255 any log
    90 deny ip host 203.0.113.1 any log
    100 deny ip host 203.0.113.3 any log
    110 permit ip any any (4 matches)
R1#$erface GigabitEthernet0/3 | include redirects|unreachables|Proxy ARP
  Proxy ARP is disabled
  Local Proxy ARP is disabled
  ICMP redirects are never sent
  ICMP unreachables are never sent
R1#
```

Рисунок 3.20 – Счётчики проверки обратного пути и списка OUTSIDE-IN

Пакеты узла ISP с адресом 10.10.10.10 остаются без ответа (рисунок 3.21), а в журнале появляются записи `%SEC-6-IPACCESSLOGDP: list OUTSIDE-IN denied` (рисунок 3.22). Счётчик проверки обратного пути на внешнем интерфейсе остался нулевым: поддельные пакеты отбрасывает список доступа, который обрабатывается раньше.

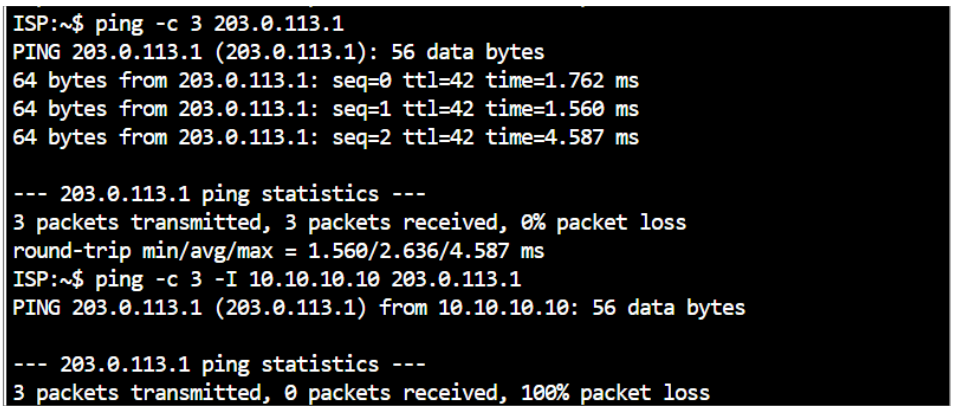


Рисунок 3.21 – После настройки: пакеты с частным адресом источника извне остаются без ответа



Рисунок 3.22 – Записи журнала о пакетах, отброшенных списком OUTSIDE-IN

Трассировка маршрута с узла ISP больше не показывает адрес маршрутизатора: вместо него выводится звёздочка (рисунок 3.23).

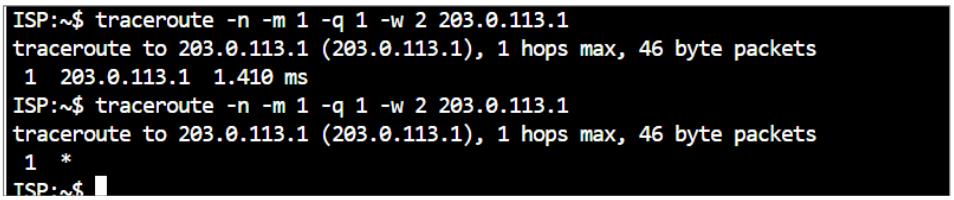


Рисунок 3.23 – Трассировка маршрута извне: R1 не раскрывает свой адрес

3.3.5. Защищённая копия конфигурации

Командой `secure boot-config` включено хранение защищённой копии конфигурации. Копия записывается во флеш-память как скрытый файл, который не виден в списке файлов и не удаляется обычными командами. Если конфигурацию сотрут, её можно восстановить из этой копии. Результат показан на рисунке 3.24. После завершения всех настроек копия была обновлена (подраздел 3.6).

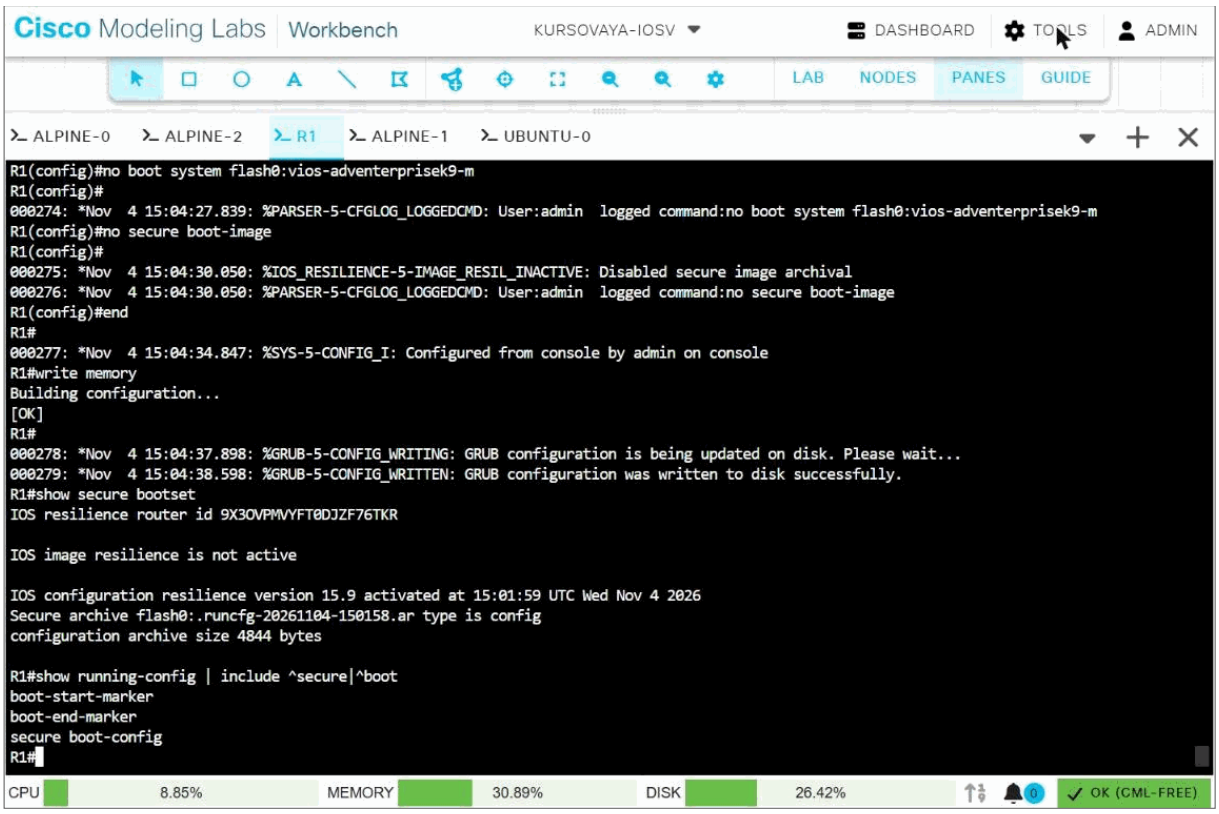


Рисунок 3.24 – Защищённая копия конфигурации

3.4. Разграничение доступа между сегментами

Четвёртый пункт задания – разграничить доступ между сегментами. Для этого на маршрутизаторе настроен межсетевой экран на зонах, реализующий матрицу доступа из таблицы 2.5.

3.4.1. Исходное состояние

До настройки экрана маршрутизатор пересылал между сегментами любые пакеты. Чтобы зафиксировать это, на сервере DMZ были временно запущены простые веб-службы на портах 80, 443 и 8080, а на узле ISP временно добавлен маршрут к внутренним сетям через R1. Узел PC-SRV, которому доступ в DMZ должен быть запрещён, открывал страницу сервера (рисунок 3.25). Узел ISP из внешней сети получал ответы на ping от рабочего места пользователя и открывал неопубликованный порт 8080 сервера (рисунок 3.26). После проверок временный маршрут и временные службы удалены.

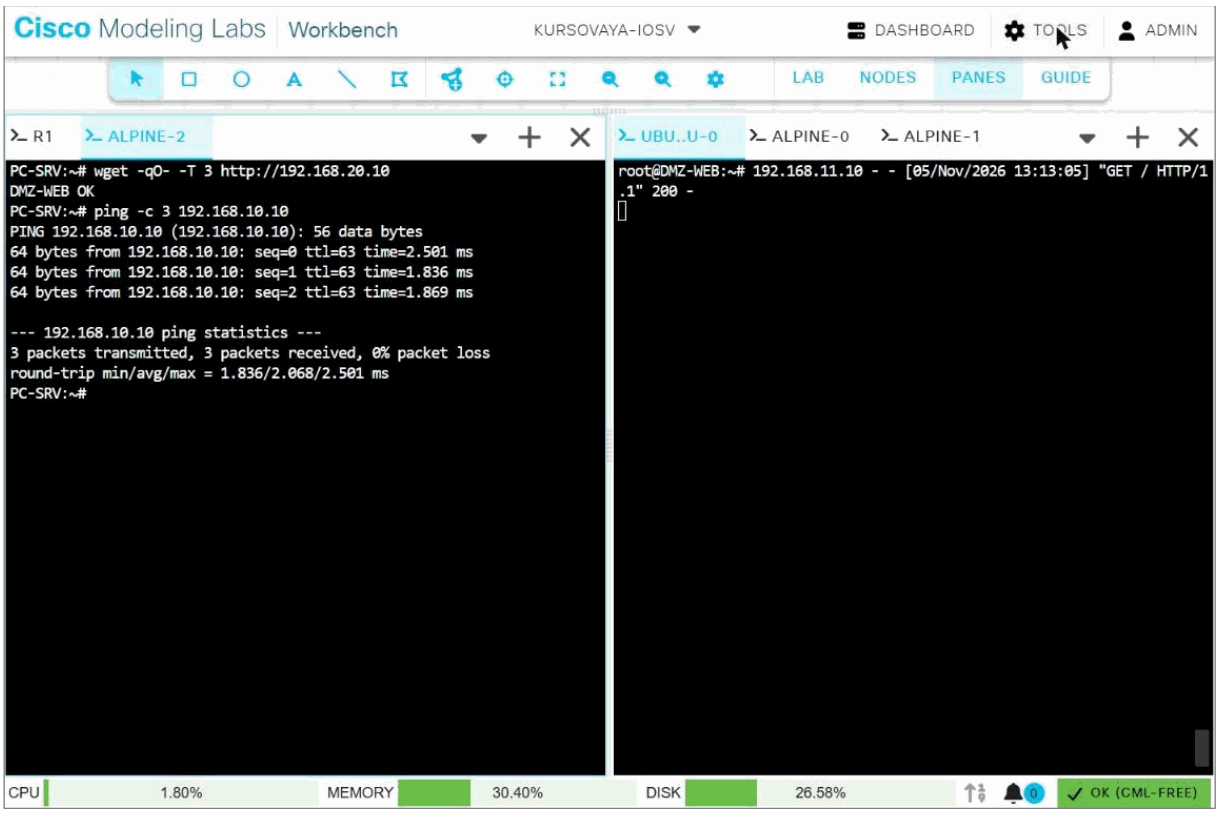


Рисунок 3.25 – До настройки экрана: узел сегмента SERVERS открывает страницу сервера DMZ

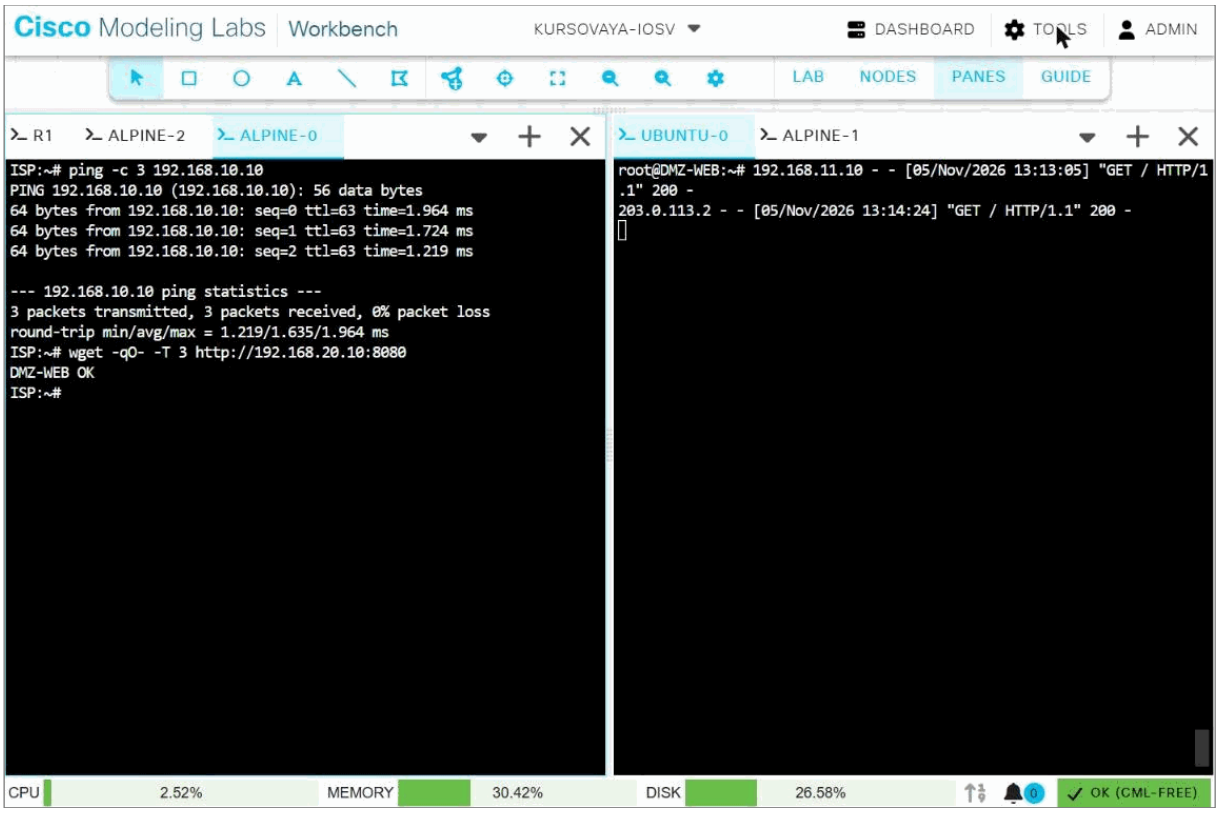


Рисунок 3.26 – До настройки экрана: внешний узел достигает сети пользователей и закрытого порта сервера

3.4.2. Зоны и классы трафика

Каждому сегменту соответствует своя зона безопасности: USERS, SERVERS, DMZ и OUTSIDE. Сам маршрутизатор представлен встроенной зоной `self`. Объекты экрана названы единообразно: списки доступа начинаются с `ACL-`, карты классов – с `CM-`, карты политик – с `PM-`, пары зон – с `ZP-`.

Сначала описан трафик, который разрешается (листинг 3.10). Класс `CM-ALL` охватывает любые соединения TCP, UDP и ICMP и используется там, где направление разрешено целиком. Класс `CM-USERS-SRV` описывает обращения пользователей к внутренним серверам по служебным портам. Класс `CM-DMZ-WEB` описывает обращения к веб-серверу по портам 80 и 443. В его списке доступа указан настоящий адрес сервера 192.168.20.10: к моменту проверки экраном публичный адрес уже заменён трансляцией.

Листинг 3.10 – Зоны, списки доступа и карты классов

```
zone security USERS
zone security SERVERS
zone security DMZ
zone security OUTSIDE
!
ip access-list extended ACL-USERS-SRV
 remark USERS to SERVERS: admin and service ports only
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 22
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq www
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 443
 permit icmp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 echo
ip access-list extended ACL-DMZ-WEB
 remark OUTSIDE to DMZ: published web server only (real address)
 permit tcp any host 192.168.20.10 eq www
 permit tcp any host 192.168.20.10 eq 443
!
! Любой трафик TCP, UDP, ICMP (достаточно одного совпадения)
class-map type inspect match-any CM-ALL
 match protocol tcp
 match protocol udp
 match protocol icmp
class-map type inspect match-all CM-USERS-SRV
 match access-group name ACL-USERS-SRV
class-map type inspect match-all CM-DMZ-WEB
 match access-group name ACL-DMZ-WEB
```

3.4.3. Политики

Политики приведены в листинге 3.11. В каждой из них разрешённый класс обрабатывается действием `inspect`, а всё остальное попадает в `class-default` с действием `drop log`. Политика `PM-DROP-LOG` не содержит разрешённых

классов и предназначена для направлений, запрещённых полностью. Для обращений из Интернета к веб-серверу дополнительно включён аудит сессий: в журнал записываются начало и конец каждого соединения, адрес посетителя и объём переданных данных.

Листинг 3.11 – Карты политик для обмена между сегментами

```
! Аудит: записывать начало и конец каждой сессии
parameter-map type inspect PAR-AUDIT
 audit-trail on
!
! Разрешить всё с отслеживанием сессий
policy-map type inspect PM-INSPECT-ALL
 class type inspect CM-ALL
  inspect
 class class-default
  drop log
! Пользователи -> внутренние серверы: только служебные порты
policy-map type inspect PM-USERS-SRV
 class type inspect CM-USERS-SRV
  inspect
 class class-default
  drop log
! Интернет -> DMZ: только веб-сервер, с аудитом сессий
policy-map type inspect PM-OUT-DMZ
 class type inspect CM-DMZ-WEB
  inspect PAR-AUDIT
 class class-default
  drop log
! Полный запрет с записью в журнал
policy-map type inspect PM-DROP-LOG
 class class-default
  drop log
```

3.4.4. Пары зон и включение экрана

Для четырёх зон существует двенадцать направлений обмена, и для каждого создана пара зон (листинг 3.12). Запрещённые направления можно было бы не описывать: без пары зон трафик отбрасывается. Однако такое отбрасывание происходит молча. Пара с политикой `PM-DROP-LOG` даёт тот же результат, но каждое отбрасывание учитывается счётчиком и попадает в журнал.

Интерфейсы включены в зоны в последнюю очередь. До этого момента экран не действует, поэтому созданные объекты можно проверить, не прерывая работу сети.

Листинг 3.12 – Пары зон между сегментами и включение интерфейсов в зоны

```
! Разрешённые направления
zone-pair security ZP-USERS-SERVERS source USERS destination SERVERS
 service-policy type inspect PM-USERS-SRV
zone-pair security ZP-USERS-DMZ source USERS destination DMZ
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-USERS-OUTSIDE source USERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-SERVERS-OUTSIDE source SERVERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-DMZ-OUTSIDE source DMZ destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-OUTSIDE-DMZ source OUTSIDE destination DMZ
 service-policy type inspect PM-OUT-DMZ
! Запрещённые направления
zone-pair security ZP-SERVERS-USERS source SERVERS destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SERVERS-DMZ source SERVERS destination DMZ
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-USERS source DMZ destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-SERVERS source DMZ destination SERVERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-USERS source OUTSIDE destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-SERVERS source OUTSIDE destination SERVERS
 service-policy type inspect PM-DROP-LOG
!
interface GigabitEthernet0/0
 zone-member security SERVERS
interface GigabitEthernet0/1
 zone-member security USERS
interface GigabitEthernet0/2
 zone-member security DMZ
interface GigabitEthernet0/3
 zone-member security OUTSIDE
```

Сразу после включения интерфейсов в зоны узел PC-SRV перестал достигать сервера DMZ, а в журнале появилась первая запись `%FW-6-DROP_PKT` с названием пары зон `ZP-SERVERS-DMZ` (рисунок 3.27).

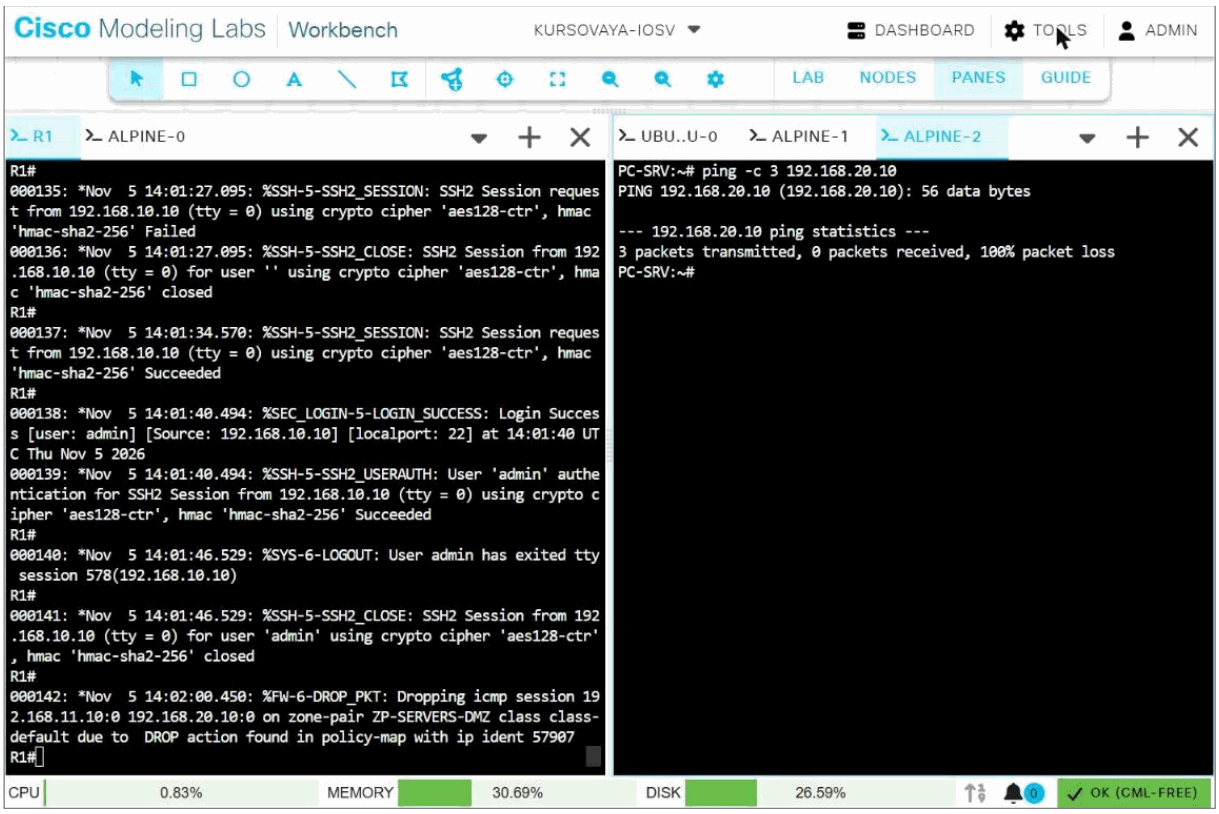


Рисунок 3.27 – Экран включён: первое отбрасывание в паре зон SERVERS – DMZ

3.4.5. Защита самого маршрутизатора

Правила для транзитного трафика не касаются пакетов, адресованных самому маршрутизатору. Для их контроля созданы восемь пар зон с участием зоны `self` (листинг 3.13). Из сети пользователей к маршрутизатору разрешены SSH и ping, из сетей SERVERS и DMZ – только ping, из внешней сети – ничего. Собственный трафик маршрутизатора (синхронизация времени, отправка журнала, проверки связи) разрешён во всех направлениях с отслеживанием сессий, поэтому ответы на него проходят.

Доступ к управлению теперь ограничен дважды. Экран отбрасывает пакеты SSH из всех сетей, кроме USERS, ещё до того, как они достигнут службы. Список доступа на линиях vty, настроенный ранее, остаётся вторым рубежом. Эти пары зон заменяют функцию ограничения управления по интерфейсу, которой в данном образе нет.

Листинг 3.13 – Политики и пары зон для трафика самого маршрутизатора

```
ip access-list extended ACL-MGMT-SSH
 remark USERS to R1: SSH only (vty access-class still applies)
 permit tcp 192.168.10.0 0.0.0.255 any eq 22
class-map type inspect match-all CM-MGMT-SSH
 match protocol tcp
 match access-group name ACL-MGMT-SSH
class-map type inspect match-any CM-ICMP
 match protocol icmp
!
! Пользователи -> R1: SSH и ping
policy-map type inspect PM-USERS-SELF
 class type inspect CM-MGMT-SSH
  inspect
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
! Серверы и DMZ -> R1: только ping
policy-map type inspect PM-INSIDE-SELF
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
! R1 -> любая зона: собственный трафик с отслеживанием сессий
policy-map type inspect PM-SELF-OUT
 class type inspect CM-ALL
  inspect
 class class-default
  drop log
!
zone-pair security ZP-OUTSIDE-SELF source OUTSIDE destination self
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SELF-OUTSIDE source self destination OUTSIDE
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-SERVERS-SELF source SERVERS destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-SERVERS source self destination SERVERS
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-DMZ-SELF source DMZ destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-DMZ source self destination DMZ
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-USERS-SELF source USERS destination self
 service-policy type inspect PM-USERS-SELF
zone-pair security ZP-SELF-USERS source self destination USERS
 service-policy type inspect PM-SELF-OUT
```

Все двадцать пар зон сведены в таблицу 3.1; на рисунке 3.28 показан их перечень на маршрутизаторе.

Таблица 3.1 – Пары зон межсетевого экрана

Пара зон	Политика	Что разрешено
ZP-USERS-SERVERS	PM-USERS-SRV	TCP 22, 80, 443 и ping
ZP-USERS-DMZ	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-USERS-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-SERVERS-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-DMZ-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-OUTSIDE-DMZ	PM-OUT-DMZ	TCP 80 и 443 к 192.168.20.10, с аудитом
ZP-SERVERS-USERS	PM-DROP-LOG	ничего
ZP-SERVERS-DMZ	PM-DROP-LOG	ничего
ZP-DMZ-USERS	PM-DROP-LOG	ничего
ZP-DMZ-SERVERS	PM-DROP-LOG	ничего
ZP-OUTSIDE-USERS	PM-DROP-LOG	ничего
ZP-OUTSIDE-SERVERS	PM-DROP-LOG	ничего
ZP-USERS-SELF	PM-USERS-SELF	SSH и ping
ZP-SERVERS-SELF	PM-INSIDE-SELF	ping
ZP-DMZ-SELF	PM-INSIDE-SELF	ping
ZP-OUTSIDE-SELF	PM-DROP-LOG	ничего
ZP-SELF-USERS, ZP-SELF-SERVERS, ZP-SELF-DMZ, ZP-SELF-OUTSIDE	PM-SELF-OUT	TCP, UDP, ICMP

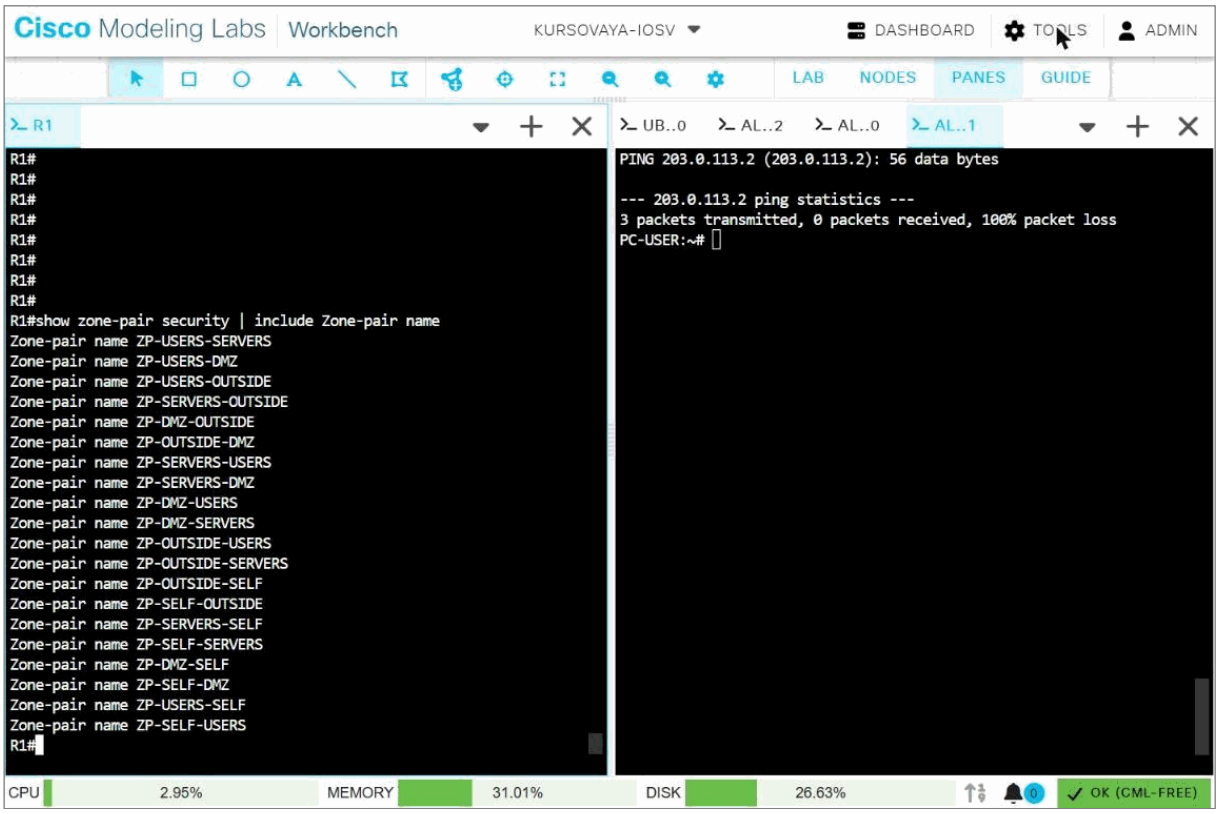


Рисунок 3.28 – Двадцать пар зон на маршрутизаторе

3.4.6. Проверка

Избирательный доступ в DMZ. Узел PC-USER открывает страницу сервера DMZ (рисунок 3.29). Узел PC-SRV на тот же запрос получает тайм-аут, а ping до сервера теряет все пакеты (рисунок 3.30). На маршрутизаторе отказ подтверждается записью `DROP_PKT` для пары `ZP-SERVERS-DMZ` и счётчиком отброшенных пакетов этой пары. Требование задания выполнено: один клиент имеет доступ в DMZ, другой не имеет.

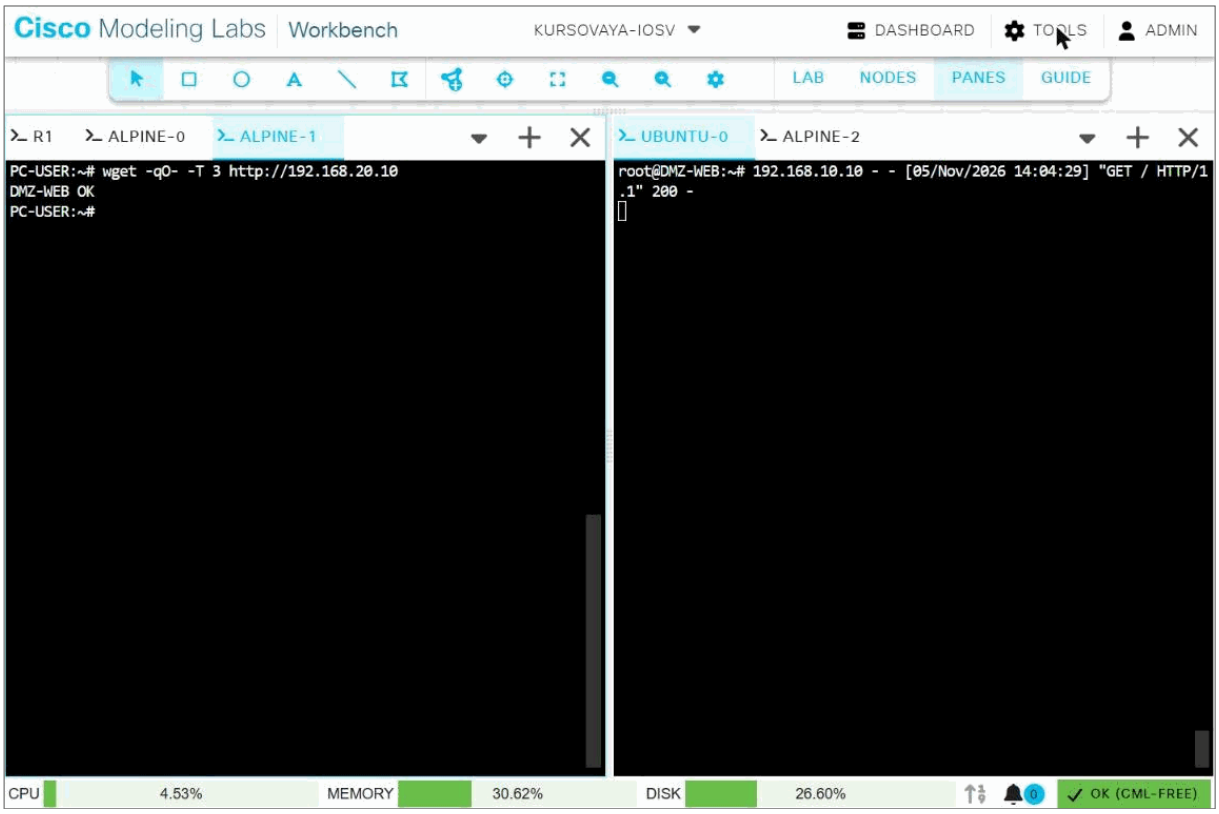


Рисунок 3.29 – Клиент из сегмента USERS получает доступ к серверу DMZ

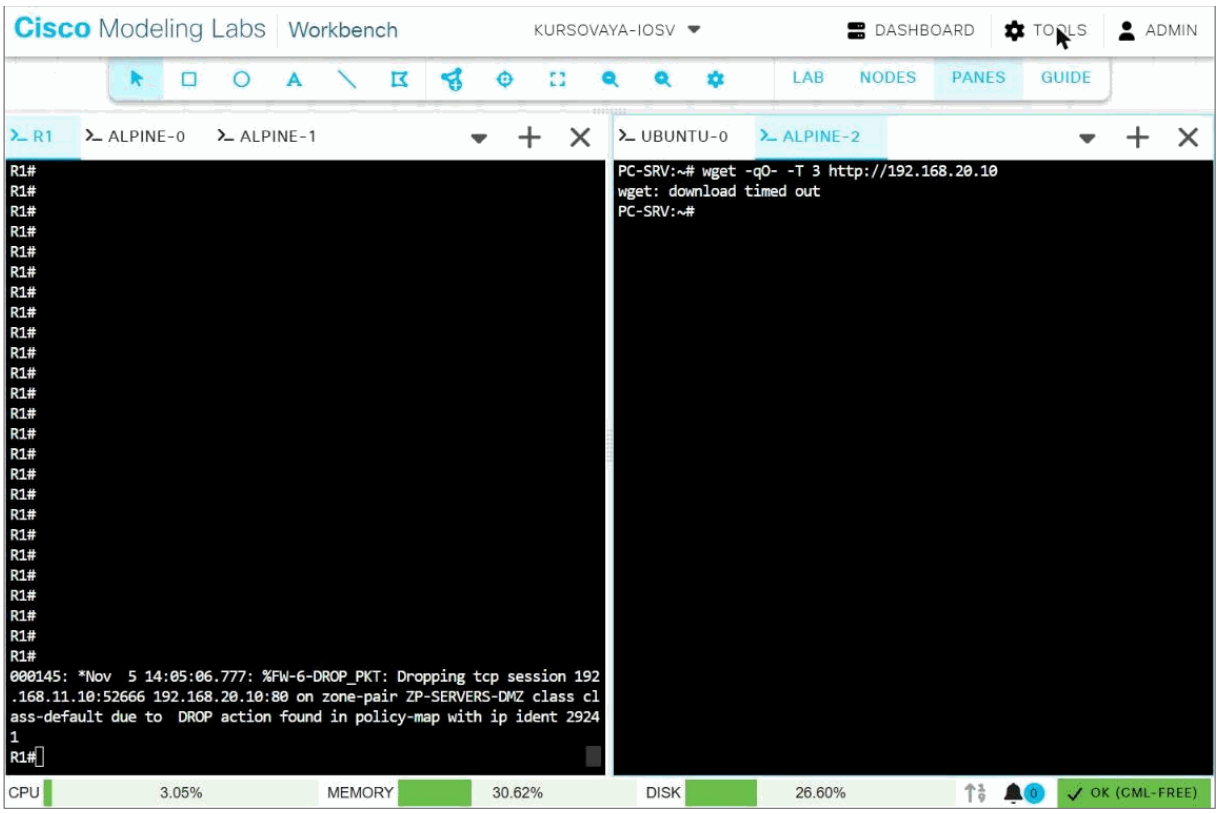


Рисунок 3.30 – Клиенту из сегмента SERVERS доступ в DMZ запрещён

Учёт состояния соединений. Пока узел PC-USER выполняет ping узла PC-SRV, в таблице сессий маршрутизатора присутствует запись об этой сессии, и ответы проходят (рисунок 3.31). Встречный ping, начатый узлом PC-SRV, отбрасывается парой `ZP-SERVERS-USERS`. Отдельного правила для ответов не создавалось: их пропускает запись в таблице сессий.

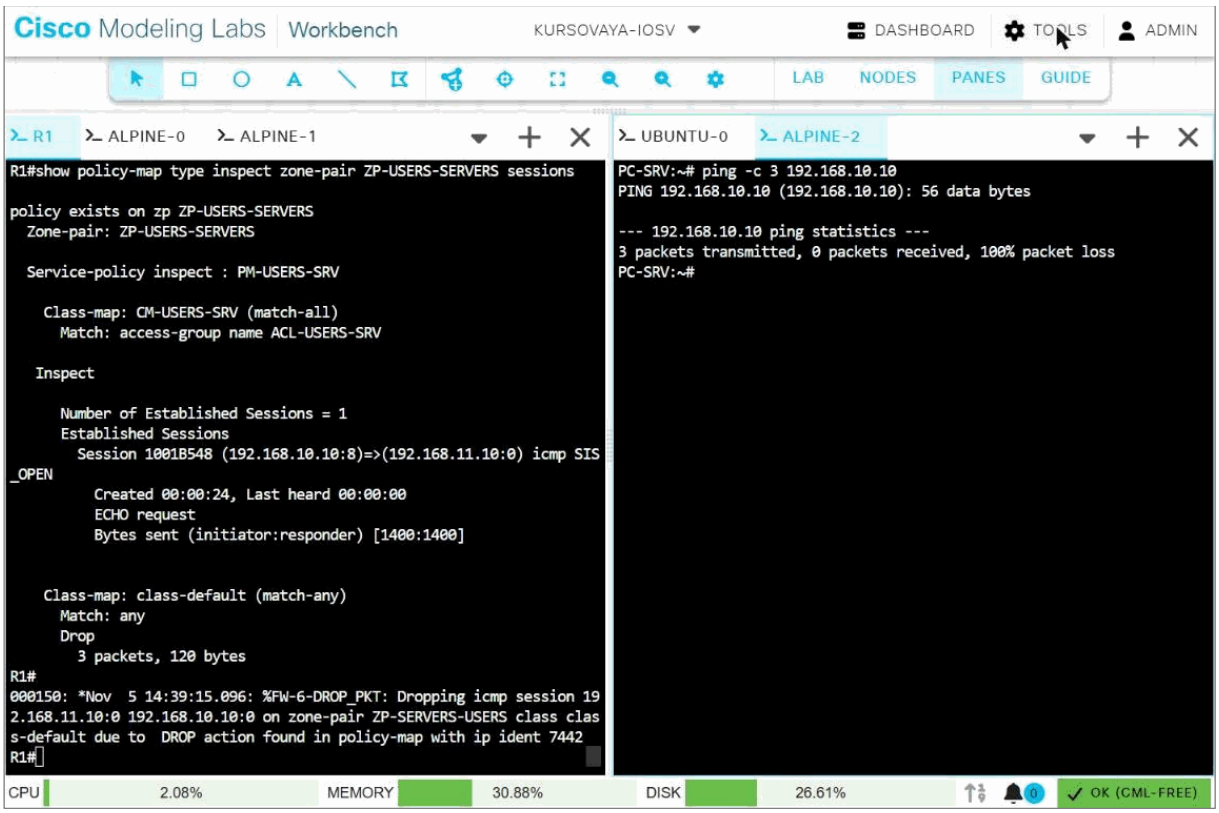


Рисунок 3.31 – Таблица сессий: ответы проходят, встречное соединение отброшено

Изоляция DMZ. Сервер DMZ не может обратиться ни к сети пользователей, ни к сети серверов: ping в обе сети теряет все пакеты (рисунок 3.32).

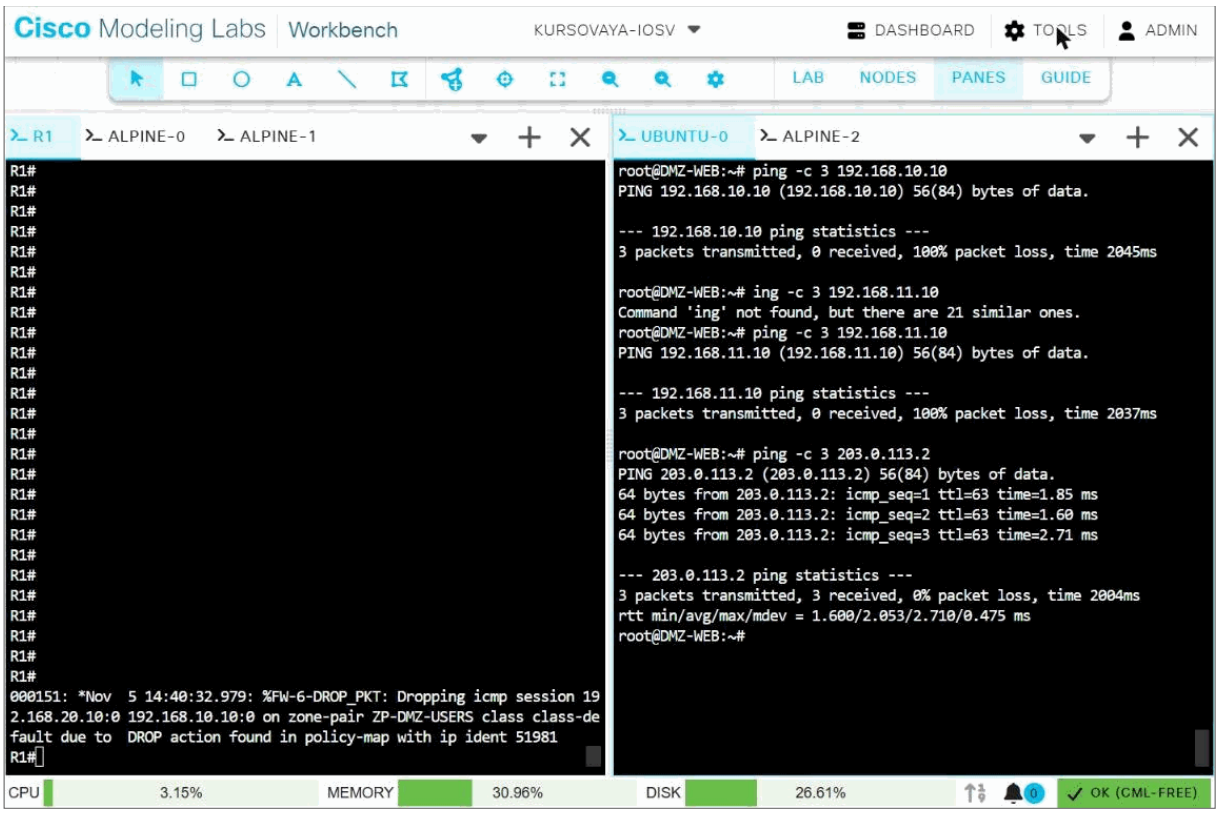


Рисунок 3.32 – Сервер DMZ не может начать соединение с внутренними сегментами

Доступ из внешней сети. Узел ISP больше не достигает сети пользователей (рисунок 3.33). К серверу DMZ он обращается по портам 80 и 443, и каждая такая сессия записывается в журнал. Обращение к порту 8080 и ping отбрасываются (рисунок 3.34).

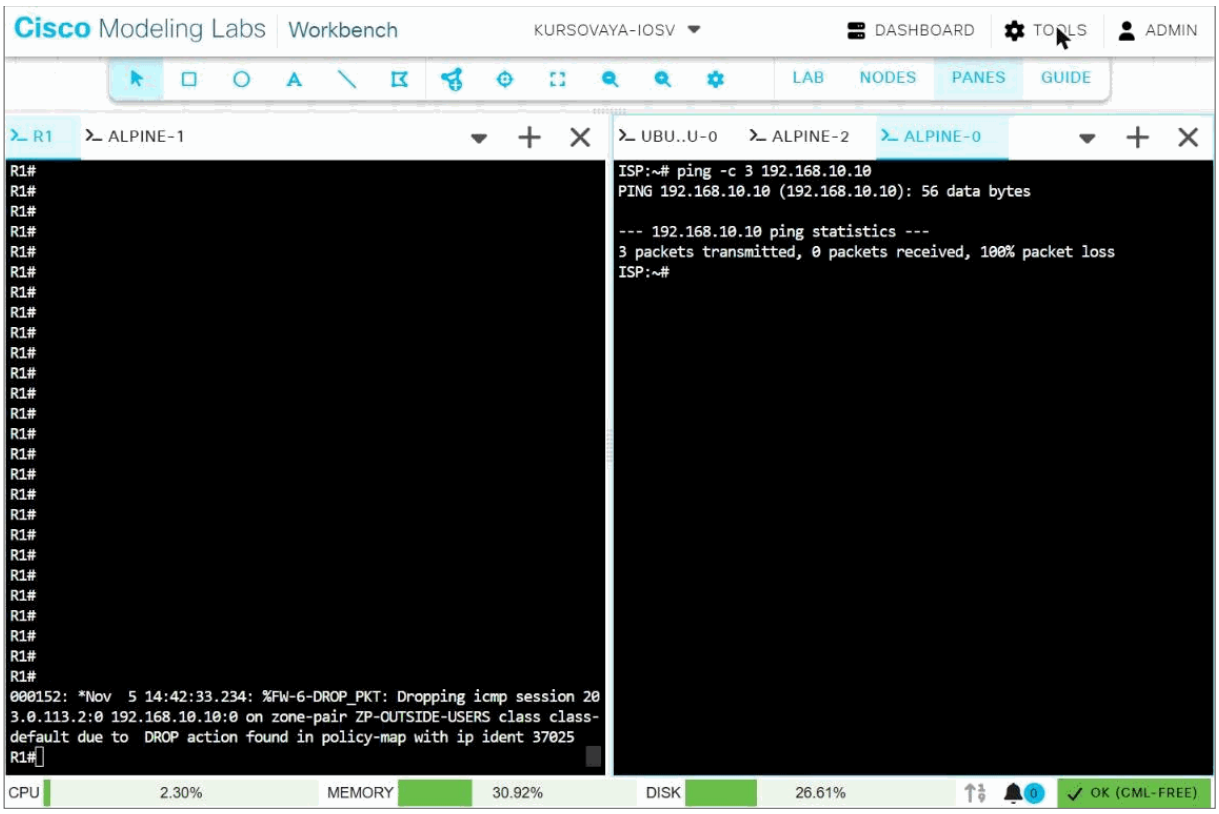


Рисунок 3.33 – Внешний узел не достигает сети пользователей

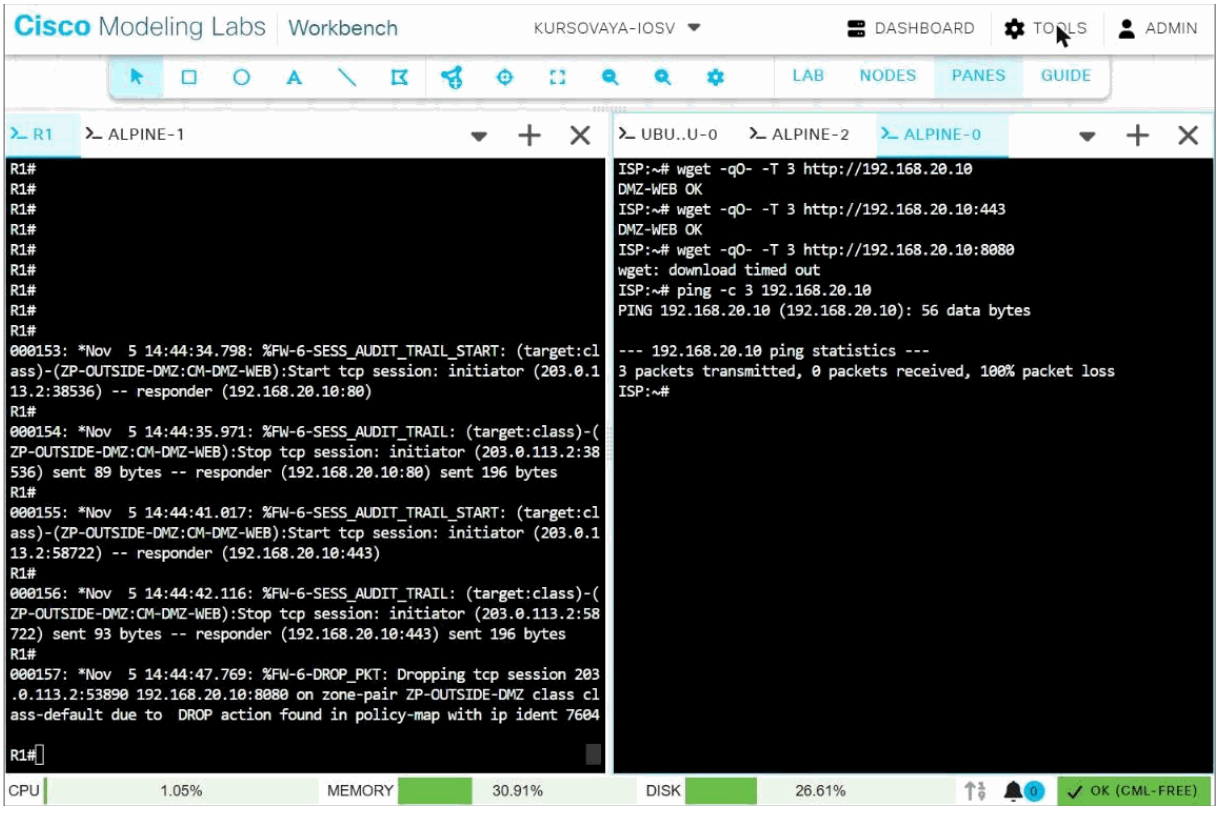


Рисунок 3.34 – Из внешней сети на сервере DMZ доступны только порты 80 и 443

Защита маршрутизатора. На ping из внешней сети маршрутизатор не отвечает, при этом собственный ping маршрутизатора в Интернет проходит (рисунок 3.35). Попытка подключиться по SSH из сети серверов завершается тайм-аутом (рисунок 3.36). Раньше, когда действовал только список доступа на линиях vty, клиент получал явный отказ `Connection refused`. Теперь пакеты отбрасываются молча, и нарушитель не получает подтверждения, что служба существует. Подключение администратора из сети пользователей работает, а его сессия видна в таблице сессий пары `ZP-USERS-SELF` (рисунок 3.37).

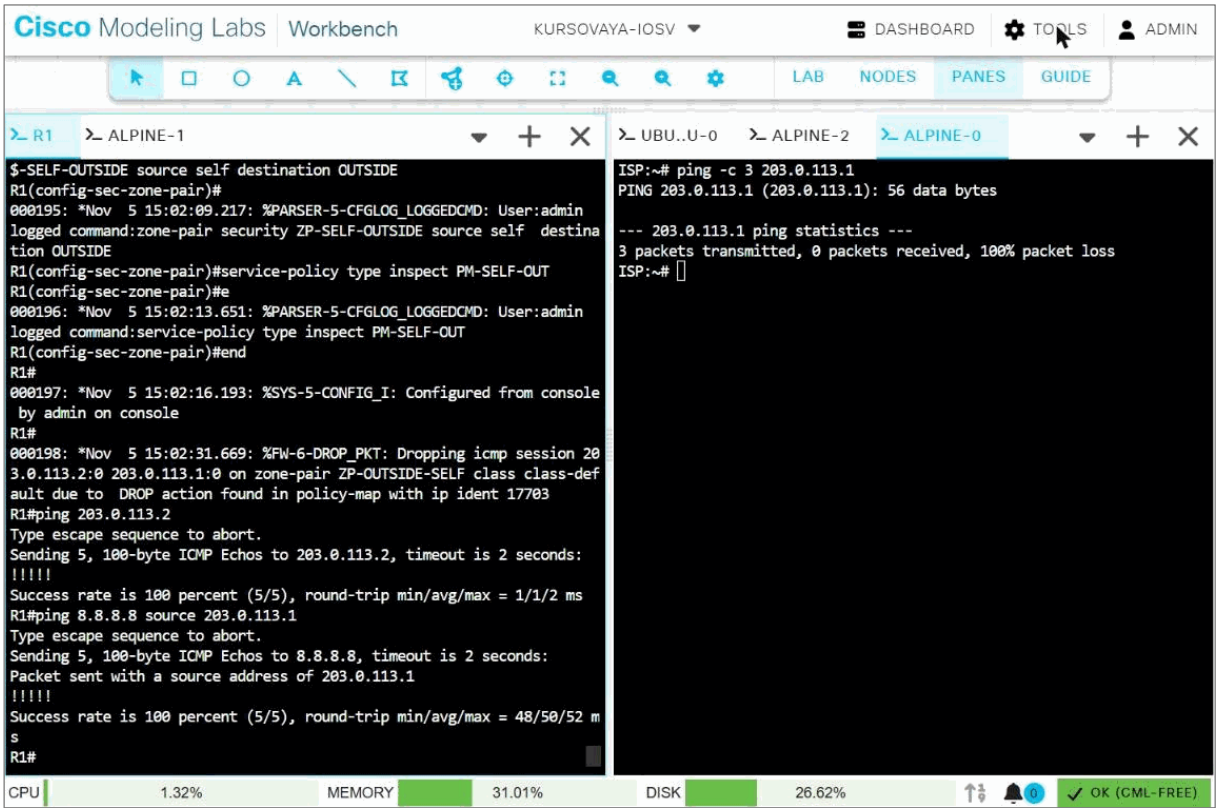


Рисунок 3.35 – Маршрутизатор не отвечает внешней сети, но сам выходит в Интернет

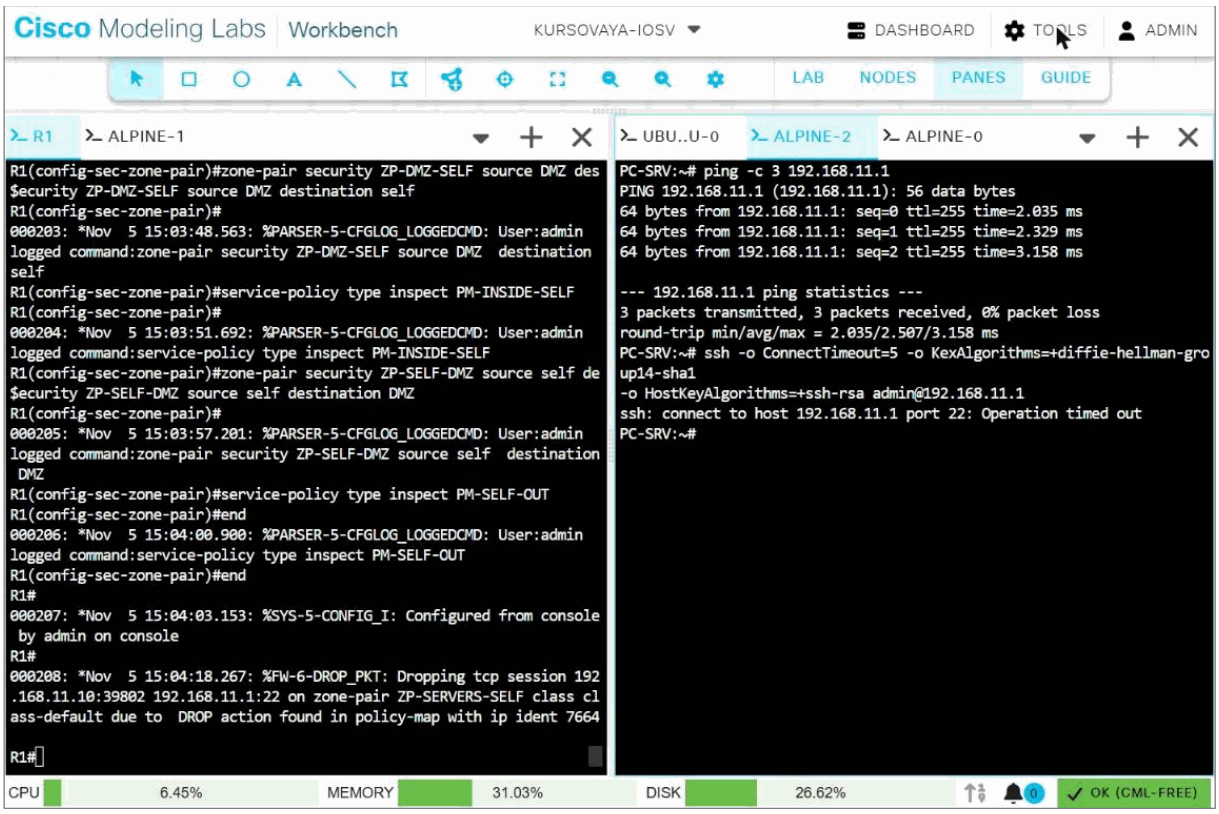


Рисунок 3.36 – Подключение по SSH из сети серверов отбрасывается экраном

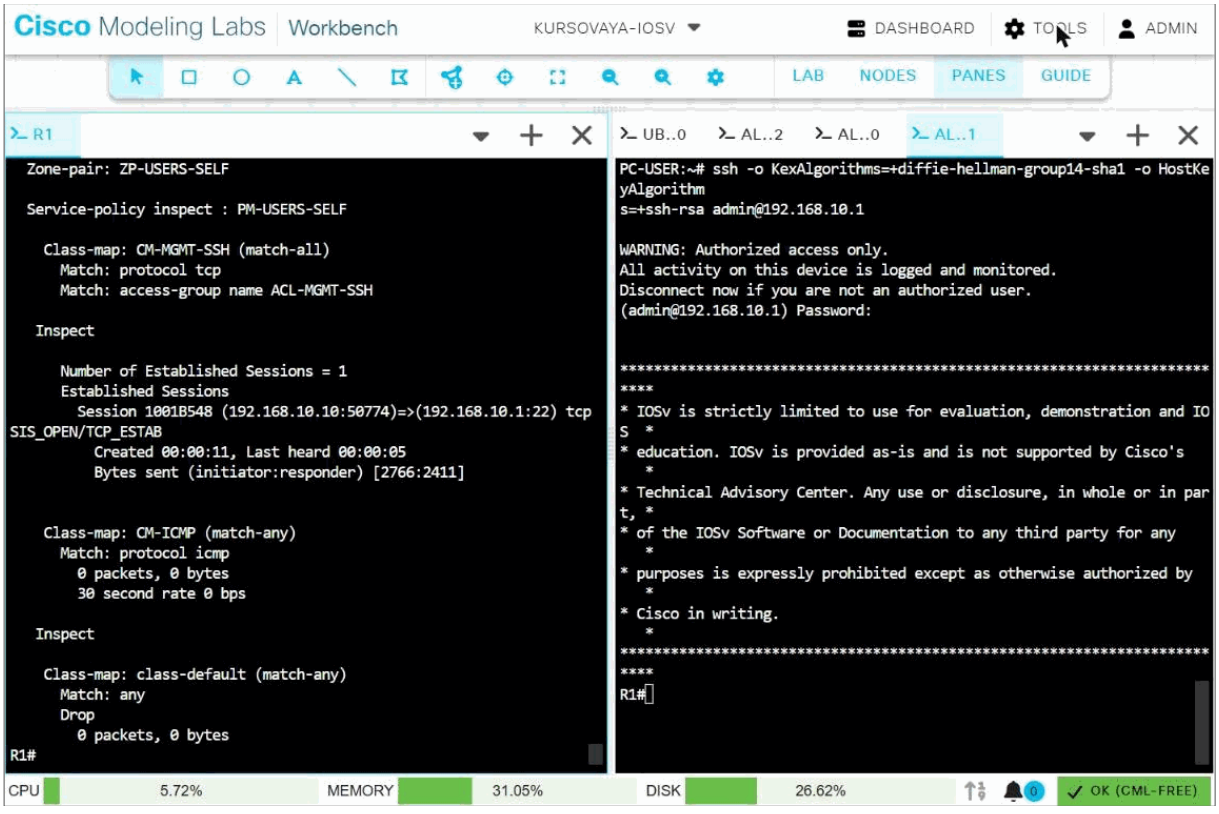


Рисунок 3.37 – Сессия SSH администратора в таблице сессий

3.5. Выход в Интернет и публикация веб-сервера

Пятый пункт задания – обеспечить выход внутренних сетей и DMZ в Интернет и сделать веб-сервер доступным извне. Обе задачи решаются трансляцией адресов.

3.5.1. Исходное состояние

После настройки экрана правила разрешают внутренним узлам выход наружу, но связи с Интернетом нет. Причина видна на рисунке 3.38: провайдер получает пакеты с адресом источника 192.168.10.10. Это частный адрес, маршрута к нему у провайдера нет, поэтому ответы не возвращаются.

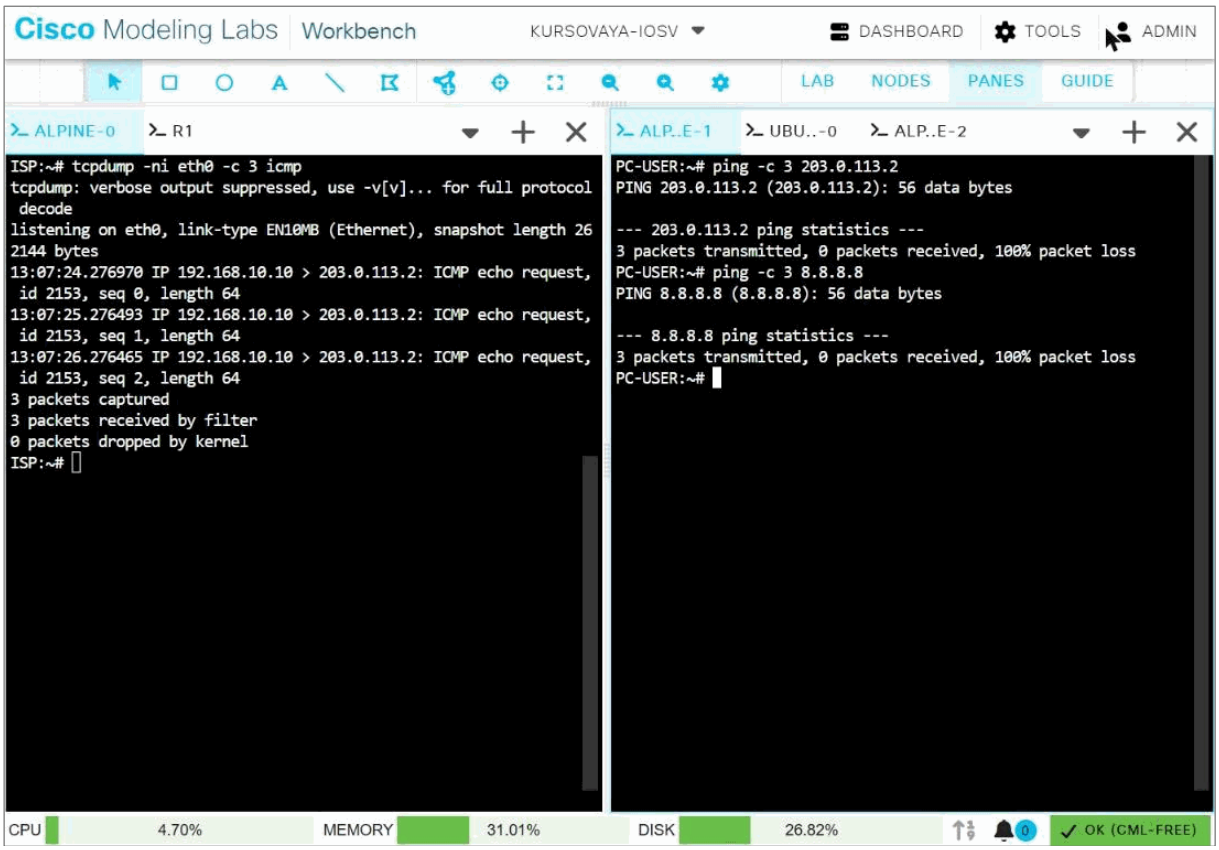


Рисунок 3.38 – До настройки трансляции: провайдер видит частный адрес источника, ответов нет

3.5.2. Трансляция с перегрузкой для выхода в Интернет

Команды приведены в листинге 3.14. Интерфейсы трёх внутренних сегментов объявлены внутренними для трансляции, интерфейс к провайдеру – внешним. Стандартный список доступа NAT-INSIDE определяет, чьи адреса транслируются. Он ничего не фильтрует и на интерфейс не назначается. Правило

с ключевым словом `overload` заменяет адрес источника на адрес внешнего интерфейса, различая соединения по номеру порта.

Листинг 3.14 – Трансляция адресов с перегрузкой (PAT)

```
interface GigabitEthernet0/0
 ip nat inside
interface GigabitEthernet0/1
 ip nat inside
interface GigabitEthernet0/2
 ip nat inside
interface GigabitEthernet0/3
 ip nat outside
!
! Чьи адреса транслировать
ip access-list standard NAT-INSIDE
 remark Inside networks translated by PAT
 permit 192.168.10.0 0.0.0.255
 permit 192.168.11.0 0.0.0.255
 permit 192.168.20.0 0.0.0.255
!
! Все перечисленные сети выходят под адресом интерфейса Gi0/3
ip nat inside source list NAT-INSIDE interface GigabitEthernet0/3 overload
```

После ввода правила провайдер видит пакеты от адреса 203.0.113.1 и отвечает на них, потерь нет (рисунок 3.39).

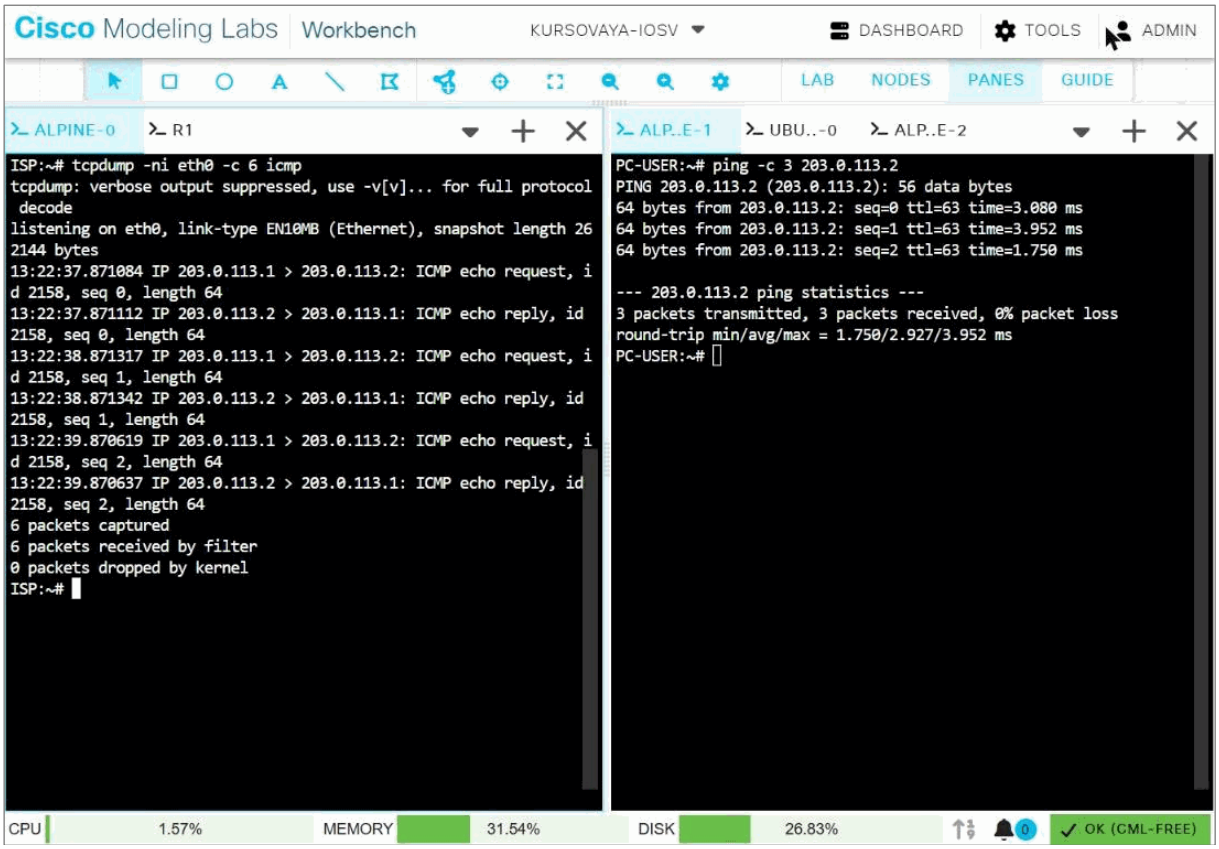


Рисунок 3.39 – После настройки PAT: провайдер видит публичный адрес R1, ответы возвращаются

На рисунке 3.40 показаны таблица трансляций и выход в реальный Интернет. Три узла одновременно обращаются к адресу 8.8.8.8 и все выходят под адресом 203.0.113.1; записи различаются идентификатором. Таблица сессий экрана при этом содержит настоящие адреса узлов: экран и трансляция ведут свои таблицы независимо. Узел PC-USER получает страницу с внешнего сайта с кодом 200.

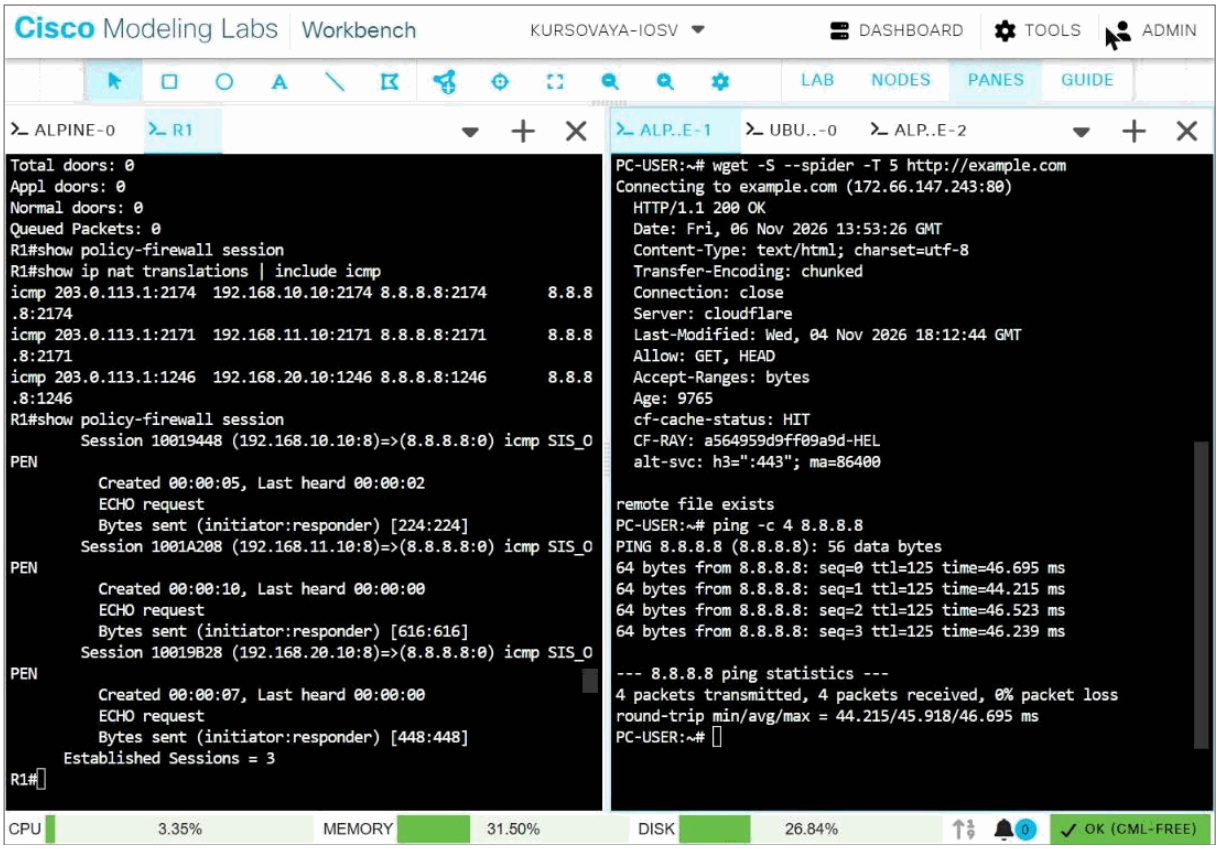


Рисунок 3.40 – Таблица трансляций, сессии экрана и доступ к внешнему сайту

3.5.3. Статическая трансляция для веб-сервера

Веб-серверу нужна постоянная трансляция: соединение начинает внешний клиент, и к этому моменту запись в таблице уже должна существовать. Одна команда (листинг 3.15) связывает внутренний адрес сервера с публичным адресом 203.0.113.3 в обоих направлениях.

Листинг 3.15 – Статическая трансляция адреса веб-сервера

```
! 192.168.20.10 <-> 203.0.113.3, в обе стороны
ip nat inside source static 192.168.20.10 203.0.113.3
```

Трансляция выполнена для адреса целиком, а не для отдельных портов. Обязанности разделены: трансляция отвечает за адрес, а экран – за то, какие порты доступны. Лишние обращения к публичному адресу при этом видны в счётчиках экрана.

Результат показан на рисунке 3.41. В таблице появилась постоянная запись. Маршрутизатор отвечает на запросы ARP за адрес 203.0.113.3 своим MAC-адресом, поэтому провайдер может доставить ему пакеты для этого адреса. На ping адрес не отвечает: ICMP из внешней сети отбрасывается экраном. Сам сервер выходит в Интернет под тем же адресом 203.0.113.3 (рисунок 3.42): статическая трансляция имеет приоритет над трансляцией с перегрузкой.

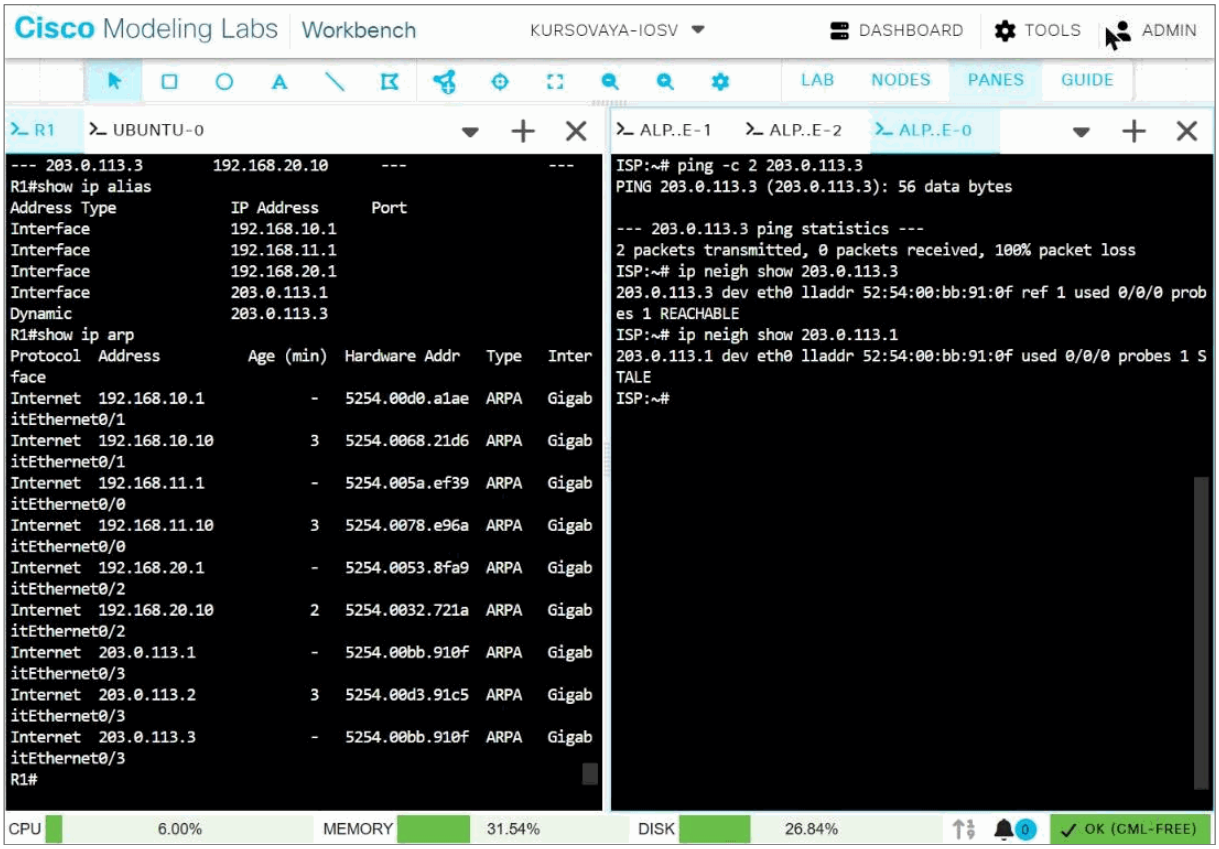


Рисунок 3.41 – Статическая трансляция: запись в таблице и ответ на ARP за публичный адрес сервера

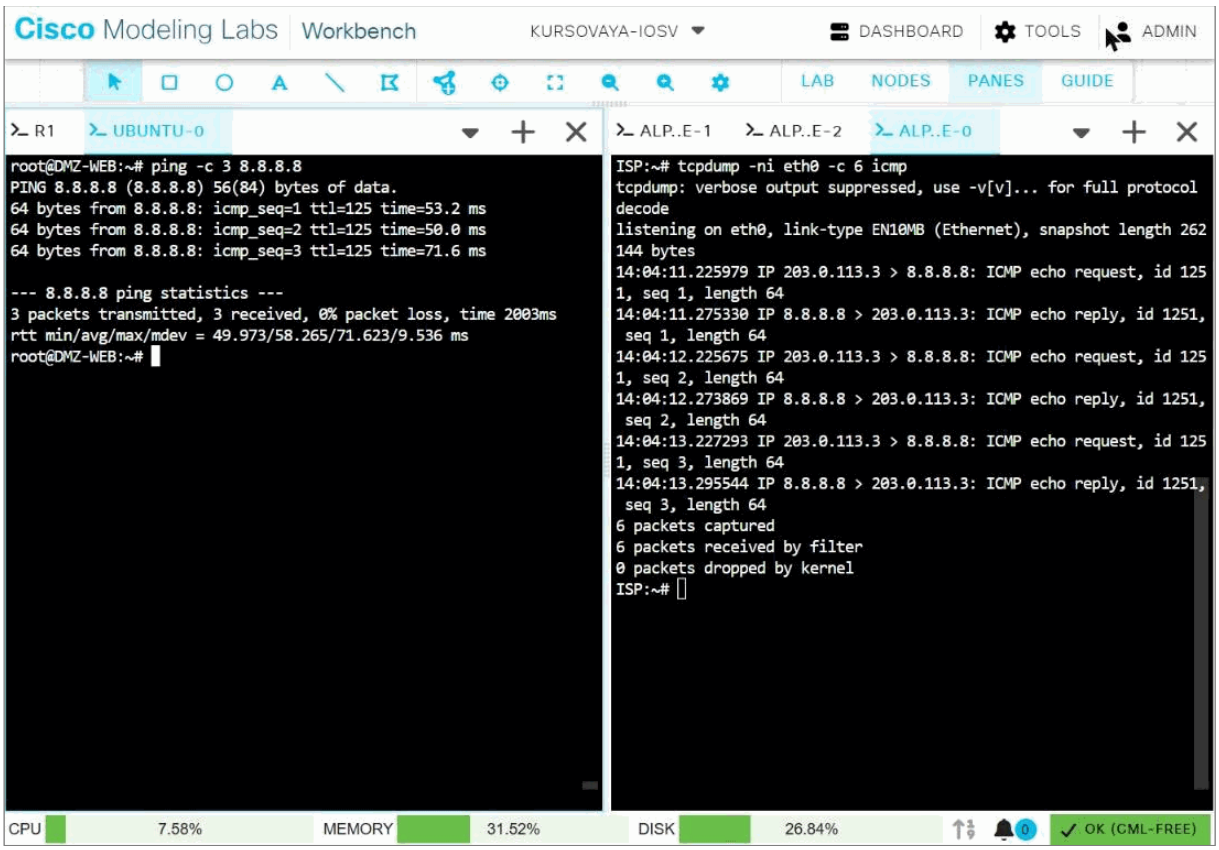


Рисунок 3.42 – Сервер DMZ выходит в Интернет под адресом 203.0.113.3

3.5.4. Публикация веб-сервера

На сервере DMZ установлен веб-сервер nginx, принимающий запросы по HTTP на порту 80 и по HTTPS на порту 443. Для HTTPS создан самоподписанный сертификат; для учебного стенда этого достаточно, а в реальной сети сертификат выдаёт удостоверяющий центр. Команды настройки сервера приведены в приложении Б.

С узла ISP страница открывается по обоим протоколам через адрес 203.0.113.3 (рисунок 3.43). В журнале веб-сервера записан настоящий адрес клиента 203.0.113.2: адрес внешнего узла не транслируется.

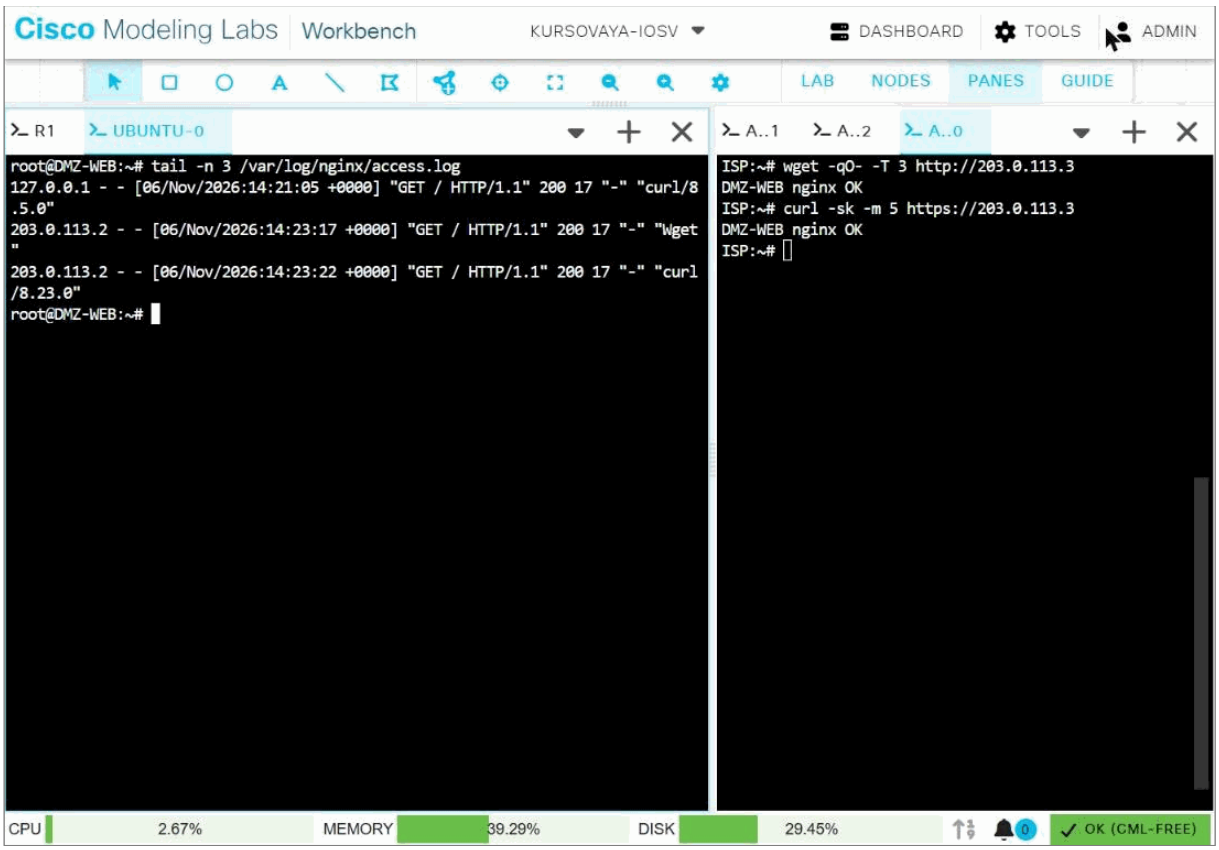


Рисунок 3.43 – Веб-сервер доступен из внешней сети по HTTP и HTTPS

На маршрутизаторе каждое обращение оставило запись аудита с адресами сторон и объёмом переданных данных, а в таблице трансляций видны записи для портов 80 и 443 (рисунок 3.44).

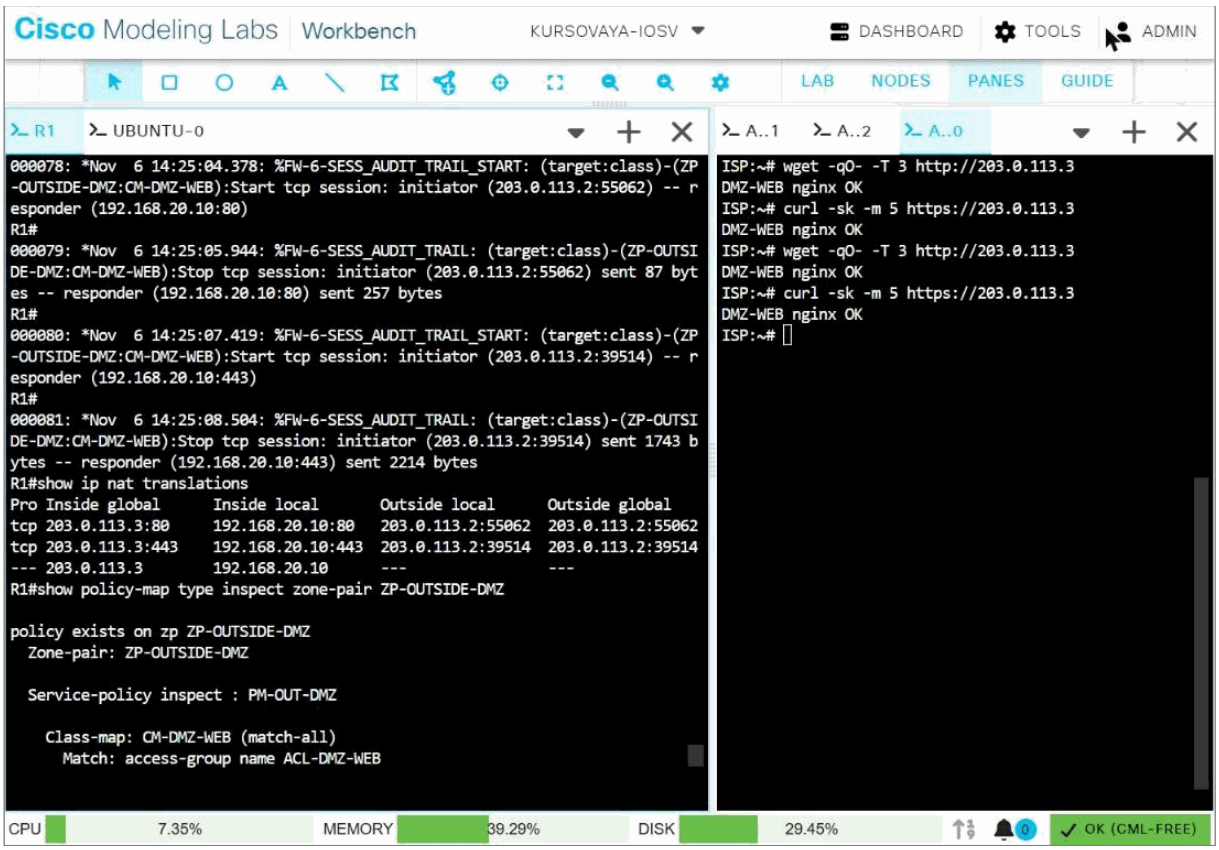


Рисунок 3.44 – Записи аудита сессий и трансляции для обращений к веб-серверу

Обращения к порту 8080 сервера, ping публичного адреса сервера, а также обращения к самому маршрутизатору отброшены (рисунок 3.45). В записях журнала указан настоящий адрес сервера 192.168.20.10, хотя внешний узел обращался к адресу 203.0.113.3. Это подтверждает порядок обработки, показанный на рисунке 2.3: трансляция адреса назначения выполняется раньше проверки экраном.

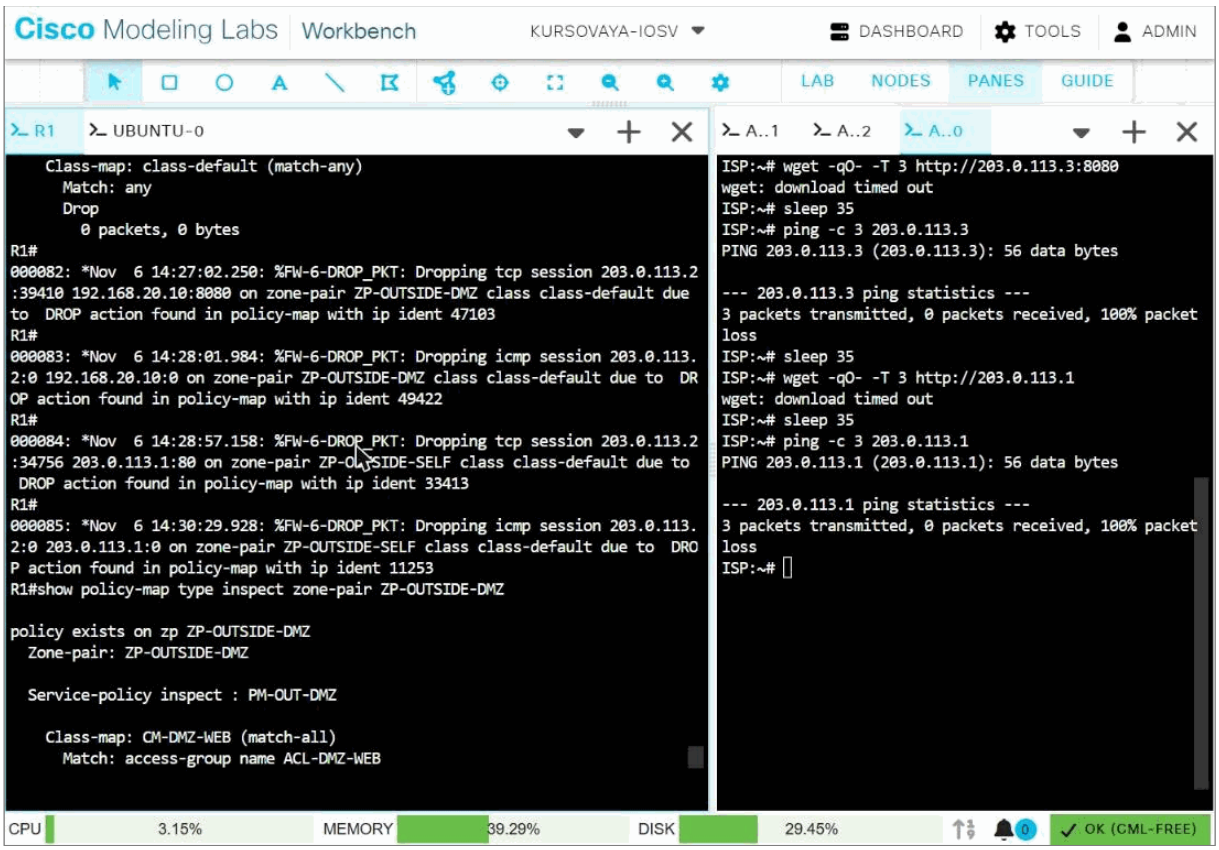


Рисунок 3.45 – Обращения к неопубликованным портам и к маршрутизатору отброшены

3.6. Учёт событий с точным временем

Шестой пункт задания – обеспечить учёт событий. К этому моменту маршрутизатор уже записывает входы, изменения конфигурации и отброшенные пакеты, но только в собственный буфер. Требуется сохранять журнал вне маршрутизатора и привязать его к точному времени.

3.6.1. Исходное состояние

До настройки часы маршрутизатора шли по Гринвичу и не были синхронизированы; в метках журнала это отмечено звёздочкой. Журнал никуда не передавался. Одно и то же обращение к веб-серверу маршрутизатор записал в 14:06:42, а веб-сервер – в 14:06:49 (рисунок 3.46). При расхождении в несколько секунд сопоставить записи двух устройств при плотном потоке событий невозможно. Позднее в тот же день расхождение выросло до 65 секунд.

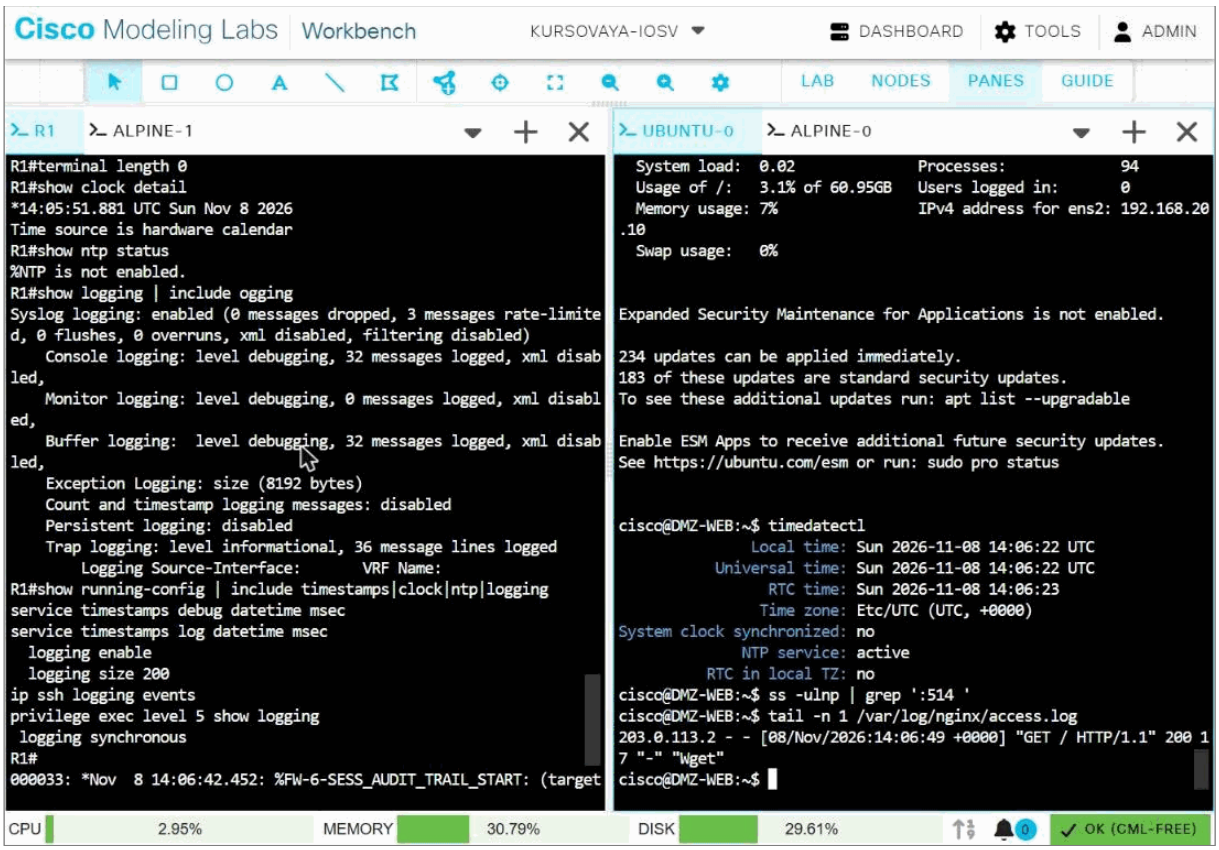


Рисунок 3.46 – До настройки: одно событие записано на R1 и на сервере с разным временем

3.6.2. Часовой пояс и формат меток времени

Задан часовой пояс и расширен формат метки времени в журнале (листинг 3.16). Метка теперь содержит год, миллисекунды и название пояса, поэтому запись однозначна. Внутри маршрутизатор по-прежнему ведёт время по Гринвичу, меняется только отображение.

Листинг 3.16 – Часовой пояс и формат меток времени

```
! Пояс MSK, смещение +3 часа
clock timezone MSK 3 0
! Метка: дата с годом, миллисекунды, местное время, название пояса
service timestamps log datetime msec localtime show-timezone year
service timestamps debug datetime msec localtime show-timezone year
```

3.6.3. Отправка журнала на сервер

Сервером журналов служит узел DMZ-WEB. На нём настроена служба rsyslog: она принимает сообщения по UDP на порту 514 и записывает в файл `/var/log/r1.log` только те, что пришли с адреса маршрутизатора 192.168.20.1 (рисунок 3.47). Настройка службы приведена в приложении Б.

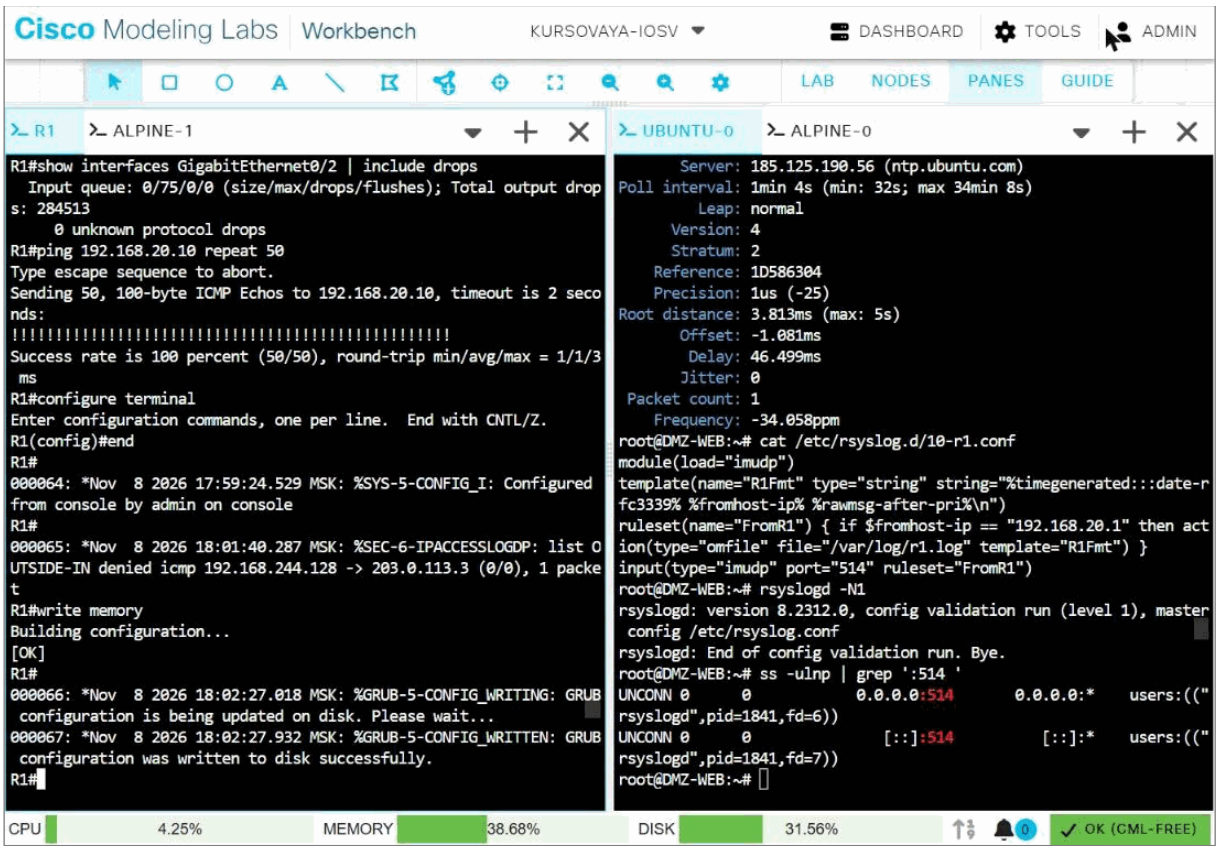


Рисунок 3.47 – Сервер журналов принимает сообщения только от R1

На маршрутизаторе увеличен буфер журнала, указан сервер и адрес, от имени которого отправляются сообщения (листинг 3.17). Поток сообщений ограничен: не более 100 в секунду, причём ограничение не распространяется на сообщения уровня warnings и важнее. Записи списков доступа создаются не чаще одного раза в 10 миллисекунд. Эти ограничения не позволяют массовой атаке превратить журнал в дополнительную нагрузку.

Листинг 3.17 – Журнал: буфер, сервер и ограничение потока

```
! Буфер 64000 байт, уровни 0-6
logging buffered 64000 informational
! Сервер журналов; на сервер уходят уровни 0-6 (значение по умолчанию)
logging host 192.168.20.10
! Адрес отправителя - интерфейс в сторону сервера
logging source-interface GigabitEthernet0/2
! Не более 100 сообщений в секунду, кроме warnings и важнее
logging rate-limit 100 except warnings
! Записи списков доступа - не чаще раза в 10 мс
ip access-list logging interval 10
```

После включения отправки записи маршрутизатора стали появляться на сервере (рисунок 3.48). В каждой строке два времени: момент приёма по часам

сервера и метка самого маршрутизатора. До синхронизации они расходились на 65,5 секунды.

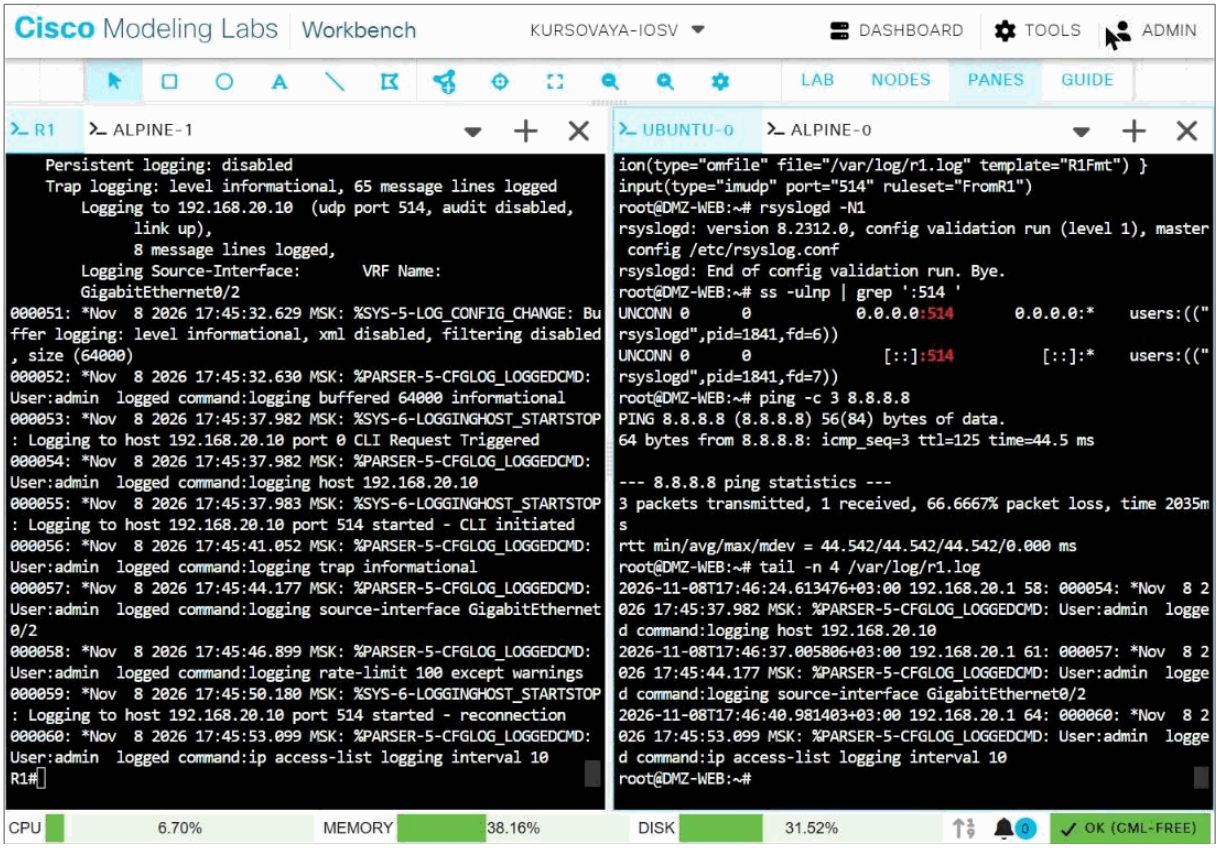


Рисунок 3.48 – Журнал R1 на сервере до синхронизации времени

При первой проверке часть записей до сервера не доходила. Причиной оказалась фоновая загрузка обновлений на сервере Ubuntu: она переполняла выходную очередь интерфейса Gi0/2, и терялись как ответы ping, так и сообщения журнала (рисунок 3.49). После остановки загрузки потери прекратились. Пропуски удалось обнаружить только благодаря нумерации записей. Наблюдение показывает слабое место передачи журнала по UDP: потерянное сообщение не повторяется.

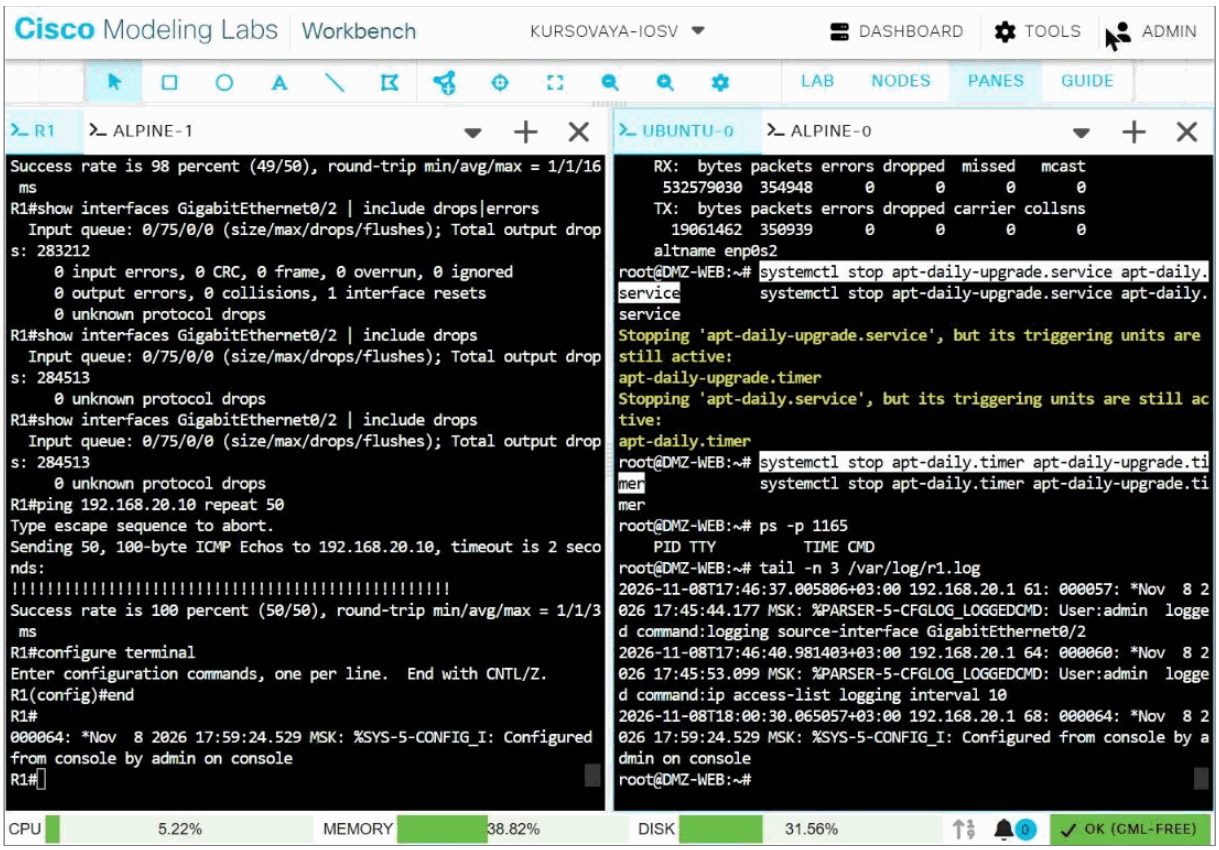


Рисунок 3.49 – Потери сообщений журнала при перегрузке очереди интерфейса

3.6.4. Синхронизация времени

Маршрутизатор получает время от трёх общедоступных серверов NTP (листинг 3.18). Три сервера позволяют выявить ошибающийся источник. Список доступа NTP-PEERS разрешает обмен только с этими серверами: на запросы времени от других узлов маршрутизатор не отвечает. Сервер DMZ в качестве источника времени не используется, поскольку доверие к нему ниже.

Листинг 3.18 – Синхронизация времени по NTP

```
ntp logging
ntp server 185.125.190.56 prefer
ntp server 185.125.190.57
ntp server 162.159.200.1
!
ip access-list standard NTP-PEERS
 remark NTP servers R1 may sync with
 permit host 185.125.190.56
 permit host 185.125.190.57
 permit host 162.159.200.1
! Обмен только с перечисленными серверами
ntp access-group peer NTP-PEERS
```

Запросы к серверам времени проходят через экран по паре `ZP-SELF-OUTSIDE`, ответы возвращаются по сессии; дополнительных правил не

потребовалось. Примерно через 16 минут маршрутизатор сообщил о синхронизации: уровень (stratum) 3, источник 185.125.190.56 (рисунок 3.50).

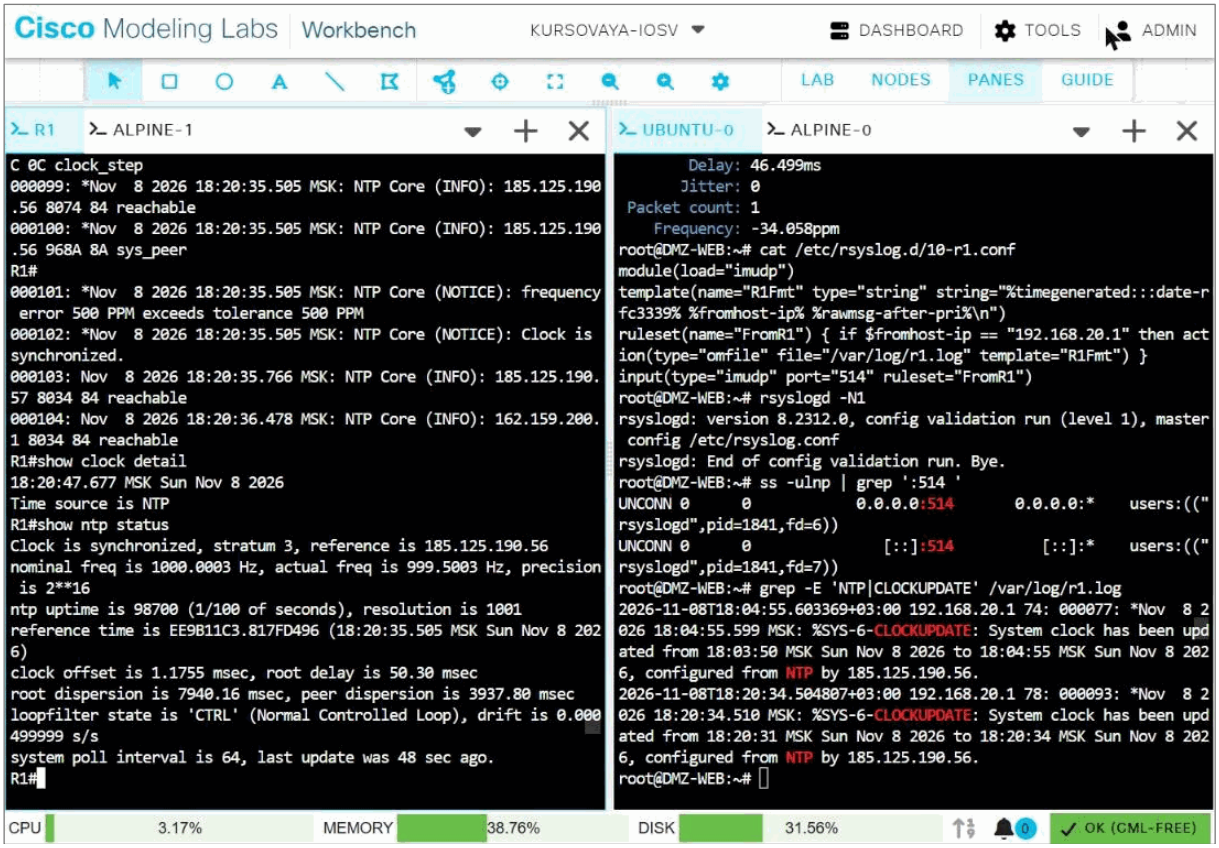


Рисунок 3.50 – Маршрутизатор синхронизирован с сервером времени

Расхождение между временем приёма записи на сервере и меткой маршрутизатора сократилось с 65,5 секунды примерно до одной секунды (рисунок 3.51). Оставшаяся секунда складывается из задержки отправки сообщения и ухода программных часов виртуального маршрутизатора; подробнее об этом сказано в подразделе 3.7.

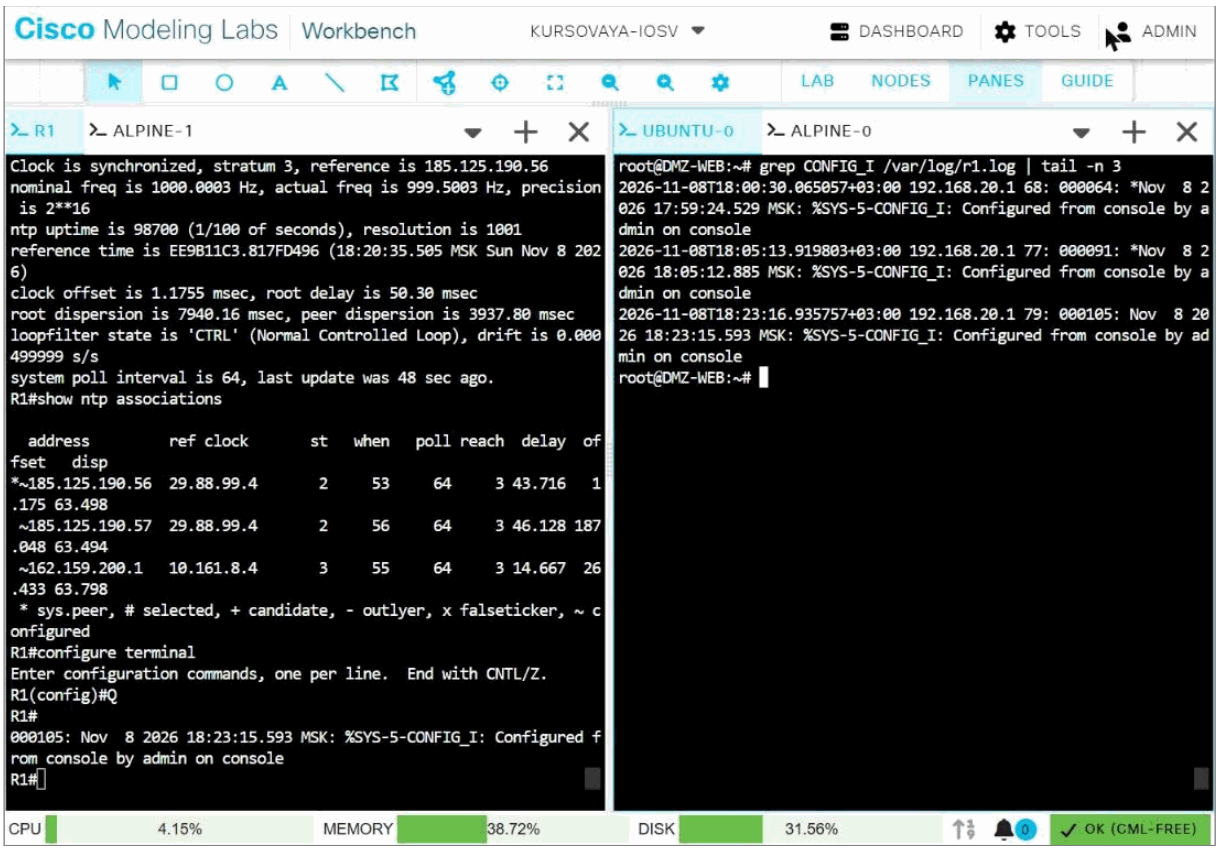


Рисунок 3.51 – После синхронизации расхождение времени сократилось до одной секунды

3.6.5. Проверка

На маршрутизаторе последовательно вызваны события разных видов: изменение конфигурации, неудачный вход, отброшенный экраном пакет, пакет с поддельным адресом, обращение к веб-серверу. Все они появились в журнале на сервере подряд, без пропусков в нумерации (рисунок 3.52).

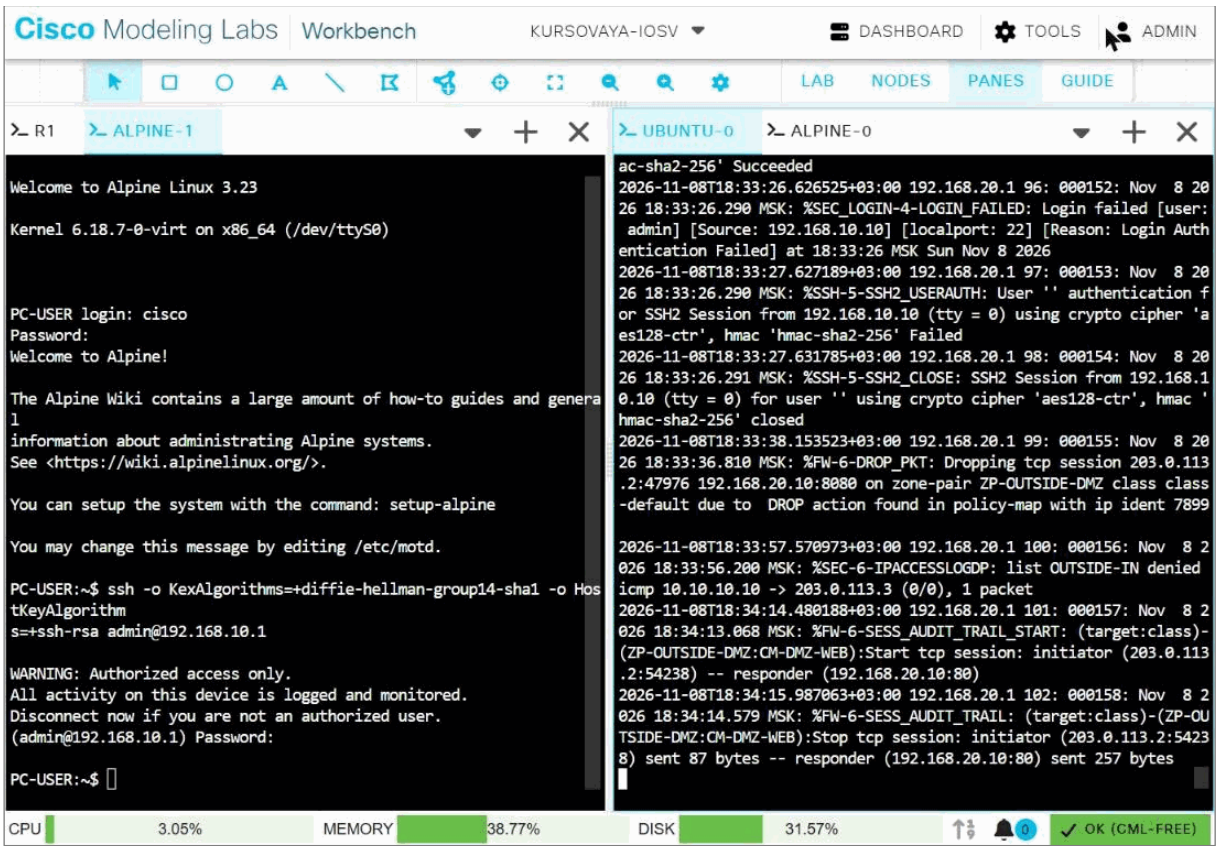


Рисунок 3.52 – События маршрутизатора в журнале на сервере

Обращение к веб-серверу маршрутизатор записал в 18:34:13.068, а веб-сервер – в 18:34:13 (рисунок 3.53). Записи двух устройств теперь относятся к одной секунде и сопоставляются однозначно.

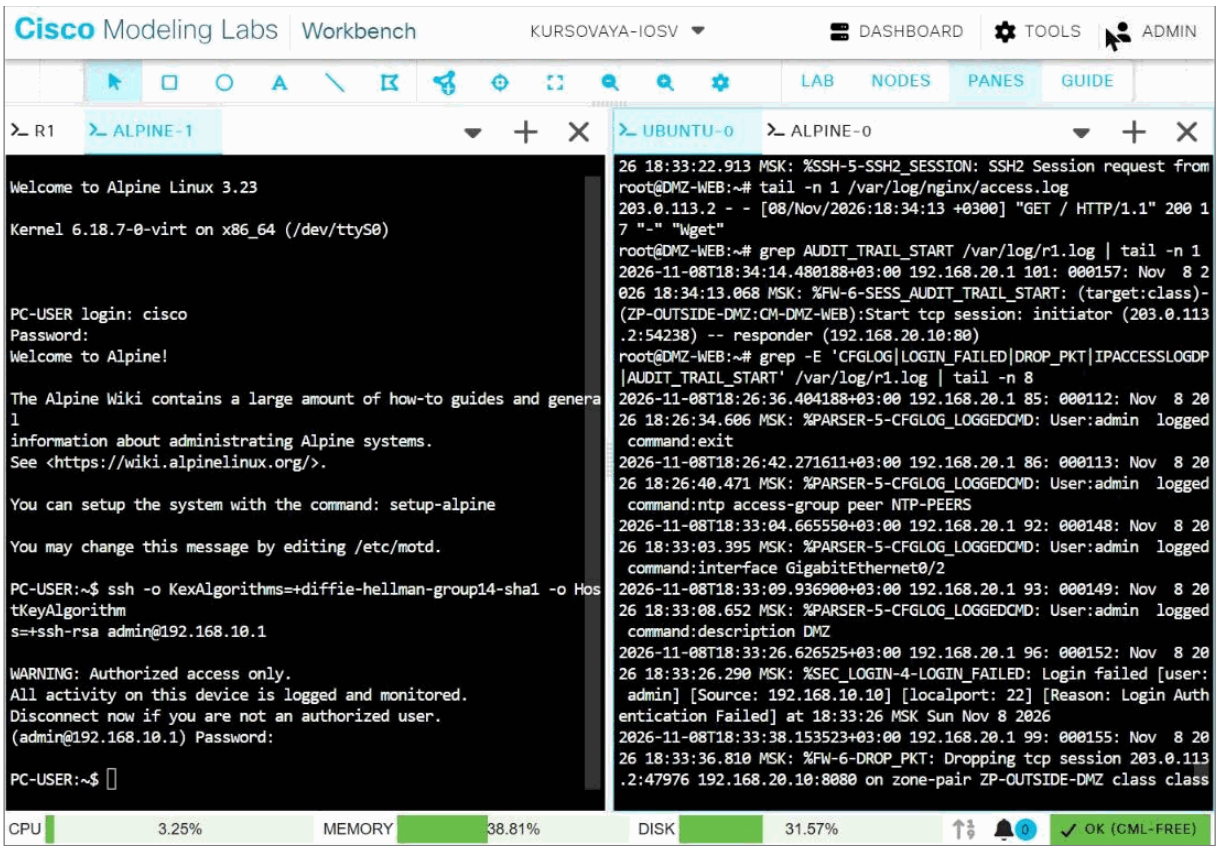


Рисунок 3.53 – R1 и веб-сервер записали обращение в одну и ту же секунду

Проверена и защита самого журнала. Узел PC-USER отправил на сервер сообщение syslog от своего имени. Пакет дошёл до сервера, но в журнал маршрутизатора не попал, поскольку пришёл с другого адреса (рисунок 3.54). Подделать адрес маршрутизатора из сети пользователей не позволяет проверка обратного пути.

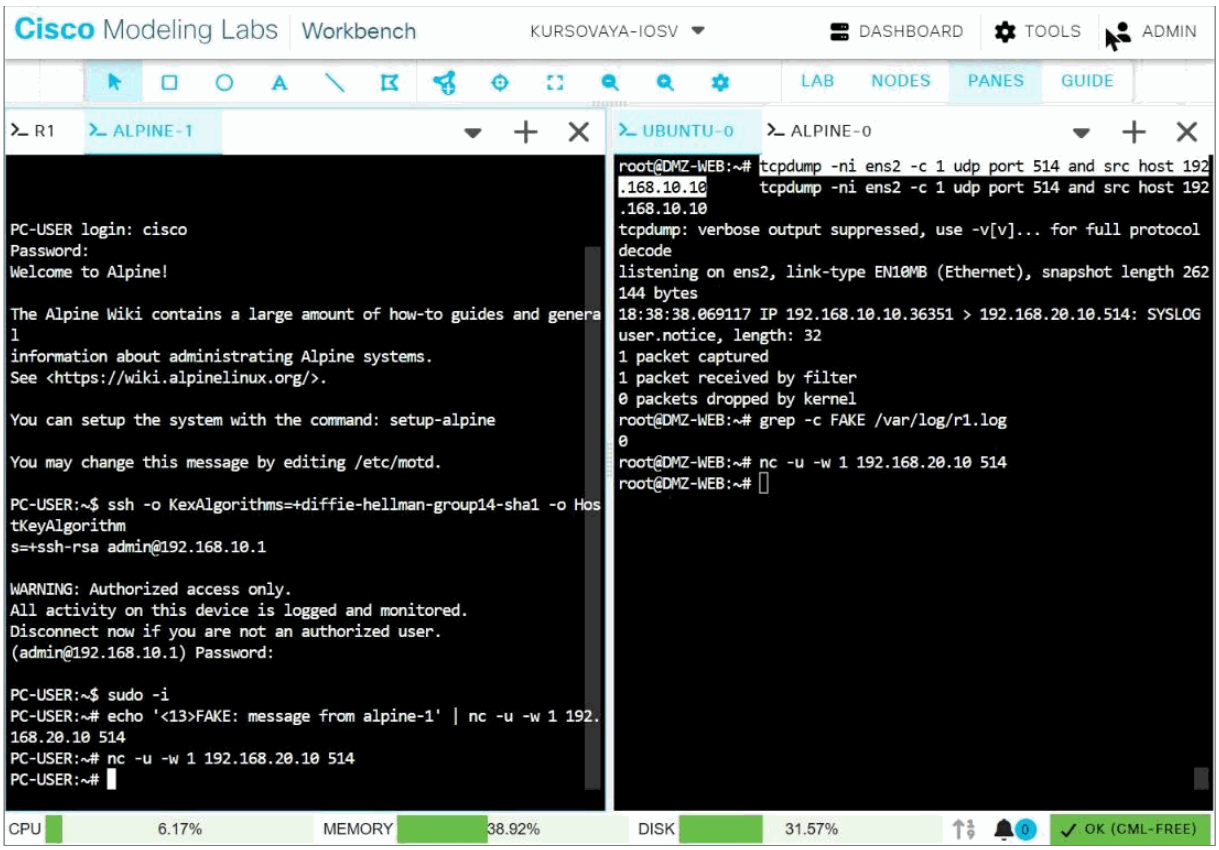


Рисунок 3.54 – Сообщение с чужого адреса в журнал маршрутизатора не принято

В завершение обновлена защищённая копия конфигурации, чтобы она включала межсетевой экран, трансляцию адресов и настройки журнала. Размер копии составил 10 188 байт.

4. ТЕСТИРОВАНИЕ ЗАЩИТЫ

Седьмой пункт задания – проверить работу защиты. Проверка состоит из двух частей. Первая часть – сводные проверки по каждому пункту задания, в которых состояние сети до настройки сравнивается с состоянием после неё. Вторая часть – испытание итоговой конфигурации атаками с внешнего узла.

4.1. Методика тестирования

Проверки выполнялись обычными сетевыми утилитами на узлах стенда: `ping`, `wget`, `curl`, `ssh`, `traceroute`, `tcpdump`. На маршрутизаторе результат контролировался командами `show`: счётчиками списков доступа и пар зон, таблицами сессий и трансляций, журналом.

Отказ в доступе считается подтверждённым, если он виден с трёх сторон. Клиент получает тайм-аут или потерю всех пакетов. Получатель не видит пакетов, что проверяется перехватом трафика или журналом службы. Маршрутизатор увеличивает счётчик отброшенных пакетов и записывает событие в журнал. Одного результата на стороне клиента недостаточно: потеря пакетов может иметь и другие причины.

Для атак использованы инструменты, применяемые при тестировании на проникновение: сканер портов nmap, генератор пакетов hping3 и программа подбора паролей hydra. Атаки проводились с узла ISP, который находится во внешней сети, то есть там же, где находился бы настоящий нарушитель. Все действия выполнялись внутри изолированного учебного стенда.

4.2. Сводные проверки по пунктам задания

Результаты защиты управления и защиты от подмены адресов сведены в таблицу 4.1.

Таблица 4.1 – Проверка защиты управления и защиты от подмены адресов

Проверка	До настройки	После настройки	Подтверждение
Вход на консоль	без имени и пароля	по учётной записи	рисунок 3.15
Пароль из 4 символов	принимается	отклонён	рисунок 3.6
Хранение паролей	паролей нет	хеш scrypt, тип 9	рисунок 3.7
SSH из сети пользователей	служба выключена	работает, версия 2	рисунок 3.10
SSH со слабым алгоритмом	–	отказ: нет общего алгоритма	рисунок 3.9
SSH из сети серверов и извне	–	отказ	запись `MGMT-ACCESS denied`, рисунок 3.12
Три неверных пароля подряд	ограничений нет	блокировка входа на 120 с	записи `QUIET_MODE_ON` и `OFF`
Изменение конфигурации	не записывается	записано с именем пользователя	рисунок 3.16
Права аудитора	–	просмотр журнала без права настройки	рисунок 3.17
Пакет из SERVERS с адресом сети USERS	доходит до DMZ	отброшен	счётчик uRPF на Gi0/0: 3
Пакет извне с адресом 10.10.10.10	R1 отвечает	отброшен	запись `OUTSIDE-IN denied`
Трассировка извне	виден адрес R1	адрес не раскрывается	рисунок 3.23

Результаты настройки межсетевого экрана приведены в таблице 4.2. Проверки выполнены сразу после настройки экрана, до настройки трансляции адресов, поэтому внешний узел обращался к серверу по его внутреннему адресу. Все шестнадцать проверок дали ожидаемый результат.

Таблица 4.2 – Проверка разграничения доступа между сегментами

№	Проверка	До настройки	После настройки	Подтверждение на R1
1	PC-USER → DMZ, веб	работает	работает	–
2	PC-SRV → DMZ, веб и ping	работает	тайм-аут, потеря 100 %	`DROP_PKT ZP-SERVERS-DMZ`, счётчик 12
3	PC-USER → PC-SRV, порт 80	работает	работает	–
4	PC-USER → PC-SRV, порт 8080	отказ узла	тайм-аут	`DROP_PKT ZP-USERS-SERVERS`
5	ping между USERS и SERVERS	в обе стороны	только из USERS	`DROP_PKT ZP-SERVERS-USERS`
6	DMZ-WEB → USERS, SERVERS	работает	потеря 100 %	`DROP_PKT ZP-DMZ-USERS`, `ZP-DMZ-SERVERS`
7	ISP → USERS, SERVERS	работает	потеря 100 %	`DROP_PKT ZP-OUTSIDE-USERS`, `ZP-OUTSIDE-SERVERS`
8	ISP → DMZ, порты 80 и 443	работает	работает	записи аудита начала и конца сессий
9	ISP → DMZ, порт 8080 и ping	работает	тайм-аут, потеря 100 %	`DROP_PKT ZP-OUTSIDE-DMZ`
10	Внутренние узлы → ISP	работает	работает	–
11	PC-USER → R1, SSH	работает	работает	сессия в `ZP-USERS-SELF`
12	PC-USER → R1, порт 23	отказ	тайм-аут	`DROP_PKT ZP-USERS-SELF`
13	PC-SRV → R1, SSH	отказ списка vty	тайм-аут	`DROP_PKT ZP-SERVERS-SELF`
14	ISP → R1, ping	R1 отвечает	потеря 100 %	`DROP_PKT ZP-OUTSIDE-SELF`
15	R1 → все узлы и 8.8.8.8	работает	работает	–
16	ISP от адреса 10.10.10.10 → R1	отброшен	отброшен	запись `OUTSIDE-IN denied`; до экрана пакет не доходит

Результаты настройки трансляции адресов приведены в таблице 4.3. Здесь также все проверки дали ожидаемый результат. Строки 12 и 13 повторяют главное требование задания уже при работающей трансляции: доступ клиентов к DMZ не изменился.

Таблица 4.3 – Проверка выхода в Интернет и публикации веб-сервера

№	Проверка	До настройки	После настройки	Подтверждение
1	PC-USER → ISP	потеря 100 %, источник 192.168.10.10	без потерь, источник 203.0.113.1	перехват на ISP, запись в таблице трансляций
2	PC-USER, PC-SRV → 8.8.8.8	потеря 100 %	без потерь	–
3	PC-USER: DNS и HTTP	не работает	имя разрешается, код 200	записи UDP 53 и TCP 80
4	DMZ-WEB → 8.8.8.8	потеря 100 %	без потерь, источник 203.0.113.3	перехват на ISP
5	Таблица трансляций	пуста	динамические записи и одна статическая	1 статическая, 7 динамических
6	MAC-адрес для 203.0.113.3 на ISP	не определяется	MAC-адрес R1	`show ip alias`
7	ISP → http://203.0.113.3	нет ответа	страница получена	записи аудита; адрес клиента в журнале nginx
8	ISP → https://203.0.113.3	нет ответа	страница получена	записи аудита
9	Порт 8080 сервера извне	–	тайм-аут	`DROP_PKT`, адрес 192.168.20.10:8080
10	ISP → ping 203.0.113.3	потеря 100 %	потеря 100 %	счётчик `ZP-OUTSIDE-DMZ`: 8 → 14
11	ISP → 203.0.113.1	потеря 100 %	тайм-аут, потеря 100 %	счётчик `ZP-OUTSIDE-SELF`: 6 → 12
12	PC-SRV → сервер DMZ	тайм-аут	тайм-аут	счётчик `ZP-SERVERS-DMZ`: 6
13	PC-USER → сервер DMZ	работает	работает	–
14	PC-USER → R1, SSH	работает	работает	запись о сессии SSH
15	ISP от адреса 10.10.10.10 → 203.0.113.3	–	потеря 100 %	запись `OUTSIDE-IN denied`: список раньше трансляции
16	R1 → все узлы и 8.8.8.8	работает	работает	–

Результаты настройки времени и журнала приведены в таблице 4.4. Пятнадцать проверок из шестнадцати выполнены полностью. Проверка 9 выполнена частично: расхождение времени составило около одной секунды при ожидаемом значении менее секунды. Причина – неточный ход программных часов виртуального маршрутизатора (подраздел 3.7).

Таблица 4.4 – Проверка учёта событий

№	Проверка	До настройки	После настройки
1	Пояс и формат меток	время по Гринвичу, не подтверждено	пояс MSK, источник времени NTP, метки с годом и миллисекундами
2	Синхронизация NTP	не включена	синхронизирован, уровень 3, смещение 0,48 мс
3	Выбор источника	–	выбран сервер 185.125.190.56
4	Список NTP-PEERS	–	совпадения по всем трём серверам
5	NTP через экран	–	счётчик отбрасываний `ZP-OUTSIDE-SELF` равен 0
6	Время сервера	Гринвич, не синхронизировано	пояс Москвы, синхронизировано
7	Приём журнала на сервере	нет	rsyslog принимает UDP 514
8	Отправка журнала с R1	только консоль и буфер	сервер 192.168.20.10, интерфейс Gi0/2
9	Расхождение времени R1 и сервера	6,5 с, позднее 65,5 с	около 1 с (выполнено частично)
10	Изменение конфигурации	только на R1	запись с именем пользователя на сервере
11	Неудачный вход	только на R1	запись с адресом источника на сервере
12	Отказ экрана	только на консоли	запись `DROP_PKT` на сервере
13	Пакет с поддельным адресом	только на R1	запись `OUTSIDE-IN denied` на сервере
14	Время R1 и веб-сервера	расходится на 6,5 с	одна и та же секунда
15	Сообщение с чужого адреса	–	до сервера дошло, в журнал R1 не записано
16	Защищённая копия конфигурации	без экрана и трансляции	обновлена, 10 188 байт

4.3. Проверка защиты атаками

Конфигурация маршрутизатора во время атак не менялась. Перед началом зафиксированы исходные значения счётчиков, чтобы приращение каждого из них можно было отнести к конкретной атаке.

4.3.1. Разведка портов маршрутизатора

Первое действие нарушителя – выяснить, какие службы доступны на пограничном устройстве. Сканирование 50 наиболее распространённых портов адреса 203.0.113.1 показало все порты в состоянии filtered: ни на один запрос маршрутизатор не ответил (рисунок 4.1). По такому результату нельзя определить ни открытые порты, ни тип устройства.

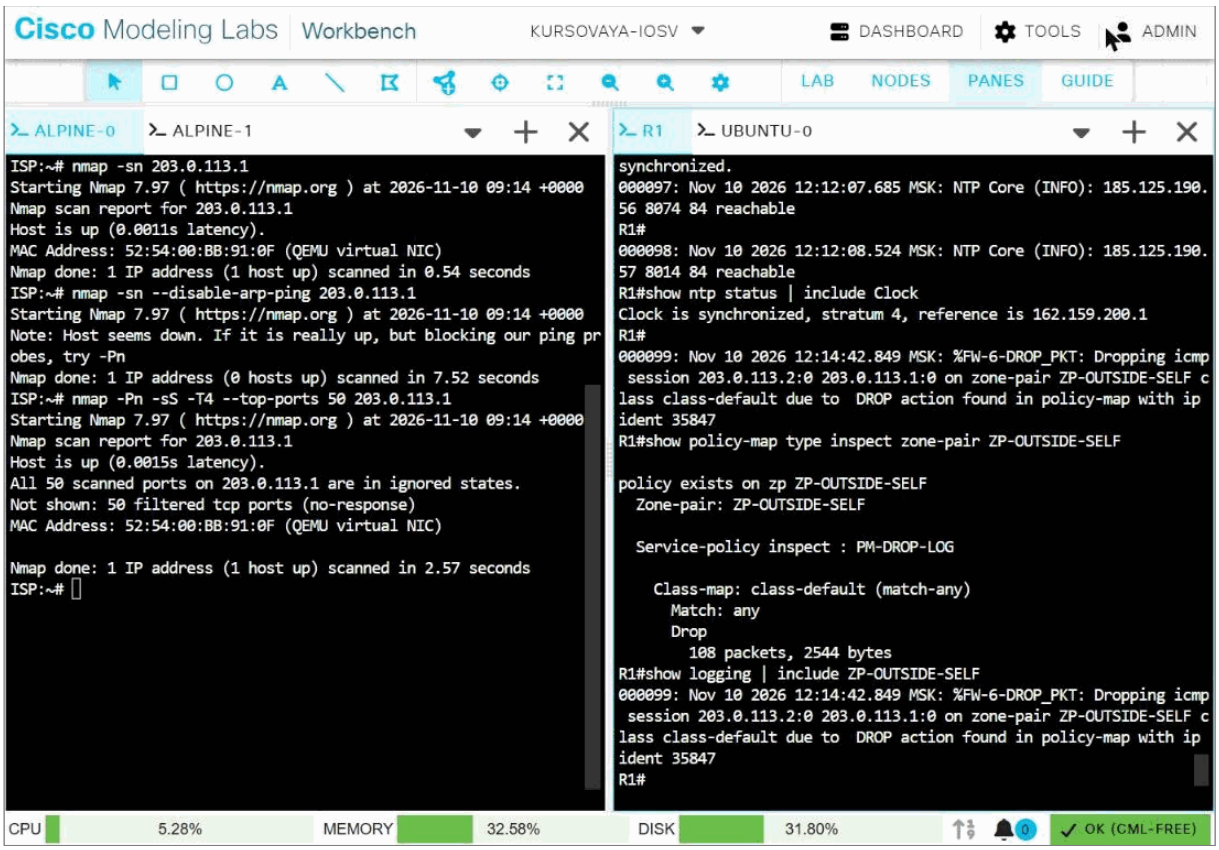


Рисунок 4.1 – Сканирование портов маршрутизатора: все порты в состоянии filtered

Счётчик отброшенных пакетов пары `ZP-OUTSIDE-SELF` вырос с 0 до 108. Это в точности число пакетов, отправленных сканером: по две пробы на каждый из 50 портов и восемь пакетов при определении доступности узла. Экран учёл каждый пакет.

При проверке доступности узла сканер сообщил, что узел активен. Это объясняется тем, что узел ISP находится в одной сети с маршрутизатором и сканер использовал запрос ARP. Протокол ARP работает ниже сетевого уровня и экраном не фильтруется, но доступен только соседу по каналу, то есть провайдеру. При запрете проб ARP сканер считает узел недоступным.

4.3.2. Разведка веб-сервера

Сканирование публичного адреса сервера с определением версий служб показало открытые порты 80 и 443. Порты 22 и 8080 находятся в состоянии filtered (рисунок 4.2). Результат соответствует политике: опубликованы только веб-службы, а управление сервером по SSH извне недоступно.

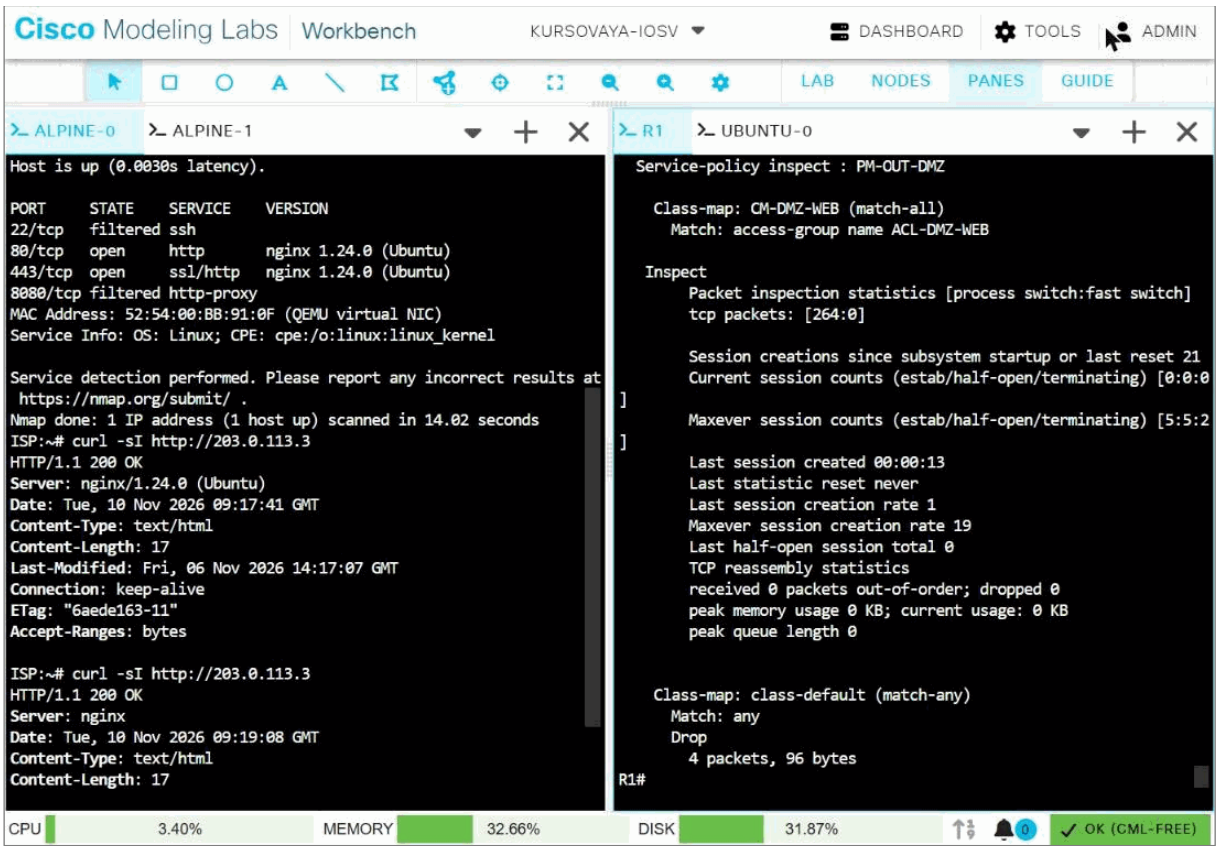


Рисунок 4.2 – Сканирование веб-сервера и сокрытие версии программы

Сканер определил точную версию веб-сервера: nginx 1.24.0. Такая информация облегчает поиск известных уязвимостей. Маршрутизатор этому помешать не может, так как версия передаётся внутри разрешённого соединения. Поэтому на самом сервере включён параметр `server_tokens off`, после чего в ответах указывается только название программы без версии. Это единственное изменение, внесённое в стенд в ходе тестирования.

4.3.3. Попытка достичь внутренних сетей

Внутренние сети имеют частные адреса, и из внешней сети обратиться к ним напрямую нельзя. Трассировка с узла ISP к адресу 192.168.10.10 уходит по маршруту по умолчанию в сторону Интернета и теряется; маршрутизатора R1 на этом пути нет. Сканирование сетей 192.168.10.0/24 и 192.168.11.0/24 не обнаружило ни одного узла. Счётчик пары `ZP-OUTSIDE-USERS` остался нулевым: пакеты до маршрутизатора не дошли. В таблице трансляций для входящих соединений существует единственная запись – статическая трансляция веб-сервера.

Внутренние сети защищены двумя независимыми способами. Трансляция адресов не даёт внешнему узлу адреса, по которому можно обратиться внутрь. Если бы у нарушителя появился маршрут к внутренним сетям, пакеты были бы отброшены экраном, что показано проверкой 7 в таблице 4.2.

4.3.4. Подмена адреса источника

С узла ISP на адрес веб-сервера отправлены пакеты, в которых источником указан сначала адрес рабочего места пользователя 192.168.10.10, а затем собственный адрес маршрутизатора 203.0.113.1. Все пакеты потеряны (рисунок 4.3). Счётчик строки списка OUTSIDE-IN для сети 192.168.0.0/16 вырос на три, счётчик строки для адреса 203.0.113.1 – также на три, по числу отправленных пакетов.

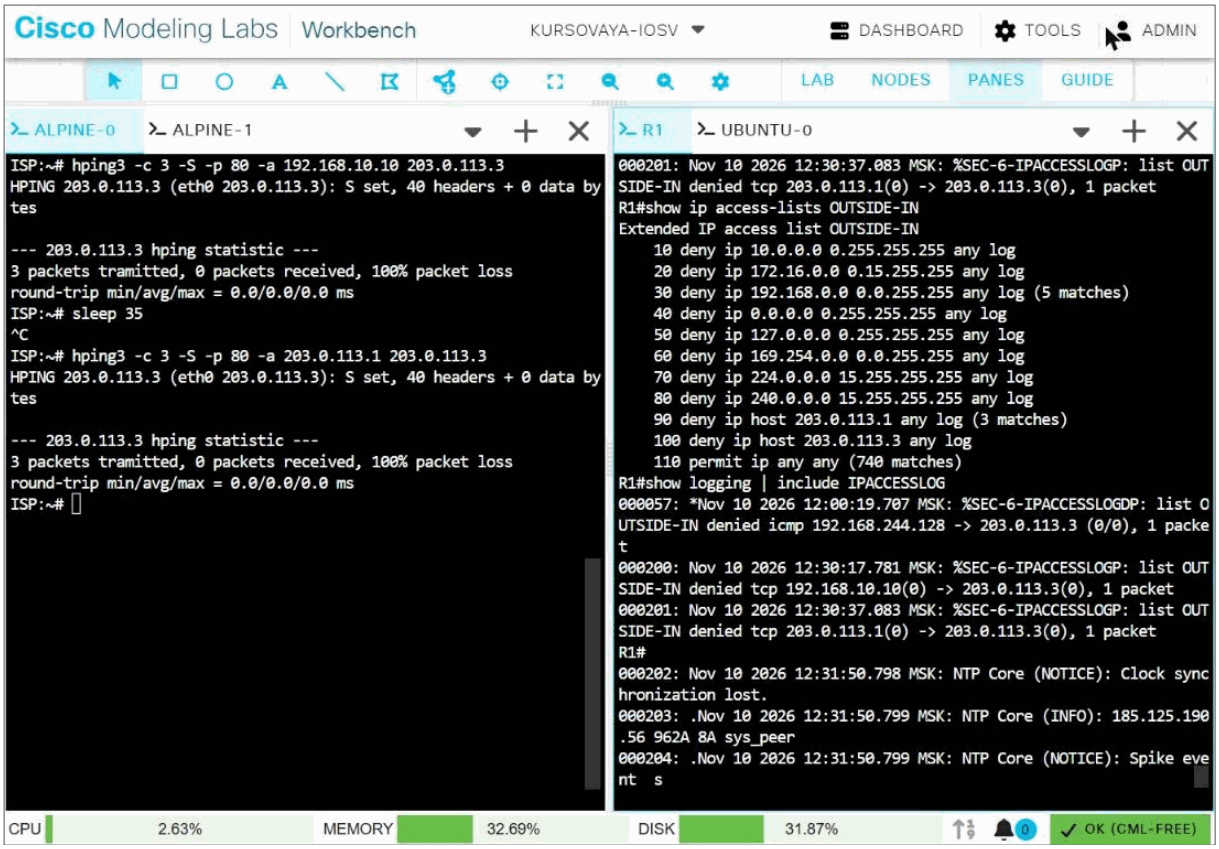


Рисунок 4.3 – Пакеты с поддельным адресом источника отброшены списком OUTSIDE-IN

На сервере DMZ во время атаки был запущен перехват трафика. За 90 секунд он не зафиксировал ни одного пакета (рисунок 4.4). Поддельные пакеты остановлены на входе маршрутизатора и до сервера не дошли.

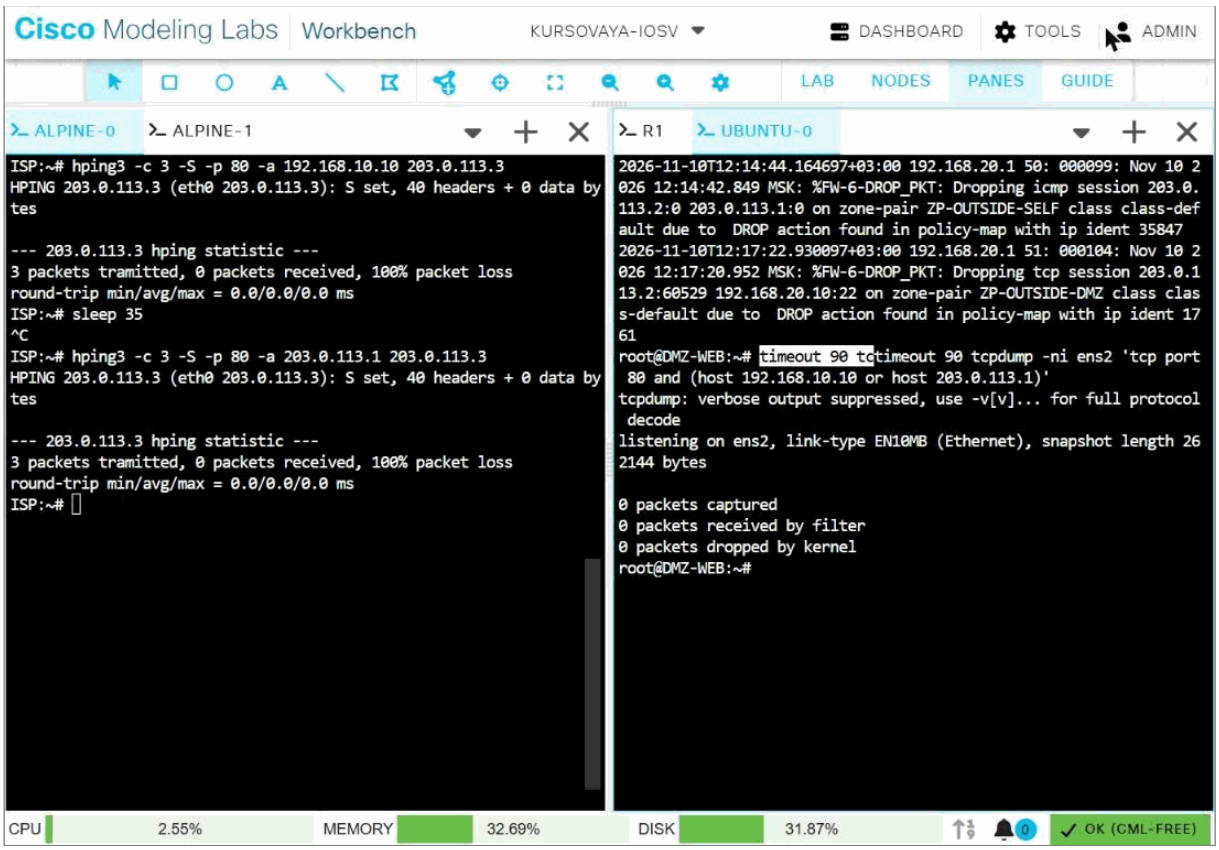


Рисунок 4.4 – Перехват на сервере DMZ: поддельные пакеты не дошли

4.3.5. Поток пакетов на закрытый порт

На закрытый порт 8080 веб-сервера отправлены серии запросов на установление соединения с высокой частотой (рисунок 4.5). Серия из 200 пакетов, отправленная за 0,02 секунды, увеличила счётчик отброшенных пакетов пары `ZP-OUTSIDE-DMZ` ровно на 200. Серия из 1000 пакетов с интервалом в одну миллисекунду увеличила его ровно на 1000. Ни один пакет не был пропущен.

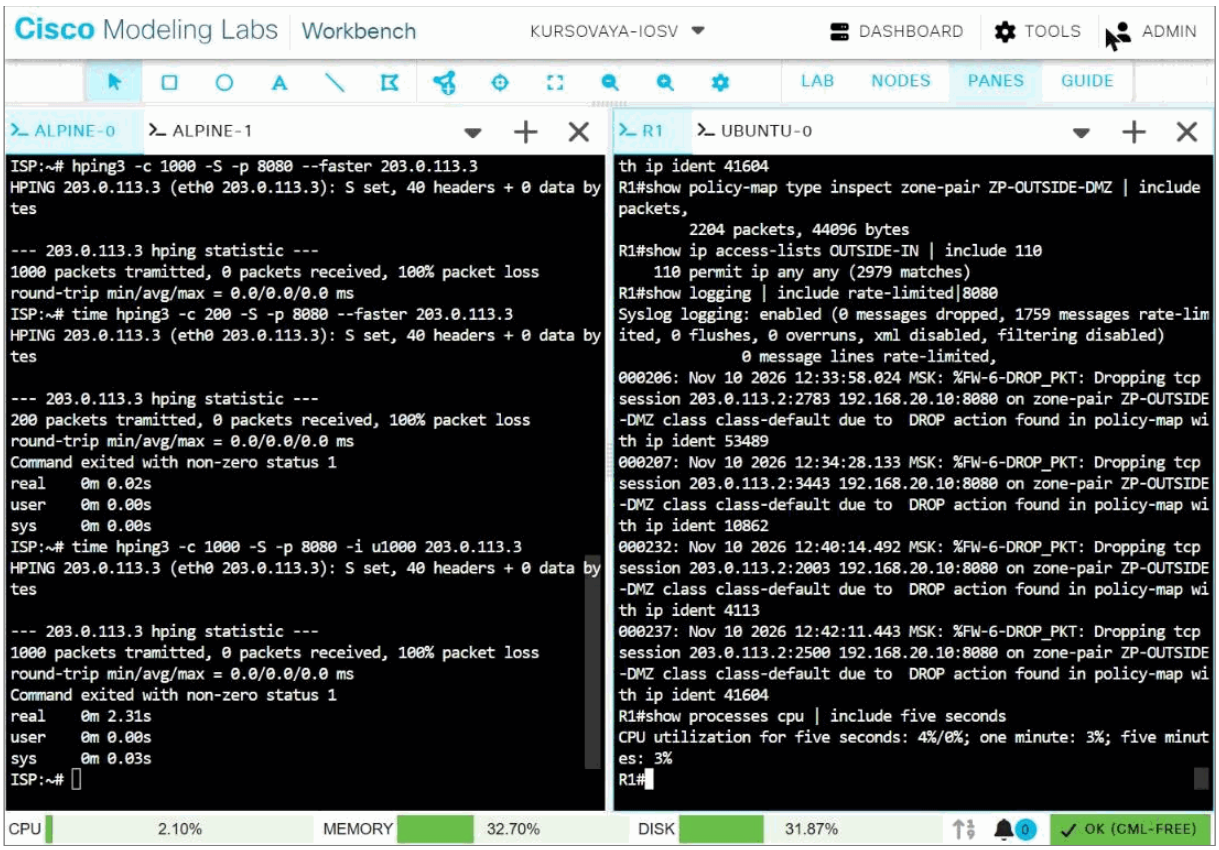


Рисунок 4.5 – Поток пакетов на закрытый порт: счётчики и ограничение журнала

На 2200 отброшенных пакетов в журнале создано четыре записи `DROP_PKT`, а счётчик сообщений, подавленных ограничением частоты, вырос с 31 до 1759. Журнал не был переполнен, и нагрузка на процессор маршрутизатора осталась на уровне 3–4 %. Управление по SSH из сети пользователей во время атаки оставалось доступным.

При отправке пакетов с максимальной скоростью пачками по 1000 до маршрутизатора доходила примерно половина: остальные терялись в виртуальном канале ещё до его интерфейса. Это наблюдение напоминает о пределе возможностей пограничного устройства. От атаки, заполняющей канал, маршрутизатор предприятия защитить не может; с ней борется провайдер.

4.3.6. Подбор пароля SSH

Программа подбора паролей запускалась дважды со списком заведомо неверных паролей. При запуске с внешнего узла соединение с маршрутизатором

не устанавливается: пакеты на порт 22 отбрасывает пара `ZP-OUTSIDE-SELF`, программа сообщает о тайм-ауте. До проверки пароля дело не доходит.

Второй запуск выполнен из сети пользователей, откуда управление разрешено. Такой сценарий соответствует заражённому рабочему месту. После трёх неудачных попыток, сделанных за две секунды, маршрутизатор перешёл в тихий режим (рисунок 4.6). Остальные попытки получили отказ в соединении. Через 120 секунд режим автоматически снят. Каждая попытка записана в журнал с адресом источника.

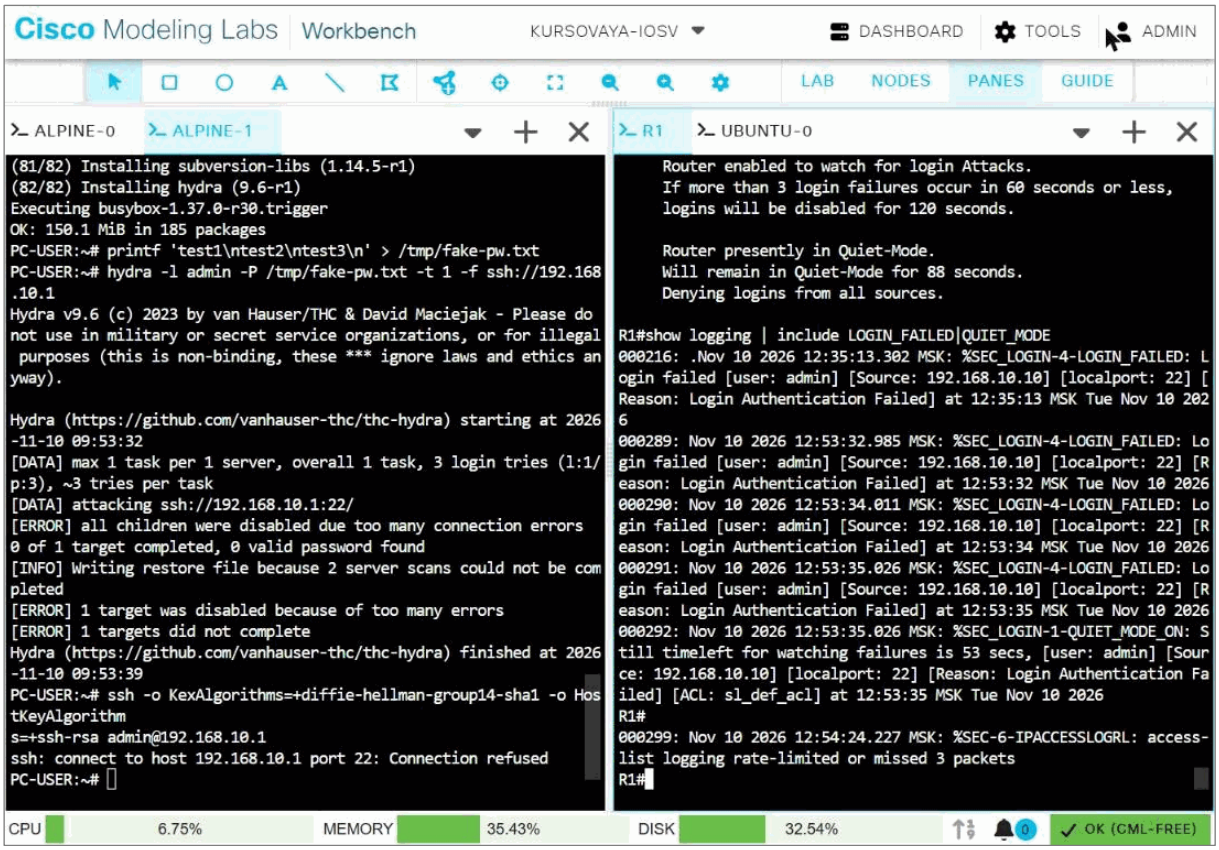


Рисунок 4.6 – Подбор пароля из сети пользователей остановлен блокировкой входа

Скорость перебора при такой защите не превышает трёх паролей за две минуты, что делает подбор по словарю практически бесполезным.

4.4. Сводная таблица угроз

Результаты атак сведены в таблицу 4.5. Для каждой угрозы указаны применённый инструмент, механизм защиты и числовое подтверждение.

Таблица 4.5 – Результаты проверки защиты атаками

Угроза	Инструмент	Механизм защиты	Результат
Разведка портов маршрутизатора	nmap	Экран, пара `ZP-OUTSIDE-SELF`	50 портов filtered; счётчик 0 → 108. Отражена
Разведка веб-сервера	nmap	Статическая трансляция и пара `ZP-OUTSIDE-DMZ`	Видны только порты 80 и 443; порты 22 и 8080 filtered
Раскрытие версии программы	curl	Параметр `server_tokens off` на сервере	Версия в ответах сервера скрыта
Выход к внутренним сетям	traceroute, nmap	Трансляция адресов и экран	Узлы недостижимы. Отражена
Подмена адреса источника	hping3	Список OUTSIDE-IN и uRPF	Счётчики +3 и +3; на сервере 0 пакетов. Отражена
Поток пакетов, перегрузка журнала	hping3	Экран и ограничение частоты журнала	Отброшены все пакеты; 4 записи на 2200 отказов; загрузка процессора 3–4 %
Подбор пароля SSH извне	hydra	Экран, пара `ZP-OUTSIDE-SELF`; список на линиях vty	Соединение не устанавливается. Отражена
Подбор пароля SSH изнутри	hydra	Блокировка входа	Тихий режим на 120 с после трёх попыток. Отражена

Все восемь проверенных угроз отражены или ограничены. В каждом случае результат подтверждён счётчиком, значение которого совпадает с числом отправленных пакетов.

4.5. Остаточные риски и направления развития

Построенная защита решает поставленную задачу, но имеет ограничения. Часть из них вызвана условиями стенда, часть – сознательными упрощениями. В реальной сети их следует устранить.

– **Размещение сервера журналов.** Журнал маршрутизатора хранится на веб-сервере DMZ, то есть на наиболее уязвимом узле. Причина – ограничение на число узлов стенда. В реальной сети сервер журналов следует разместить во внутреннем сегменте или в отдельной сети управления.

– **Передача журнала.** Сообщения передаются по UDP без шифрования и подтверждения доставки. Потери при перегрузке канала наблюдались в работе. Решение – передача журнала по TCP с шифрованием TLS [17].

– **Исходящий трафик.** Все сегменты могут обращаться в Интернет по любым протоколам, а пользователи – к любым портам сервера DMZ. Следует оставить только необходимые протоколы, в первую очередь для серверов и DMZ.

– **Блокировка входа.** В тихом режиме подключиться по SSH не может и сам администратор; остаётся только консоль. Команда `login quiet-mode access-class` позволяет сохранить доступ для адреса администратора. Кроме того, управление разрешено из всей сети пользователей, тогда как правильнее выделить для него отдельный узел или сеть.

– **Учётные записи.** Используются локальные учётные записи и вход по паролю. В сети с несколькими устройствами применяют централизованную аутентификацию (RADIUS, TACACS+) и вход по ключам.

– **Криптография SSH.** Обмен ключами на основе SHA-1 устарел. Устранить это можно только переходом на платформу с IOS XE.

– **Источники времени.** Обмен с серверами NTP не аутентифицируется: общедоступные серверы не поддерживают ключи, а более новый протокол защиты времени в IOS 15.9 отсутствует.

– **Единая точка отказа.** Вся защита сосредоточена на одном устройстве. Его отказ останавливает сеть, а ошибка в его настройке открывает её целиком.

– **Уровень приложений.** Экран проверяет адреса и порты, но не содержимое. Атака на веб-приложение через порт 443 пройдёт беспрепятственно. Для защиты нужны своевременные обновления сервера и средства анализа содержимого.

– **Канальный уровень.** В стенде нет коммутаторов, поэтому защита от атак внутри сегмента не рассматривалась.

ЗАКЛЮЧЕНИЕ

В курсовой работе на маршрутизаторе Cisco под управлением IOS 15.9 организован защищённый сегмент сети малого предприятия с демилитаризованной зоной и выходом в Интернет. Работа выполнена на виртуальном стенде в среде Cisco Modeling Labs. Все семь пунктов задания выполнены.

Сеть разделена на сегмент пользователей, сегмент внутренних серверов, демилитаризованную зону и внешнюю сеть. Маршрутизатор расположен между сегментами и контролирует весь обмен между ними. Главное требование задания выполнено и подтверждено: клиент из сегмента пользователей имеет доступ в DMZ, а клиент из сегмента серверов не имеет.

На маршрутизаторе последовательно настроены:

– защита управления: пароли в виде хеша scrypt, SSH версии 2 с ограниченным набором алгоритмов, доступ только из сети пользователей, блокировка при подборе пароля, разграничение прав, журнал изменений конфигурации;

– защита от подмены адресов: проверка обратного пути на всех интерфейсах и входной список доступа на внешнем интерфейсе;

– межсетевой экран на зонах: четыре зоны, двадцать пар зон, запрет по умолчанию, защита самого маршрутизатора;

– трансляция адресов: выход внутренних сетей в Интернет под одним адресом и публикация веб-сервера под отдельным адресом;

– учёт событий: синхронизация времени по NTP и хранение журнала на отдельном сервере.

Каждая мера проверена сравнением состояния сети до и после настройки. Итоговая конфигурация испытана восемью атаками с внешнего узла: сканированием портов, подменой адреса, потоком пакетов и подбором пароля. Все атаки отражены или ограничены, причём показания счётчиков маршрутизатора совпали с числом отправленных пакетов.

В ходе работы выявлены ограничения выбранной платформы: устаревшие алгоритмы обмена ключами SSH, отсутствие отдельных функций защиты управления, неточный ход часов виртуального маршрутизатора. Для каждого ограничения найдено решение или оно явно отмечено. Определены и остаточные риски: размещение сервера журналов в DMZ, неограниченный исходящий трафик, передача журнала без шифрования. Их устранение составляет направление дальнейшего развития работы.

В результате закреплены знания о сегментации сетей, фильтрации трафика, трансляции адресов и защите сетевых устройств и получены практические навыки настройки и проверки этих механизмов на оборудовании Cisco. Цель работы достигнута.

СПИСОК ИСПОЛЬЗОВАННОЙ ЛИТЕРАТУРЫ

1. Олифер В. Г., Олифер Н. А. Компьютерные сети. Принципы, технологии, протоколы: учебник для вузов. 5-е изд. СПб.: Питер, 2016. 992 с.

2. Таненбаум Э., Уэзеролл Д. Компьютерные сети. 5-е изд. СПб.: Питер, 2012. 960 с.

3. Odom W. CCNA 200-301 Official Cert Guide. Volume 2. Indianapolis: Cisco Press, 2019.

4. Santos O., Stuppi J. CCNA Security 210-260 Official Cert Guide. Indianapolis: Cisco Press, 2015.

5. Harden IOS Devices. Document ID 13608 // Cisco Systems. URL: https://www.cisco.com/c/en/us/support/docs/ip/access-lists/13608-21.html (дата обращения: 10.11.2026).

6. Understand the Zone-Based Policy Firewall Design. Document ID 98628 // Cisco Systems. URL: https://www.cisco.com/c/en/us/support/docs/security/ios-firewall/98628-zone-design-guide.html (дата обращения: 10.11.2026).

7. Understand the NAT Order of Operation. Document ID 6209 // Cisco Systems. URL: https://www.cisco.com/c/en/us/support/docs/ip/network-address-translation-nat/6209-5.html (дата обращения: 10.11.2026).

8. Cisco Modeling Labs Documentation // Cisco DevNet. URL: https://developer.cisco.com/docs/modeling-labs/ (дата обращения: 10.11.2026).

9. Rekhter Y., Moskowitz B., Karrenberg D., de Groot G. J., Lear E. Address Allocation for Private Internets. RFC 1918. 1996. URL: https://www.rfc-editor.org/rfc/rfc1918 (дата обращения: 10.11.2026).

10. Ferguson P., Senie D. Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing. RFC 2827 (BCP 38). 2000. URL: https://www.rfc-editor.org/rfc/rfc2827 (дата обращения: 10.11.2026).

11. Baker F., Savola P. Ingress Filtering for Multihomed Networks. RFC 3704 (BCP 84). 2004. URL: https://www.rfc-editor.org/rfc/rfc3704 (дата обращения: 10.11.2026).

12. Arkko J., Cotton M., Vegoda L. IPv4 Address Blocks Reserved for Documentation. RFC 5737. 2010. URL: https://www.rfc-editor.org/rfc/rfc5737 (дата обращения: 10.11.2026).

13. Srisuresh P., Egevang K. Traditional IP Network Address Translator (Traditional NAT). RFC 3022. 2001. URL: https://www.rfc-editor.org/rfc/rfc3022 (дата обращения: 10.11.2026).

14. Ylonen T., Lonvick C. The Secure Shell (SSH) Transport Layer Protocol. RFC 4253. 2006. URL: https://www.rfc-editor.org/rfc/rfc4253 (дата обращения: 10.11.2026).

15. Percival C., Josefsson S. The scrypt Password-Based Key Derivation Function. RFC 7914. 2016. URL: https://www.rfc-editor.org/rfc/rfc7914 (дата обращения: 10.11.2026).

16. Gerhards R. The Syslog Protocol. RFC 5424. 2009. URL: https://www.rfc-editor.org/rfc/rfc5424 (дата обращения: 10.11.2026).

17. Miao F., Ma Y., Salowey J. Transport Layer Security (TLS) Transport Mapping for Syslog. RFC 5425. 2009. URL: https://www.rfc-editor.org/rfc/rfc5425 (дата обращения: 10.11.2026).

18. Mills D., Martin J., Burbank J., Kasch W. Network Time Protocol Version 4: Protocol and Algorithms Specification. RFC 5905. 2010. URL: https://www.rfc-editor.org/rfc/rfc5905 (дата обращения: 10.11.2026).

19. Scarfone K., Hoffman P. Guidelines on Firewalls and Firewall Policy. NIST Special Publication 800-41 Revision 1. Gaithersburg: NIST, 2009.

ПРИЛОЖЕНИЕ А. ПОЛНАЯ КОНФИГУРАЦИЯ МАРШРУТИЗАТОРА R1

Ниже приведён вывод команды `show running-config` после выполнения всех пунктов задания. Значения хешей паролей скрыты. Баннеры `exec` и `incoming` являются частью образа IOSv и в работе не изменялись.

Листинг А.1 – Конфигурация R1

```
Building configuration...

Current configuration : 10187 bytes
!
! Last configuration change at 18:41:52 MSK Sun Nov 8 2026 by admin
! NVRAM config last updated at 18:44:17 MSK Sun Nov 8 2026 by admin
!
version 15.9
no service pad
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone year
service timestamps log datetime msec localtime show-timezone year
service password-encryption
service sequence-numbers
!
hostname R1
!
boot-start-marker
boot-end-marker
!
!
security passwords min-length 10
logging buffered 64000 informational
logging rate-limit 100 except warnings
enable secret 9 $9$<ХЕШ>
!
no aaa new-model
!
!
!
clock timezone MSK 3 0
mmi polling-interval 60
no mmi auto-configure
no mmi pvc
mmi snmp-timeout 180
!
!
!
!
!
no ip source-route
!
!
!
!
!
!
no ip bootp server
no ip domain lookup
ip domain name lab.local
ip cef
login block-for 120 attempts 3 within 60
login on-failure log
```

```
login on-success log
no ipv6 cef
!
parameter-map type inspect PAR-AUDIT
 audit-trail on
multilink bundle-name authenticated
!
!
!
!
archive
 log config
  logging enable
  logging size 200
  notify syslog contenttype plaintext
  hidekeys
username admin privilege 15 secret 9 $9$<XE▯▯>
username auditor privilege 5 secret 9 $9$<XE▯▯>
secure boot-config
!
redundancy
!
no cdp run
!
!
class-map type inspect match-all CM-DMZ-WEB
 match access-group name ACL-DMZ-WEB
class-map type inspect match-all CM-USERS-SRV
 match access-group name ACL-USERS-SRV
class-map type inspect match-any CM-ICMP
 match protocol icmp
class-map type inspect match-all CM-MGMT-SSH
 match protocol tcp
 match access-group name ACL-MGMT-SSH
class-map type inspect match-any CM-ALL
 match protocol tcp
 match protocol udp
 match protocol icmp
!
policy-map type inspect PM-INSIDE-SELF
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
policy-map type inspect PM-USERS-SELF
 class type inspect CM-MGMT-SSH
  inspect
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
policy-map type inspect PM-OUT-DMZ
 class type inspect CM-DMZ-WEB
  inspect PAR-AUDIT
 class class-default
  drop log
policy-map type inspect PM-INSPECT-ALL
 class type inspect CM-ALL
  inspect
 class class-default
  drop log
policy-map type inspect PM-USERS-SRV
 class type inspect CM-USERS-SRV
  inspect
 class class-default
  drop log
policy-map type inspect PM-SELF-OUT
 class type inspect CM-ALL
  inspect
 class class-default
```

```
  drop log
policy-map type inspect PM-DROP-LOG
 class class-default
  drop log
!
zone security USERS
zone security SERVERS
zone security DMZ
zone security OUTSIDE
zone-pair security ZP-USERS-SERVERS source USERS destination SERVERS
 service-policy type inspect PM-USERS-SRV
zone-pair security ZP-USERS-DMZ source USERS destination DMZ
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-USERS-OUTSIDE source USERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-SERVERS-OUTSIDE source SERVERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-DMZ-OUTSIDE source DMZ destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-OUTSIDE-DMZ source OUTSIDE destination DMZ
 service-policy type inspect PM-OUT-DMZ
zone-pair security ZP-SERVERS-USERS source SERVERS destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SERVERS-DMZ source SERVERS destination DMZ
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-USERS source DMZ destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-SERVERS source DMZ destination SERVERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-USERS source OUTSIDE destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-SERVERS source OUTSIDE destination SERVERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-SELF source OUTSIDE destination self
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SELF-OUTSIDE source self destination OUTSIDE
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-SERVERS-SELF source SERVERS destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-SERVERS source self destination SERVERS
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-DMZ-SELF source DMZ destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-DMZ source self destination DMZ
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-USERS-SELF source USERS destination self
 service-policy type inspect PM-USERS-SELF
zone-pair security ZP-SELF-USERS source self destination USERS
 service-policy type inspect PM-SELF-OUT
!
interface GigabitEthernet0/0
 description INSIDE-SERVERS
 ip address 192.168.11.1 255.255.255.0
 ip nat inside
 ip virtual-reassembly in
 ip verify unicast source reachable-via rx
 zone-member security SERVERS
 duplex auto
 speed auto
 media-type rj45
!
interface GigabitEthernet0/1
 description INSIDE-USERS
 ip address 192.168.10.1 255.255.255.0
 ip nat inside
 ip virtual-reassembly in
 ip verify unicast source reachable-via rx
 zone-member security USERS
 duplex auto
 speed auto
```

```
 media-type rj45
!
interface GigabitEthernet0/2
 description DMZ
 ip address 192.168.20.1 255.255.255.0
 ip nat inside
 ip virtual-reassembly in
 ip verify unicast source reachable-via rx
 zone-member security DMZ
 duplex auto
 speed auto
 media-type rj45
!
interface GigabitEthernet0/3
 description OUTSIDE
 ip address 203.0.113.1 255.255.255.248
 ip access-group OUTSIDE-IN in
 no ip redirects
 no ip unreachables
 no ip proxy-arp
 ip nat outside
 ip virtual-reassembly in
 ip verify unicast source reachable-via rx allow-default
 zone-member security OUTSIDE
 duplex auto
 speed auto
 media-type rj45
!
ip forward-protocol nd
!
!
no ip http server
no ip http secure-server
ip nat inside source list NAT-INSIDE interface GigabitEthernet0/3 overload
ip nat inside source static 192.168.20.10 203.0.113.3
ip route 0.0.0.0 0.0.0.0 203.0.113.2
ip ssh time-out 60
ip ssh rsa keypair-name R1.lab.local
ip ssh logging events
ip ssh version 2
ip ssh server algorithm mac hmac-sha2-512 hmac-sha2-256
ip ssh server algorithm encryption aes256-ctr aes192-ctr aes128-ctr
ip ssh server algorithm kex diffie-hellman-group14-sha1
!
ip access-list standard MGMT-ACCESS
 permit 192.168.10.0 0.0.0.255
 deny   any log
ip access-list standard NAT-INSIDE
 remark Inside networks translated by PAT
 permit 192.168.10.0 0.0.0.255
 permit 192.168.11.0 0.0.0.255
 permit 192.168.20.0 0.0.0.255
ip access-list standard NTP-PEERS
 remark NTP servers R1 may sync with
 permit 185.125.190.56
 permit 185.125.190.57
 permit 162.159.200.1
!
ip access-list extended ACL-DMZ-WEB
 remark OUTSIDE to DMZ: published web server only (real address)
 permit tcp any host 192.168.20.10 eq www
 permit tcp any host 192.168.20.10 eq 443
ip access-list extended ACL-MGMT-SSH
 remark USERS to R1: SSH only (vty access-class still applies)
 permit tcp 192.168.10.0 0.0.0.255 any eq 22
ip access-list extended ACL-USERS-SRV
 remark USERS to SERVERS: admin and service ports only
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 22
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq www
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 443
```

```
 permit icmp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 echo
ip access-list extended OUTSIDE-IN
 remark Anti-spoofing: private sources (RFC 1918)
 deny   ip 10.0.0.0 0.255.255.255 any log
 deny   ip 172.16.0.0 0.15.255.255 any log
 deny   ip 192.168.0.0 0.0.255.255 any log
 remark Anti-spoofing: special-use sources
 deny   ip 0.0.0.0 0.255.255.255 any log
 deny   ip 127.0.0.0 0.255.255.255 any log
 deny   ip 169.254.0.0 0.0.255.255 any log
 deny   ip 224.0.0.0 15.255.255.255 any log
 deny   ip 240.0.0.0 15.255.255.255 any log
 remark Anti-spoofing: our own addresses
 deny   ip host 203.0.113.1 any log
 deny   ip host 203.0.113.3 any log
 remark Everything else passes (who-can-go-where is stage 5)
 permit ip any any
!
ip access-list logging interval 10
logging source-interface GigabitEthernet0/2
logging host 192.168.20.10
ipv6 ioam timestamp
!
!
control-plane host
!
!
control-plane
!
privilege exec level 5 show logging
privilege exec level 5 show
banner exec ^C
**************************************************************************
* IOSv is strictly limited to use for evaluation, demonstration and IOS  *
* education. IOSv is provided as-is and is not supported by Cisco's      *
* Technical Advisory Center. Any use or disclosure, in whole or in part, *
* of the IOSv Software or Documentation to any third party for any       *
* purposes is expressly prohibited except as otherwise authorized by     *
* Cisco in writing.                                                      *
**************************************************************************^C
banner incoming ^C
**************************************************************************
* IOSv is strictly limited to use for evaluation, demonstration and IOS  *
* education. IOSv is provided as-is and is not supported by Cisco's      *
* Technical Advisory Center. Any use or disclosure, in whole or in part, *
* of the IOSv Software or Documentation to any third party for any       *
* purposes is expressly prohibited except as otherwise authorized by     *
* Cisco in writing.                                                      *
**************************************************************************^C
banner login ^C
WARNING: Authorized access only.
All activity on this device is logged and monitored.
Disconnect now if you are not an authorized user.
^C
!
line con 0
 logging synchronous
 login local
line aux 0
line vty 0 4
 access-class MGMT-ACCESS in
 exec-timeout 5 0
 login local
 transport input ssh
!
no scheduler allocate
ntp logging
ntp access-group peer NTP-PEERS
ntp server 185.125.190.56 prefer
ntp server 185.125.190.57
```

```
ntp server 162.159.200.1
!
end
```

ПРИЛОЖЕНИЕ Б. НАСТРОЙКА УЗЛОВ СТЕНДА

В приложении приведены настройки узлов, необходимые для воспроизведения стенда.

Листинг Б.1 – Узел ISP (alpine-0): адреса, пересылка пакетов и трансляция в сторону Интернета

```
# /etc/network/interfaces
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet static
    address 203.0.113.2/29

auto eth1
iface eth1 inet dhcp

# /etc/local.d/isp.start - выполняется при загрузке
#!/bin/sh
sysctl -w net.ipv4.ip_forward=1
iptables -t nat -C POSTROUTING -o eth1 -j MASQUERADE 2>/dev/null || \
  iptables -t nat -A POSTROUTING -o eth1 -j MASQUERADE

# Инструменты для проверок
apk add iptables tcpdump curl nmap nmap-nselibs nmap-scripts hydra
apk add hping3 --repository=https://dl-cdn.alpinelinux.org/alpine/edge/testing
```

Листинг Б.2 – Узлы PC-USER (alpine-1) и PC-SRV (alpine-2)

```
# PC-USER: /etc/network/interfaces
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet static
    address 192.168.10.10/24
    gateway 192.168.10.1

# PC-SRV: то же с адресом 192.168.11.10/24 и шлюзом 192.168.11.1

# Оба узла: /etc/resolv.conf
nameserver 8.8.8.8
```

Листинг Б.3 – Узел DMZ-WEB (ubuntu-0): сеть

```
# /etc/netplan/99-lab.yaml
network:
  version: 2
  ethernets:
    ens2:
      dhcp4: false
      addresses: [192.168.20.10/24]
      routes:
        - to: default
          via: 192.168.20.1
      nameservers:
        addresses: [8.8.8.8]
```

Листинг Б.4 – Узел DMZ-WEB: веб-сервер nginx

```
apt-get update
apt-get install -y nginx
echo 'DMZ-WEB nginx OK' > /var/www/html/index.html

# Самоподписанный сертификат для HTTPS
openssl req -x509 -nodes -newkey rsa:2048 -days 365 \
  -keyout /etc/ssl/private/dmz-web.key \
  -out /etc/ssl/certs/dmz-web.crt -subj "/CN=203.0.113.3"

# /etc/nginx/conf.d/dmz-https.conf
server {
    listen 443 ssl;
    server_name _;
    ssl_certificate /etc/ssl/certs/dmz-web.crt;
    ssl_certificate_key /etc/ssl/private/dmz-web.key;
    root /var/www/html;
    index index.html;
}

# /etc/nginx/conf.d/00-server-tokens.conf - не сообщать версию
server_tokens off;

nginx -t
systemctl reload nginx
```

Листинг Б.5 – Узел DMZ-WEB: приём журнала маршрутизатора

```
timedatectl set-timezone Europe/Moscow

# /etc/rsyslog.d/10-r1.conf
module(load="imudp")
template(name="R1Fmt" type="string"
  string="%timegenerated:::date-rfc3339% %fromhost-ip% %rawmsg-after-pri%\n")
# В файл попадают только сообщения с адреса R1
ruleset(name="FromR1") {
  if $fromhost-ip == "192.168.20.1" then
    action(type="omfile" file="/var/log/r1.log" template="R1Fmt")
}
input(type="imudp" port="514" ruleset="FromR1")

rsyslogd -N1
systemctl restart rsyslog
```